DetectKB

راهنمای کاربری

پایگاه دانش مهندسی تشخیص

ویرایش ۲ · مهر ۱۴۰۵

فهرست فصل‌ها

فصل ۱ آشنایی با DetectKB

فصل ۲ شروع کار

فصل ۳ قوانین تشخیص

فصل ۴ ورود و خروج قوانین

فصل ۵ پوشش MITRE ATT&CK

فصل ۶ رویدادهای Sysmon

فصل ۷ منابع لاگ

فصل ۸ ابزارهای مهاجم

فصل ۹ گروه‌های تهدید و بدافزارها

فصل ۱۰ سناریوهای تحلیلی Splunk

فصل ۱۱ Atomic Red Team و اعتبارسنجی در لب

فصل ۱۲ گراف دانش

فصل ۱۳ صفحات دانش

فصل ۱۴ جست‌وجو و مستندسازی

فصل ۱۵ مدیریت سامانه

فصل ۱۶ میانبرهای صفحه‌کلید و ظاهر

فصل ۱۷ پرسش‌های رایج و عیب‌یابی

درباره‌ی این راهنما. این راهنما کار با همه‌ی بخش‌های DetectKB را قدم‌به‌قدم توضیح می‌دهد. رابط کاربری سامانه انگلیسی است؛ برای اینکه دکمه‌ها و منوها را راحت پیدا کنید، نام آن‌ها دقیقاً همان‌طور که روی صفحه دیده می‌شوند به‌صورت **پررنگ** آمده است، مثل **Import rules**. کلیدهای صفحه‌کلید و مقادیر فنی به شکل `Ctrl+K` نوشته شده‌اند.

تصاویر از محیط آزمایشی با حدود ۲۱۰۰ قانون واقعی از مخزن‌های عمومی Elastic، Splunk ESCU، Sigma و Microsoft Sentinel گرفته شده‌اند. عددهای داخل تصاویر مربوط به همان داده‌ی نمونه است.

فصل ۱ — آشنایی با DetectKB

DetectKB یک پایگاه دانش برای تیم‌های مهندسی تشخیص (Detection Engineering) است. قوانین تشخیص، دانش پشت آن‌ها و منابع داده‌ای که به آن تکیه دارند در یک جا نگه داشته می‌شوند. سامانه از روی این داده‌ها نشان می‌دهد در برابر کدام تکنیک‌های مهاجم پوشش داریم، هر تشخیص به کدام داده وابسته است و کجا شکاف داریم.

مفاهیم پایه

مفهوم	توضیح
قانون تشخیص (Rule)	یک منطق شناسایی رفتار مخرب، همراه با کوئری (EQL، KQL، SPL یا Sigma)، شدت، وضعیت، تکنیک‌های ATT&CK و منبع داده.
وضعیت (Status)	`draft` پیش‌نویس · `testing` در حال تست · `production` فعال در محیط عملیاتی · `deprecated` کنار گذاشته‌شده.
شدت (Severity)	`info` · `low` · `medium` · `high` · `critical`
تکنیک ATT&CK	شناسه‌ی تکنیک مهاجم در چارچوب MITRE ATT&CK، مثل `T1003.001` (استخراج حافظه‌ی LSASS). سامانه از نسخه‌ی v19.2 استفاده می‌کند.
رویداد Sysmon	نوع رویدادی که Sysmon ثبت می‌کند، مثل `EID 1` (ساخت پروسه) یا `EID 10` (دسترسی به پروسه).
منبع داده (Data Source)	جایی که لاگ از آن می‌آید، مثل Sysmon Operational Log. در سامانه به شکل یک صفحه‌ی دانش ثبت می‌شود.
ابزار مهاجم	فایل‌های مجاز سیستم‌عامل که مهاجم از آن‌ها سوءاستفاده می‌کند، از مخزن‌های LOLBAS، GTFOBins و LOLDrivers.
صفحه‌ی دانش (Page)	هر محتوای متنی سامانه: قانون، مفهوم (Concept)، منبع داده، یادداشت (Note) و دستور SPL.

نقش‌ها و سطح دسترسی

هر کاربر یک یا چند نقش دارد. دکمه‌ها و منوهایی که کاربر اجازه‌ی استفاده از آن‌ها را ندارد، برایش نمایش داده نمی‌شوند.

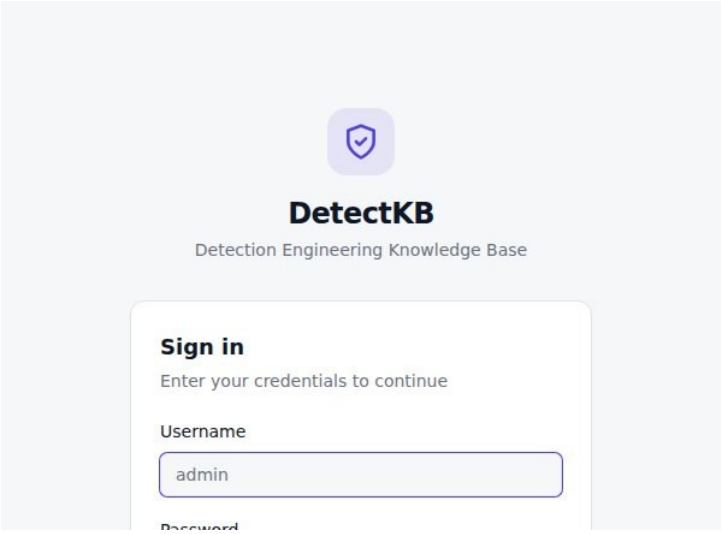
نقش	دسترسی
`viewer`	فقط مشاهده: صفحه‌ها، قوانین، تگ‌ها، گراف، پوشش ATT&CK و ساخت گزارش.
`editor`	همه‌ی دسترسی‌های viewer، به‌علاوه‌ی ساخت، ویرایش و حذف صفحه و قانون، ورود قوانین، مدیریت

نقش	دسترسی
	تگ و گرفتن پشتیبان.
`admin`	همه‌ی دسترسی‌ها، از جمله مدیریت کاربران، بازگردانی پشتیبان، گزارش فعالیت، انواع صفحه و به‌روزرسانی داده‌ی ابزارهای مهاجم.

فصل ۲ — شروع کار

ورود به سامانه

آدرس سامانه را در مرورگر باز کنید، نام کاربری و رمز عبور را وارد کنید و **Sign In** را بزنید. نام کاربری و رمز اولیه‌ی مدیر در پایان نصب نمایش داده می‌شود و در فایل `.env` هم ثبت است.



شکل ۱ — صفحه‌ی ورود

> **نکته**
>
> اگر مدیر برای شما حساب ساخته یا رمزتان را بازنشانی کرده باشد، بعد از اولین ورود باید رمز جدیدی انتخاب کنید. تا رمز عوض نشود، سامانه به صفحه‌ی دیگری نمی‌رود.
>
> بعد از چند تلاش ناموفق، ورود برای ۱۵ دقیقه بسته می‌شود: ۱۰ تلاش اشتباه برای یک کاربر از یک دستگاه، یا ۳۰ تلاش اشتباه از یک دستگاه برای هر نام کاربری. پیام **Too many failed login attempts** زمان باقی‌مانده را می‌گوید.
>
> پیام خطای ورود عمداً نمی‌گوید نام کاربری اشتباه است یا رمز؛ این کار حدس زدن نام‌های کاربری را سخت می‌کند.

آشنایی با محیط

صفحه‌ی سامانه سه بخش ثابت دارد:

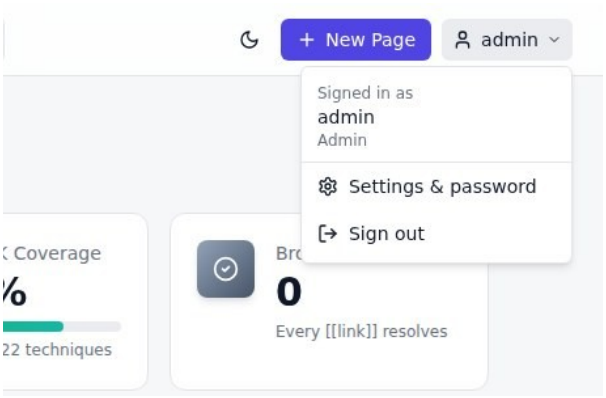
- **نوار کناری (سمت چپ):** دسترسی به همه‌ی بخش‌ها. بخش **Main** داشبورد است. بخش **Content** شامل فهرست صفحه‌ها، قوانین، پوشش ATT&CK، کتابخانه‌ی SPL، رویدادهای Sysmon، منابع لاگ، گروه‌های تهدید، سناریوهای تحلیلی، Atomic Red Team، ابزارهای مهاجم، منابع داده، مفاهیم و مستندسازی است. **Saved views** نماهای ذخیره‌شده‌ی شماست. **Categories** دسته‌بندی صفحه‌هاست و با دکمه‌ی +

دسته‌ی جدید ساخته می‌شود. **Tools** جست‌وجو، گراف دانش، سلامت داده، به‌روزرسانی از مخزن‌های اصلی، لینک‌های شکسته، پشتیبان‌گیری و تنظیمات است. **Admin** فقط برای مدیر نمایش داده می‌شود. با **Collapse** پایین نوار، نوار کوچک می‌شود و فقط آیکون‌ها می‌مانند.

- **نوار بالا:** وضعیت اتصال به سرور (**Connected**)، جعبه‌ی جست‌وجوی سریع، دکمه‌ی تغییر حالت روشن و تاریک، دکمه‌ی **New Page** برای ساخت صفحه‌ی جدید، و **منوی کاربر** با نام شما.
- **محتوای اصلی:** صفحه‌ای که باز کرده‌اید. بالای هر صفحه مسیر آن (breadcrumb) نمایش داده می‌شود و با کلیک روی هر بخش مسیر، به آن برمی‌گردید.

منوی کاربر و خروج

با کلیک روی نام کاربری در گوشه‌ی نوار بالا، منوی کاربر باز می‌شود: نام و نقش شما، **Settings & password** برای رفتن به تنظیمات و تغییر رمز، و **Sign out** برای خروج.

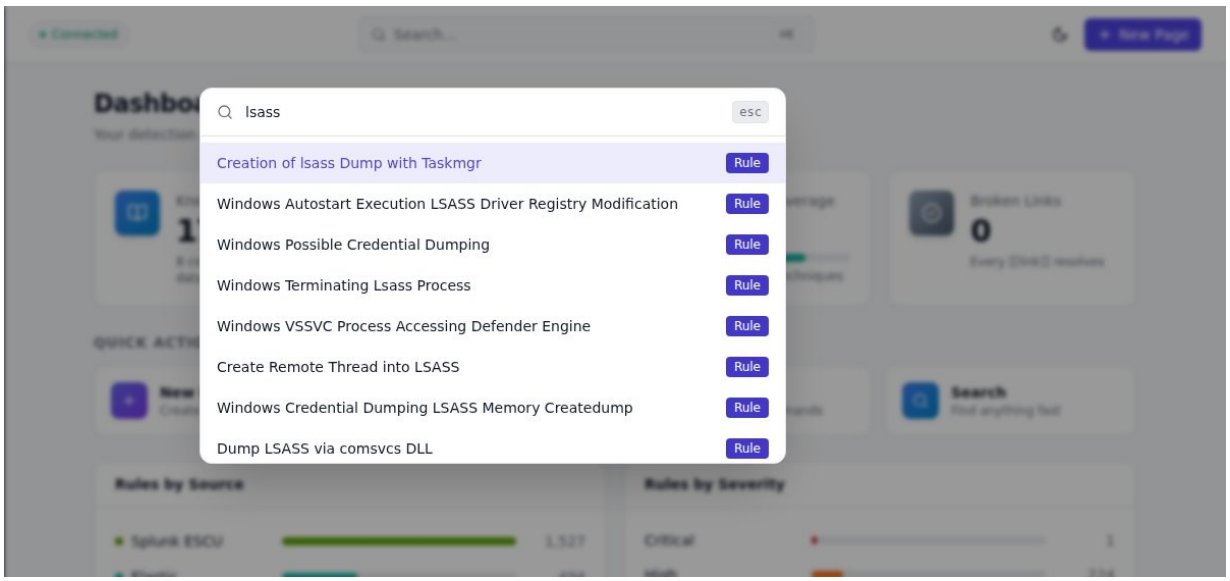


شکل ۲ — منوی کاربر

> **نکته**
>
> روی رایانه‌ی مشترک همیشه با **Sign out** خارج شوید. نشست ورود حداکثر ۲۴ ساعت معتبر است.

جست‌وجوی سریع

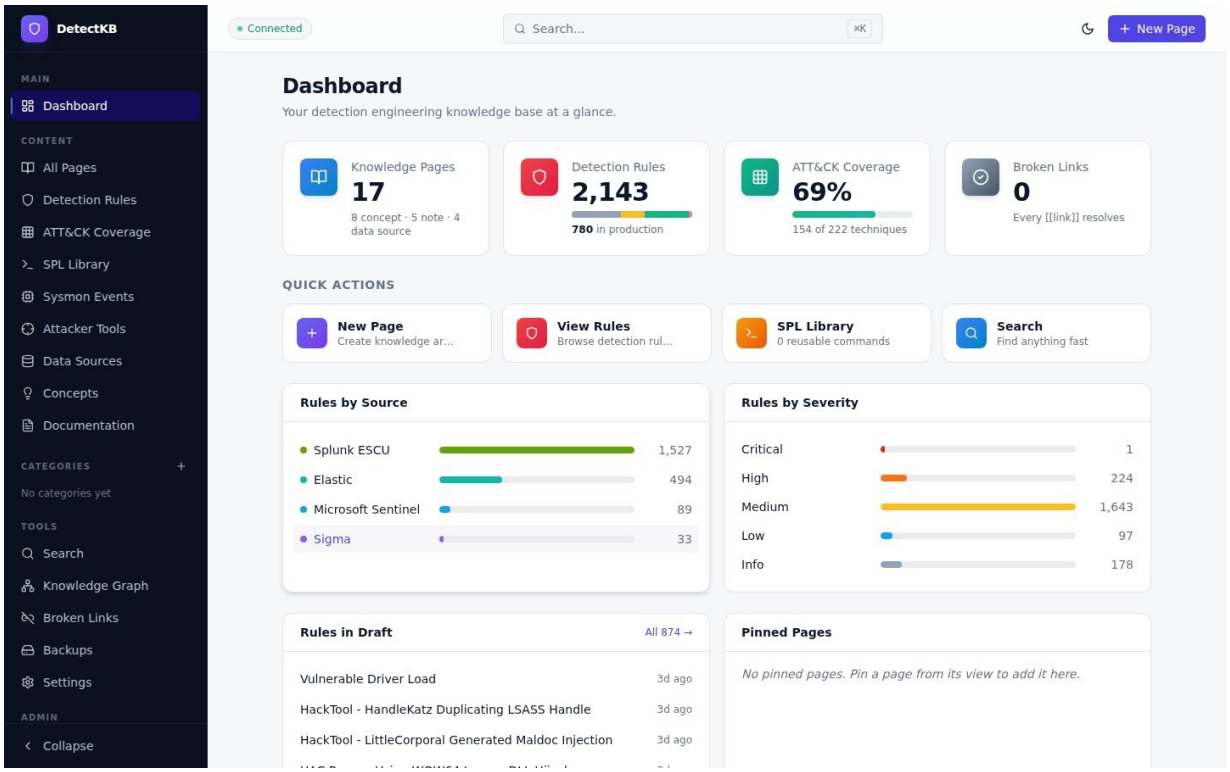
با `Ctrl+K` (در مک ⌘K) یا کلیک روی جعبه‌ی **Search** در نوار بالا، پنجره‌ی جست‌وجوی سریع باز می‌شود. دست‌کم دو حرف تایپ کنید. نتیجه‌ها با کلیدهای جهت‌دار انتخاب و با `Enter` باز می‌شوند.



شکل ۳ — جست‌وجوی سریع با Ctrl+K

داشبورد

داشبورد اولین صفحه بعد از ورود است و خلاصه‌ی وضعیت پایگاه دانش را نشان می‌دهد:



شکل ۴ — داشبورد

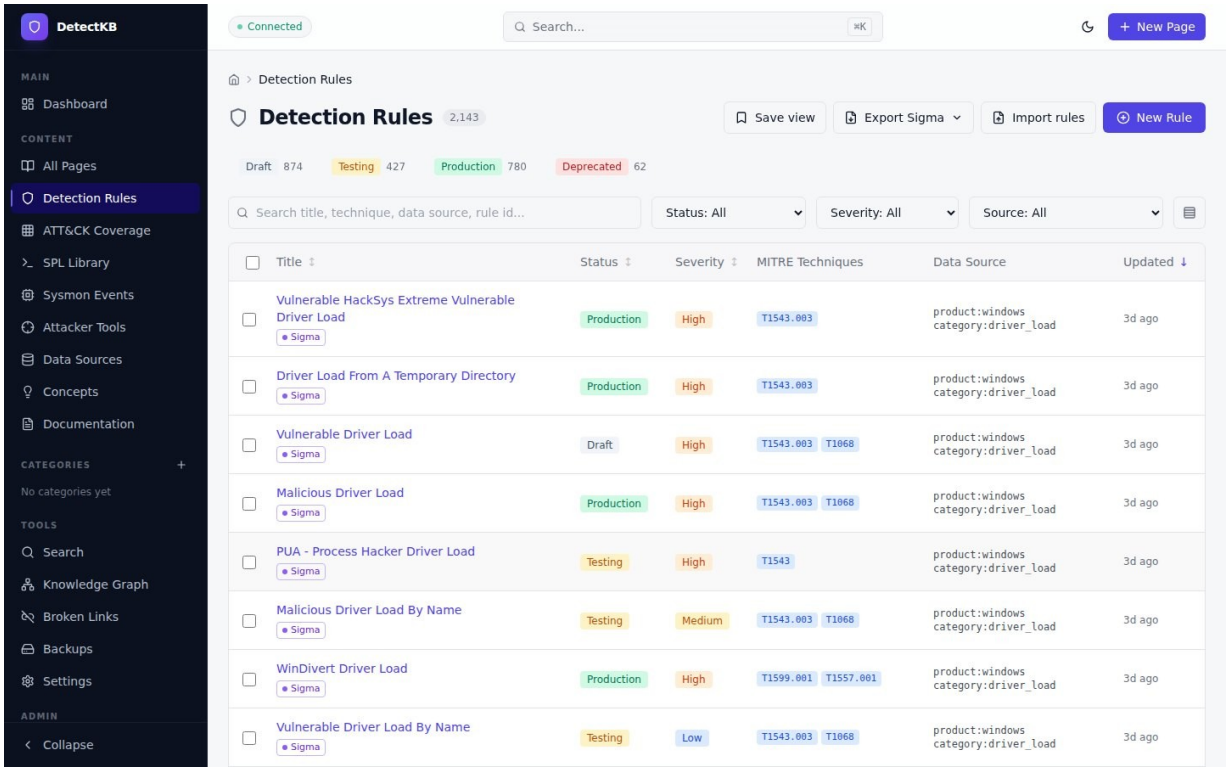
- **Knowledge Pages:** تعداد صفحه‌های دانش (بدون قوانین)، به تفکیک نوع.
- **Detection Rules:** تعداد کل قوانین، با نوار رنگی وضعیت‌ها و تعداد قوانین production.
- **ATT&CK Coverage:** درصد تکنیک‌های ATT&CK که دست‌کم یک قانون فعال دارند.
- **Broken Links:** تعداد لینک‌های ویکی که به صفحه‌ی ناموجود اشاره می‌کنند.

- **Rules by Source** و **Rules by Severity:** تعداد قوانین به تفکیک منبع و شدت. با کلیک روی هر ردیف، فهرست قوانین با همان فیلتر باز می‌شود.
- **Rules in Draft:** آخرین قوانین پیش‌نویس. **Pinned Pages:** صفحه‌هایی که سنجاق کرده‌اید. **Recent Activity:** آخرین صفحه‌های ویرایش‌شده.

همه‌ی کارت‌های بالای داشبورد قابل کلیک‌اند و صفحه‌ی مربوط را باز می‌کنند.

فصل ۳ — قوانین تشخیص

صفحه‌ی **Detection Rules** از نوار کناری باز می‌شود و مرکز کار با قوانین است.



شکل ۵ — فهرست قوانین تشخیص

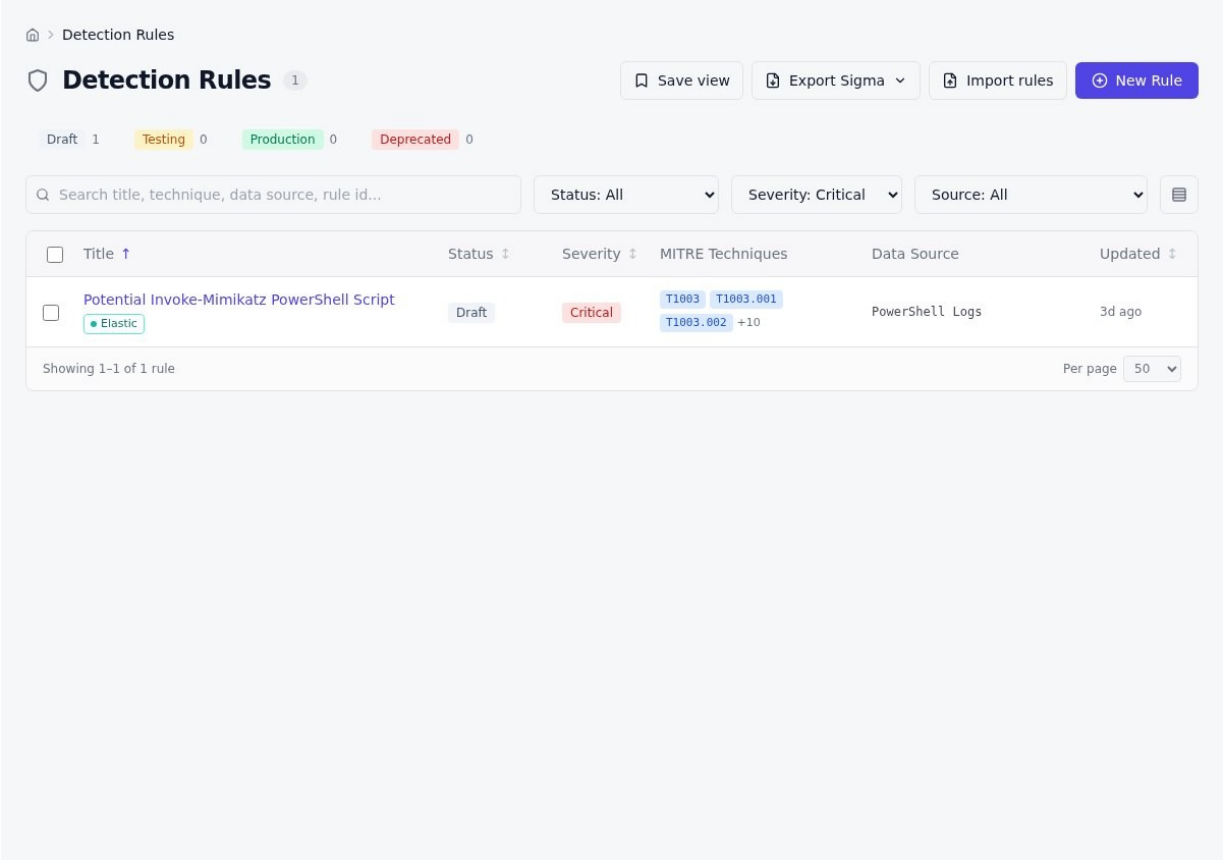
اجزای صفحه

- **دکمه‌های بالا:** **Save view** ذخیره‌ی فیلترها، **Export Sigma** خروجی Sigma، **Import rules** ورود قانون، و **New Rule** قانون جدید.
- **برچسب‌های وضعیت:** تعداد قوانین در هر وضعیت (Draft، Testing، Production، Deprecated). با کلیک روی هر کدام، فهرست به همان وضعیت فیلتر می‌شود و با کلیک دوباره فیلتر برداشته می‌شود.
- **جعبه‌ی جست‌وجو:** در عنوان، تکنیک، منبع داده، شناسه‌ی Sigma و منبع، و نام تگ جست‌وجو می‌کند.
- **فیلترها:** وضعیت (**Status**)، شدت (**Severity**) و منبع قانون (**Source**). گزینه‌ی **Written here** یعنی قوانینی که در خود سامانه نوشته شده‌اند.
- **دکمه‌ی تراکم:** آیکون کنار فیلترها، ردیف‌ها را فشرده یا راحت نمایش می‌دهد. انتخاب شما در همان مرورگر به خاطر سپرده می‌شود.
- **جدول:** عنوان (با منبع و تگ‌ها)، وضعیت، شدت، تکنیک‌های MITRE، منبع داده و زمان آخرین تغییر.
- **پایین جدول:** تعداد نتیجه‌ها، تعداد ردیف در هر صفحه (۲۵، ۵۰ یا ۱۰۰) و دکمه‌های رفتن به صفحه‌ی بعد و قبل.

جست‌وجو، فیلتر و مرتب‌سازی

با کلیک روی سر ستون‌های **Severity**، **Status**، **Title** و **Updated**، فهرست بر همان ستون مرتب می‌شود. کلیک دوباره ترتیب را برعکس می‌کند. شدت و وضعیت به ترتیب منطقی خودشان مرتب می‌شوند، نه الفبایی.

با کلیک روی شناسه‌ی یک تکنیک در جدول، مثل `T1003.001`، فقط قوانین همان تکنیک نشان داده می‌شوند. با کلیک روی برچسب منبع، مثل **Sigma**، هم فقط قوانین همان منبع می‌مانند. فیلتر تکنیک بالای جدول با علامت × نمایش داده می‌شود و با کلیک روی × برداشته می‌شود.

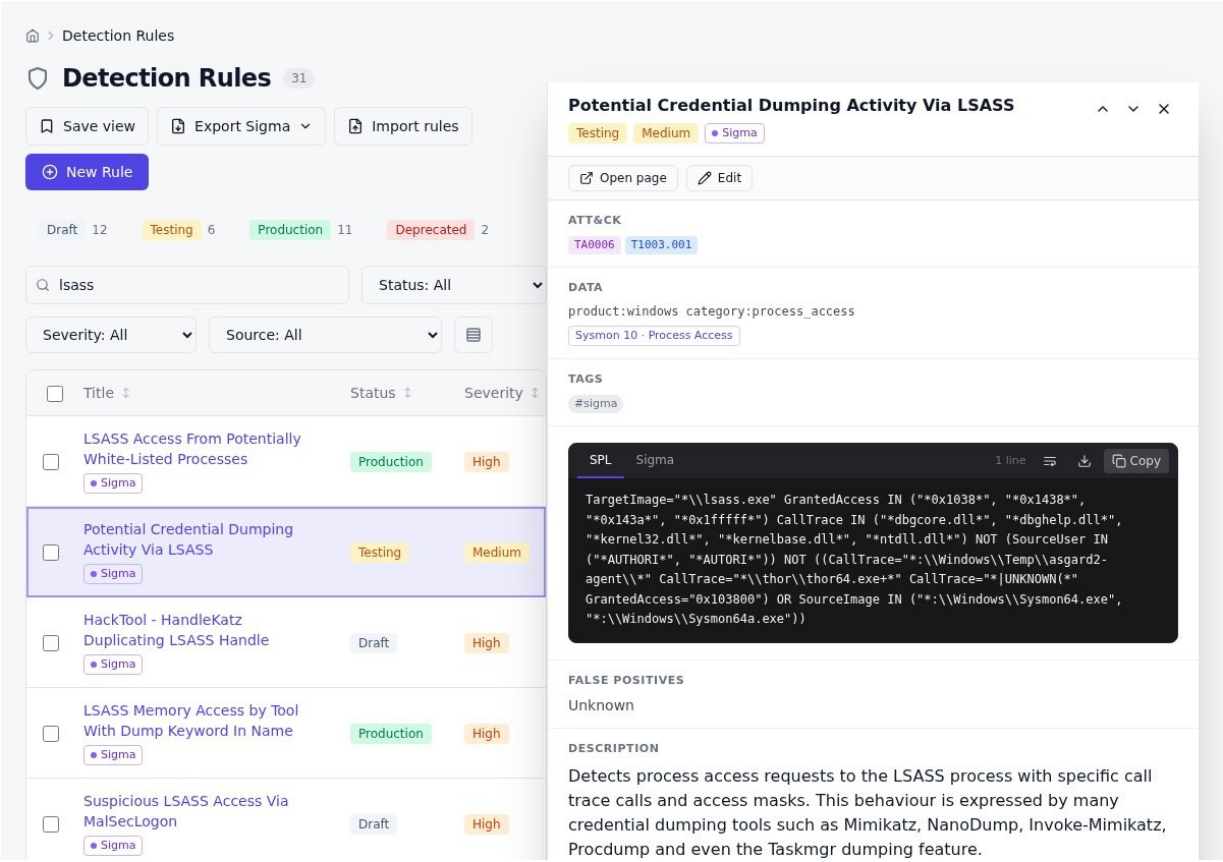


شکل ۶ — فهرست قوانین با فیلتر شدت critical، مرتب‌شده بر اساس عنوان

> **نکته**
>
> همه‌ی فیلترها، جست‌وجو و شماره‌ی صفحه در آدرس صفحه (URL) ذخیره می‌شوند. می‌توانید آدرس را برای همکارتان بفرستید تا دقیقاً همین فهرست را ببیند. دکمه‌ی Back مرورگر هم فیلتر قبلی را برمی‌گرداند.

پیش‌نمایش کناری

با کلیک روی عنوان یک قانون، جزئیات آن در یک پنل کنار فهرست باز می‌شود و فهرست سر جایش می‌ماند. این پنل برای مرور سریع چند قانون پشت‌سرهم است.



شکل ۷ — پنل پیش‌نمایش قانون

- بالای پنل: عنوان، وضعیت، شدت و منبع قانون. دکمه‌های ▲ و ▼ قانون قبلی و بعدی فهرست را نشان می‌دهند و × پنل را می‌بندد.
- **Open page** صفحه‌ی کامل قانون را باز می‌کند و **Edit** صفحه‌ی ویرایش را.
- بخش‌های پنل: تکنیک‌ها و تاکتیک‌های ATT&CK، منبع داده و رویدادهای Sysmon، تگ‌ها، کوئری‌ها (در تب‌های جدا)، موارد مثبت کاذب، توضیح و منابع.
- وقتی پنل باز است، ستون‌های تکنیک، منبع داده و تاریخ از جدول پنهان می‌شوند تا عنوان‌ها جا داشته باشند.

> **نکته**
>
> برای باز کردن صفحه‌ی کامل قانون به جای پیش‌نمایش، هنگام کلیک کلید `Ctrl` را نگه دارید (در مک ⌘). صفحه در تب جدید باز می‌شود.

انتخاب قوانین و عملیات گروهی

با تیک ستون اول می‌توانید چند قانون را انتخاب کنید. تیک سر جدول همه‌ی قوانین صفحه‌ی فعلی را انتخاب می‌کند. انتخاب‌ها با رفتن به صفحه‌ی بعد حفظ می‌شوند، ولی با تغییر فیلتر پاک می‌شوند.

وقتی قانونی انتخاب شود، نواری پایین صفحه ظاهر می‌شود:



شکل ۸ — نوار عملیات گروهی و منوی تغییر وضعیت

- **Select all … matching:** اگر همه‌ی قوانین صفحه را انتخاب کرده باشید، این گزینه همه‌ی قوانینِ منطبق با فیلتر فعلی را انتخاب می‌کند، حتی آن‌هایی که در صفحه‌های بعدی‌اند.
- **Status** و **Severity:** تغییر وضعیت یا شدت همه‌ی قوانین انتخاب‌شده.
- **Tag:** افزودن یا حذف یک تگ. نام تگ را بنویسید و **Add tag** یا **Remove tag** را بزنید.
- **Export Sigma:** خروجی Sigma فقط از قوانین انتخاب‌شده.
- **Delete:** حذف قوانین انتخاب‌شده، بعد از تأیید.
- × یا کلید Esc انتخاب را پاک می‌کند.

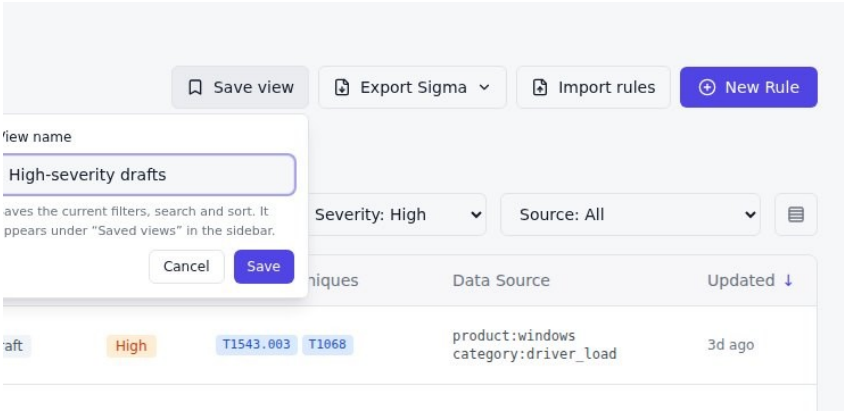
> **توجه**
>
> حذف گروهی قابل بازگشت نیست. صفحه‌ی قانون، کوئری‌ها، لینک‌ها و تاریخچه‌اش حذف می‌شوند. اگر مطمئن نیستید، قبل از حذف پشتیبان بگیرید (فصل ۱۴).

نماهای ذخیره‌شده

اگر ترکیبی از فیلترها را زیاد استفاده می‌کنید، مثلاً «قوانین draft با شدت high»، آن را ذخیره کنید:

1. فیلترها، جست‌وجو و مرتب‌سازی را تنظیم کنید.

2. روی **Save view** بالای صفحه کلیک کنید.
3. یک نام وارد کنید (سامانه نامی از روی فیلترها پیشنهاد می‌دهد) و **Save** را بزنید.

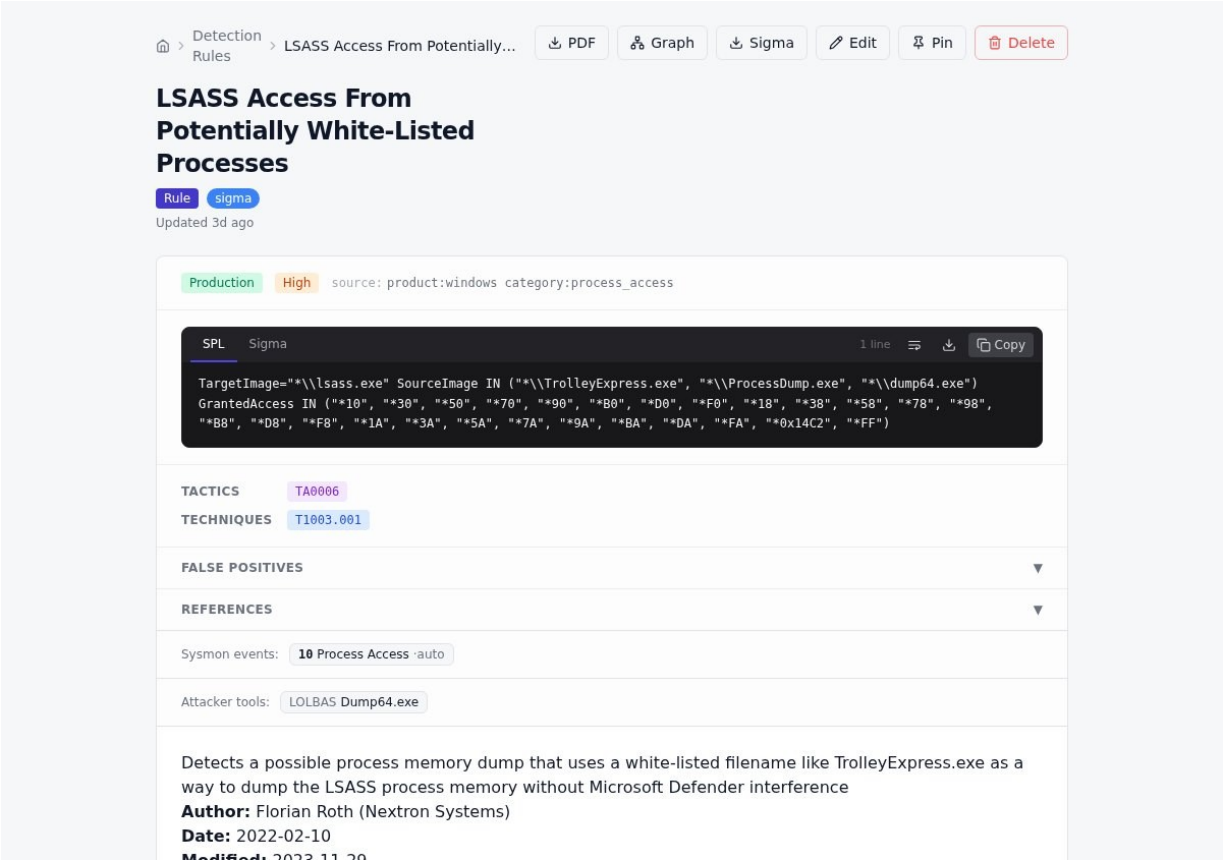


شکل ۹ — ذخیره‌ی نما

نما در بخش **Saved views** نوار کناری اضافه می‌شود و با یک کلیک همان فیلترها را برمی‌گرداند. برای حذف، ماوس را روی نام نما نگه دارید و × را بزنید. نماها برای هر کاربر جدا هستند. این دکمه در صفحه‌ی **All Pages** و گراف دانش هم هست.

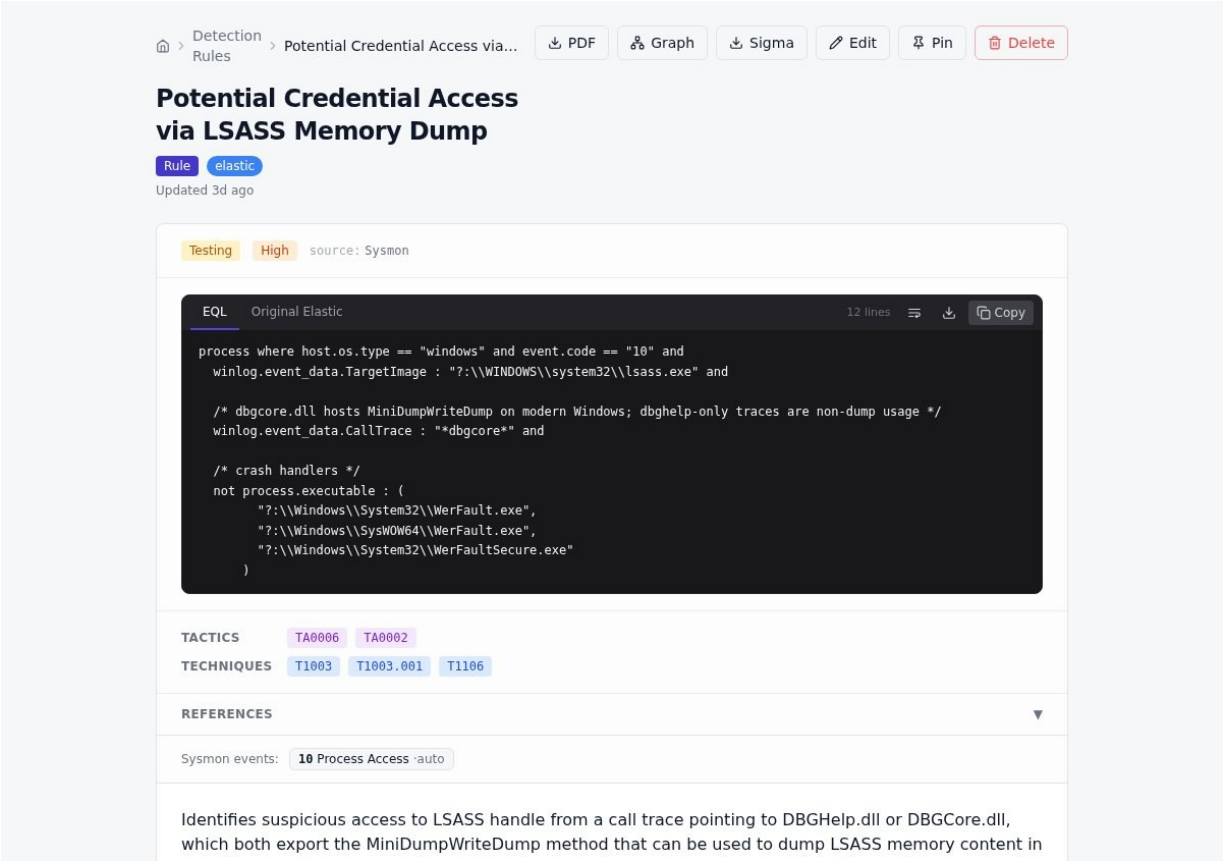
صفحه‌ی قانون

با **Open page** در پیش‌نمایش، یا `Ctrl`+کلیک روی عنوان، صفحه‌ی کامل قانون باز می‌شود.



شکل ۱۰ — صفحه‌ی یک قانون Sigma

- **دکمه‌های بالا: PDF** خروجی PDF از صفحه، **Graph** نمایش قانون در گراف دانش، **Sigma** دانلود فایل Sigma، **Edit** ویرایش، **Pin** سنجاق به داشبورد، و **Delete** حذف.
- **کادر کوئری‌ها:** کوئری‌های قانون در تب‌های جدا: **SPL**، کوئری اصلی قوانین Elastic و Sentinel (مثل **EQL** یا **KQL**)، **Sigma**، و فایل اصلی واردشده (**Original …**). هر تب دکمه‌های کپی (**Copy**)، دانلود و شکستن خطوط بلند دارد. آخرین تبی که انتخاب کرده‌اید در قانون بعدی هم باز می‌ماند.
- **Tactics / Techniques:** با کلیک روی هر شناسه، فهرست قوانین همان تکنیک یا تاکتیک باز می‌شود.
- **False Positives، References، Test Notes:** با کلیک باز می‌شوند.
- **Sysmon events:** رویدادهایی که قانون به آن‌ها وابسته است. برچسب **auto** یعنی سامانه آن را از کوئری تشخیص داده است.
- **Attacker tools:** ابزارهای GTFOBins، LOLBAS یا LOLDrivers که در کوئری قانون آمده‌اند.
- **Backlinks:** صفحه‌هایی که با لینک ویکی به این قانون اشاره کرده‌اند.
- **نشان اعتبارسنجی:** کنار وضعیت و شدت قانون، نتیجه‌ی آخرین تست قانون در لب نمایش داده می‌شود (مثل **Validated** یا **Failed in lab**). بخش **Lab validation · Atomic Red Team** تاریخچه‌ی تست‌ها، فرم ثبت نتیجه و تست‌های پیشنهادی را دارد (فصل ۱۱).

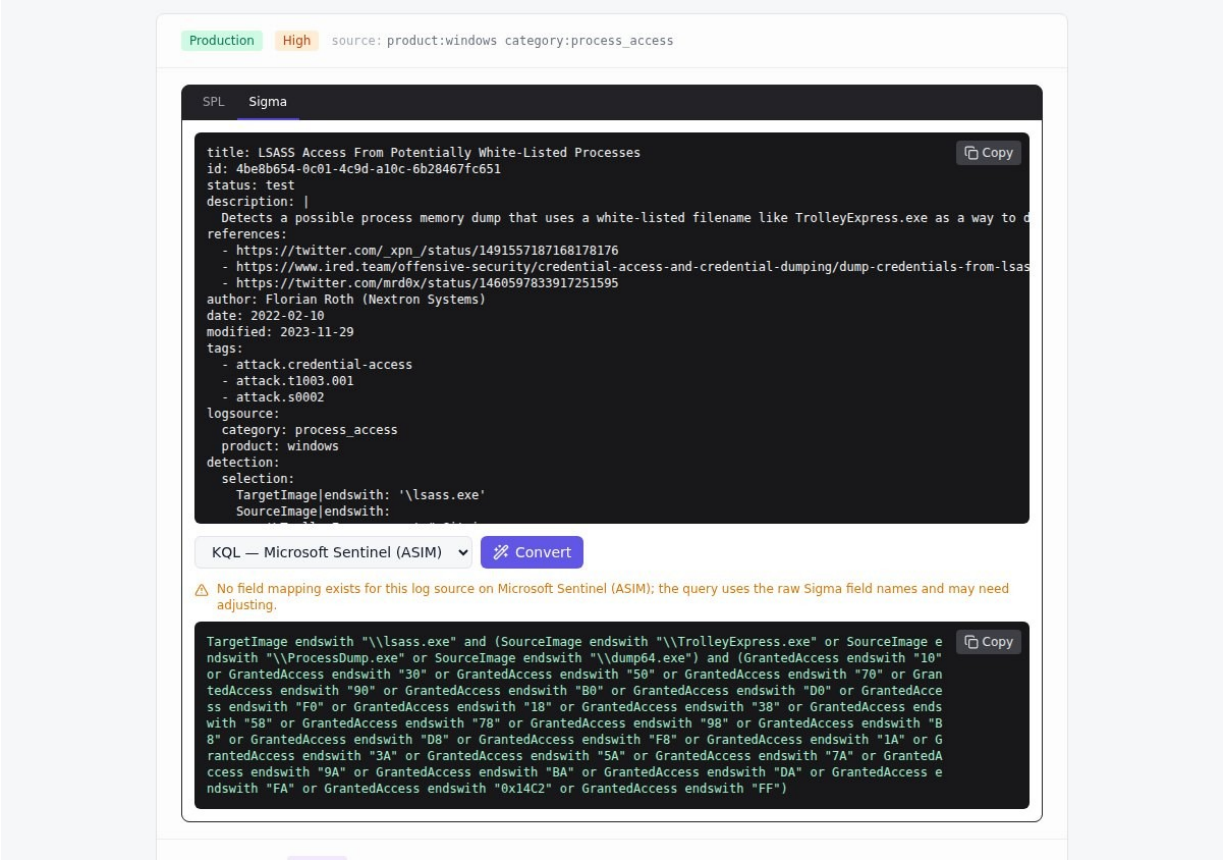


شکل ۱۱ — قانون Elastic با تب کوئری EQL و فایل اصلی

تبدیل Sigma به زبان SIEM

برای قانونی که منبع Sigma دارد، می‌توانید کوئری را برای SIEM خودتان بسازید:

1. در کادر کوئری‌ها، تب **Sigma** را باز کنید.
2. زبان مقصد را انتخاب کنید: **SPL — Splunk**، **KQL — Microsoft Defender XDR**، **KQL — Microsoft Sentinel (ASIM)**، **EQL — Elastic (ECS)** یا **Lucene — Elastic (ECS)**.
3. **Convert** را بزنید. کوئری ساخته‌شده زیر آن نمایش داده می‌شود و با **Copy** کپی می‌شود.

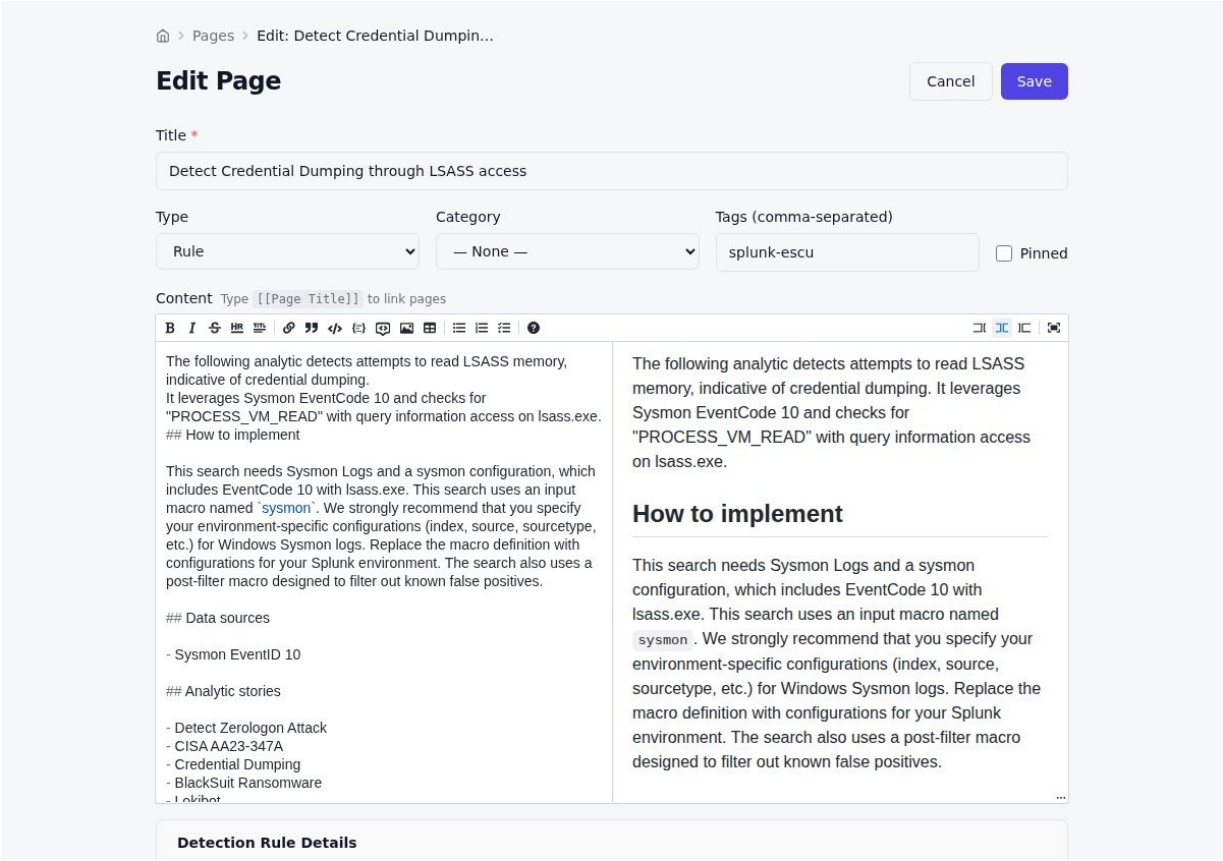


شکل ۱۲ — تبدیل قانون Sigma به KQL برای Microsoft Sentinel

> **نکته**
>
> اگر برای منبع لاگ قانون نگاشت فیلدی در زبان مقصد وجود نداشته باشد، پیام زردرنگی نمایش داده می‌شود. در این حالت کوئری با نام‌های اصلی فیلدهای Sigma ساخته شده و باید آن را با نام فیلدهای محیط خود تطبیق دهید.

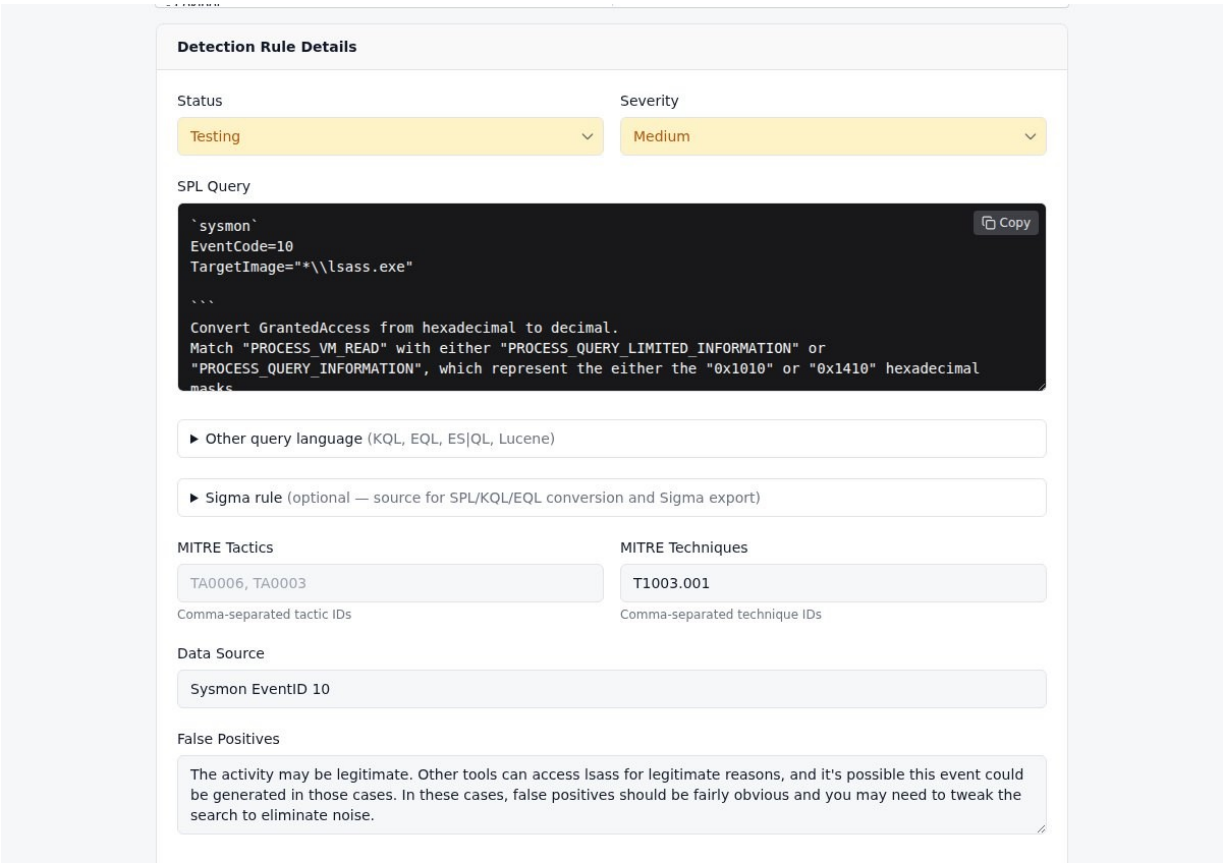
ساخت و ویرایش قانون

برای قانون جدید، **New Rule** را در صفحه‌ی قوانین بزنید. برای ویرایش، **Edit** را در صفحه‌ی قانون بزنید. فرم دو بخش دارد:



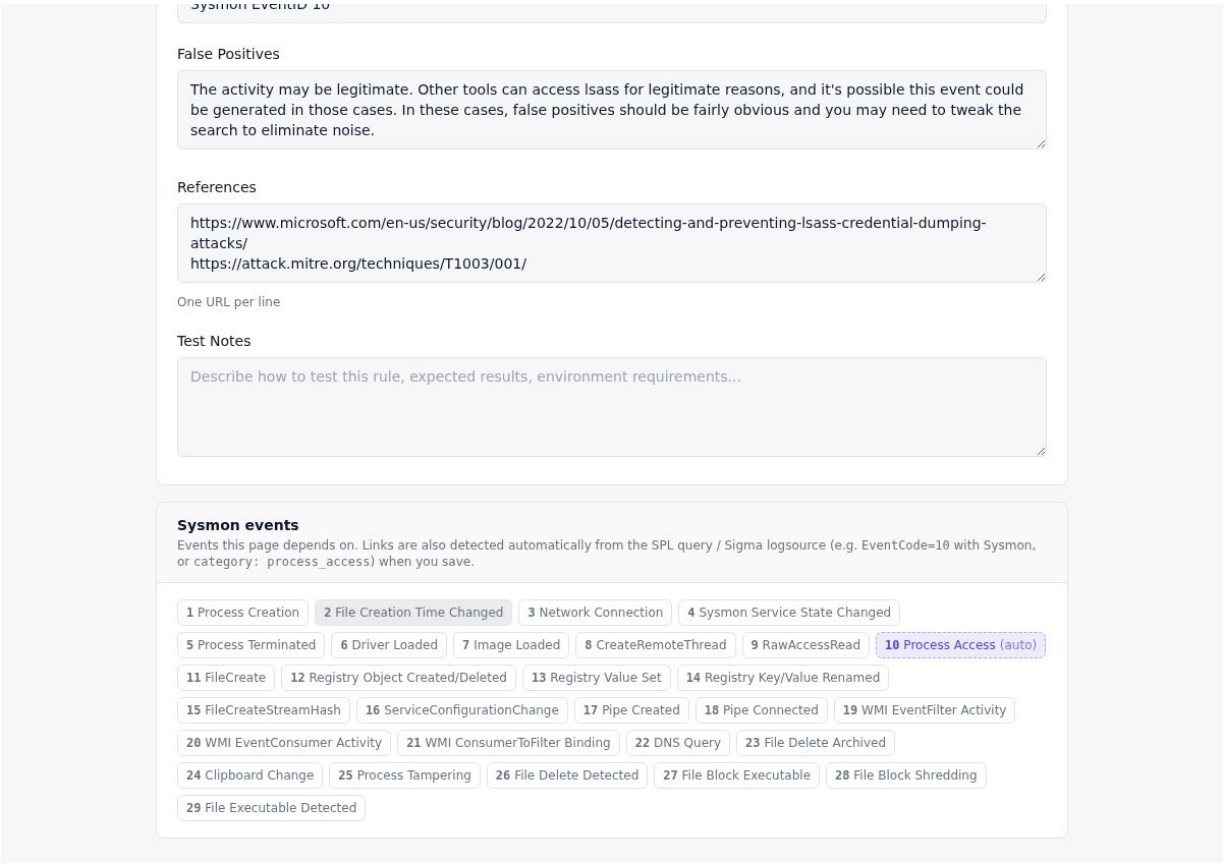
شکل ۱۳ — بخش بالای فرم: عنوان، نوع، دسته، تگ‌ها و متن توضیح

- **Title:** عنوان قانون (اجباری).
- **Type:** نوع صفحه. برای قانون، **Rule** است.
- **Category** و **Tags:** دسته‌بندی و تگ‌ها. تگ‌ها را با ویرگول جدا کنید.
- **Pinned:** سنجاق کردن صفحه به داشبورد.
- **Content:** توضیح قانون به زبان Markdown. سمت چپ متن را می‌نویسید و سمت راست نتیجه را می‌بینید. برای لینک به صفحه‌ی دیگر، `[[` تایپ کنید (فصل ۱۲).



شکل ۱۴ — بخش Detection Rule Details: وضعیت، شدت، کوئری‌ها و ATT&CK

فیلد	توضیح
Status / Severity	وضعیت و شدت قانون.
SPL Query	کوئری Splunk قانون.
Other query language	کوئری به زبان دیگر (KQL، EQL، ES|QL، Lucene) و انتخاب زبان آن.
Sigma rule	متن YAML قانون Sigma (اختیاری). از روی آن می‌شود کوئری ساخت و خروجی Sigma گرفت. با گزینه‌ی تبدیل به Splunk، نتیجه مستقیم در SPL Query قرار می‌گیرد.
MITRE Tactics	شناسه‌ی تاکتیک‌ها با ویرگول، مثل `TA0006, TA0003`.
MITRE Techniques	شناسه‌ی تکنیک‌ها با ویرگول، مثل `T1003.001`.
Data Source	منبع داده‌ی قانون به‌صورت متن.
False Positives	مواردی که ممکن است قانون به اشتباه هشدار بدهد.
References	منابع و لینک‌ها، هر کدام در یک خط.
Test Notes	روش تست، نتیجه‌ی مورد انتظار و پیش‌نیازهای محیط.
Sysmon events	رویدادهایی که قانون به آن‌ها وابسته است (پایین فرم).



شکل ۱۵ — انتخاب رویدادهای Sysmon؛ رویداد 10 به‌طور خودکار تشخیص داده شده است

سامانه هنگام ذخیره، رویدادهای Sysmon را از کوئری (مثل `EventCode=10`) یا logsource قانون Sigma (مثل `ca tegory: process_access`) خودکار تشخیص می‌دهد. رویدادهای خودکار با **(auto)** مشخص شده‌اند. با کلیک روی هر رویداد، آن را دستی اضافه یا حذف می‌کنید.

در پایان **Save** را بزنید. **Cancel** بدون ذخیره برمی‌گردد.

فصل ۴ — ورود و خروج قوانین

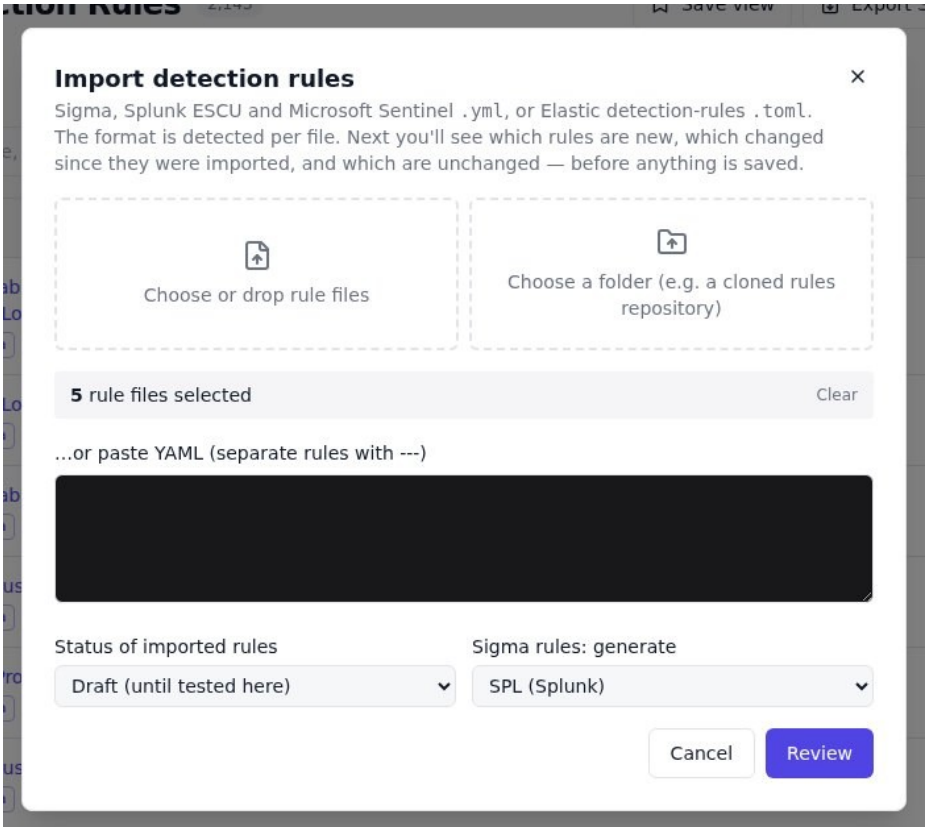
قوانین را می‌توانید از مخزن‌های عمومی یا فایل‌های خودتان وارد کنید. قالب‌های پشتیبانی‌شده:

- **Sigma** — فایل `.yml`
- **Splunk ESCU** (security_content) — فایل `.yml`
- **Microsoft Sentinel** — فایل `.yaml`
- **Elastic detection-rules** — فایل `.toml`

قالب هر فایل خودکار تشخیص داده می‌شود و می‌توانید چند قالب را با هم وارد کنید.

مراحل ورود

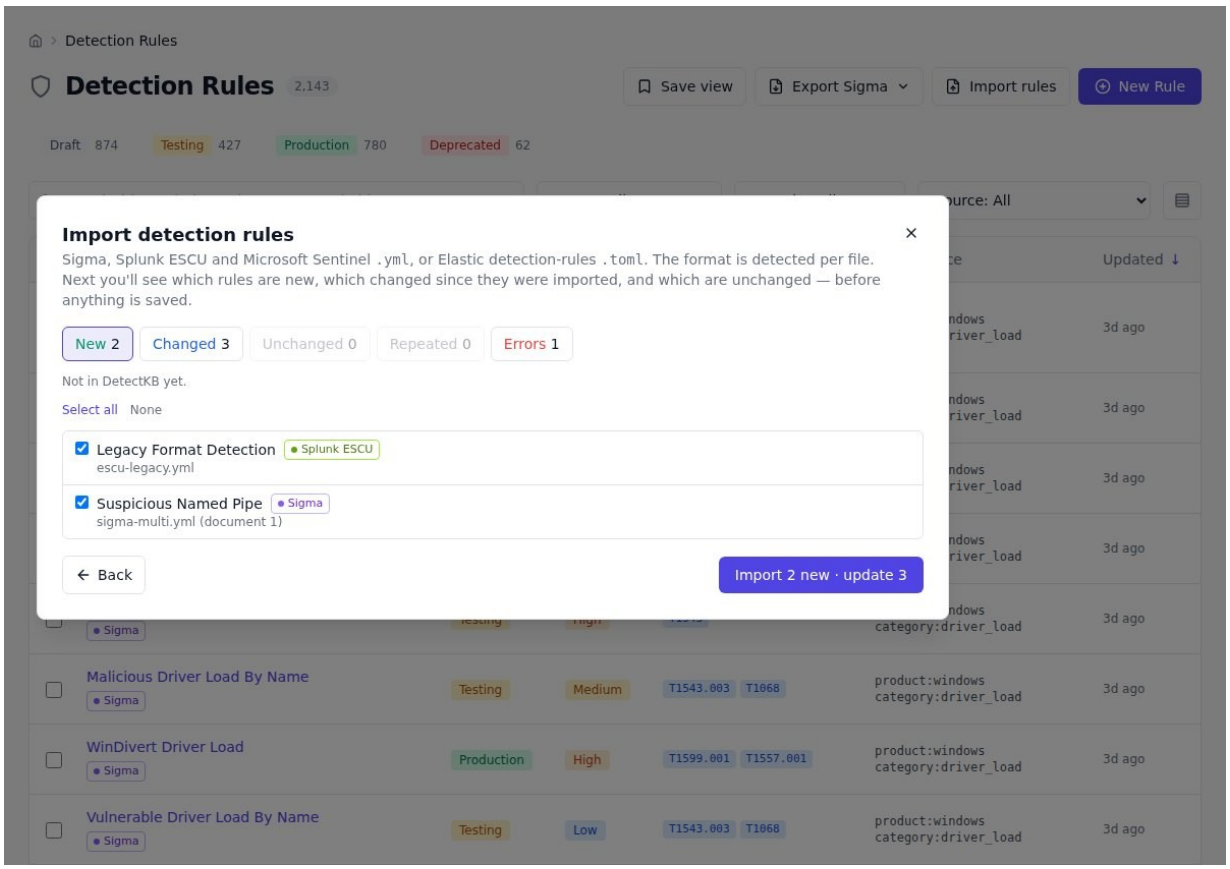
1. در صفحه‌ی قوانین، **Import rules** را بزنید.
2. فایل‌ها را انتخاب یا روی کادر رها کنید (**Choose or drop rule files**)، یا یک پوشه‌ی کامل انتخاب کنید (**Choose a folder**)، مثلاً پوشه‌ی clone شده‌ی مخزن SigmaHQ. می‌توانید متن YAML را هم مستقیم در کادر پایین بچسبانید. چند قانون را با `---` از هم جدا کنید.
3. در **Status of imported rules** مشخص کنید قوانین با وضعیت **Draft** وارد شوند (پیشنهادی) یا وضعیت اعلام‌شده در منبع حفظ شود.
4. در **Sigma rules: generate** مشخص کنید برای قوانین Sigma کوئری SPL ساخته شود یا نه.
5. **Review** را بزنید. هنوز چیزی ذخیره نشده است.



شکل ۱۶ — پنجره‌ی ورود قوانین

بازبینی قبل از ذخیره

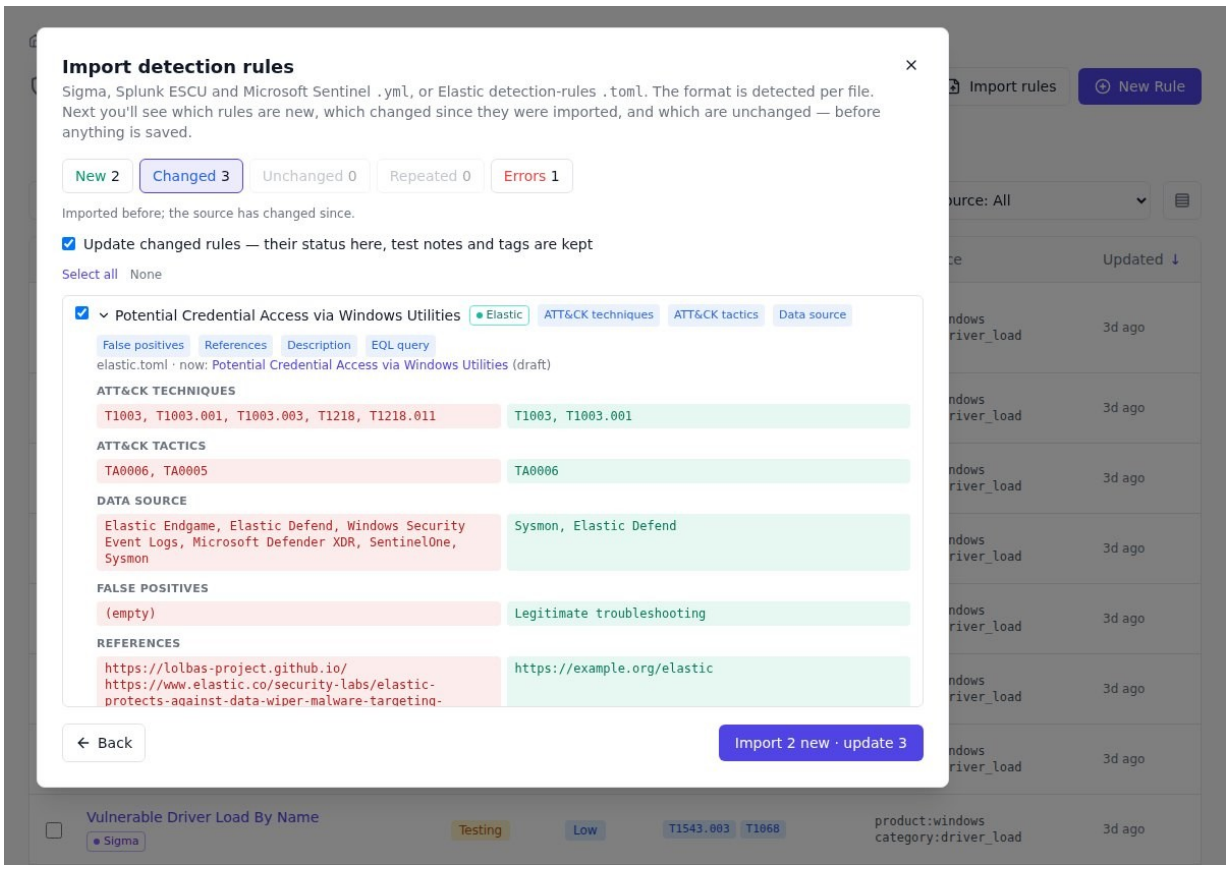
در مرحله‌ی بازبینی، قوانین در پنج دسته قرار می‌گیرند:



شکل ۱۷ — صفحه‌ی بازبینی: دسته‌ی قوانین جدید

دسته	معنی	رفتار
New	قانونی که هنوز در سامانه نیست.	ساخته می‌شود؛ می‌توانید تیک هر کدام را بردارید.
Changed	قبلاً وارد شده، ولی منبع اصلی از آن زمان تغییر کرده است.	اگر **Update changed rules** روشن باشد، به‌روز می‌شود.
Unchanged	قبلاً وارد شده و با منبع یکسان است.	نادیده گرفته می‌شود.
Repeated	همین قانون در همین آپلود قبلاً آمده است.	نادیده گرفته می‌شود.
Errors	فایل خوانده نشد، مثلاً به دلیل YAML نامعتبر یا فیلد ناقص.	نادیده گرفته می‌شود و علت خطا نمایش داده می‌شود.

در دسته‌ی **Changed**، با کلیک روی عنوان هر قانون، تفاوت فیلدها دیده می‌شود: مقدار فعلی با زمینه‌ی قرمز و مقدار جدید با زمینه‌ی سبز.



شکل ۱۸ — تفاوت فیلد به فیلد یک قانون تغییرکرده

> **نکته**
>
> اگر قانون جدیدی هم‌نام یک قانون موجود باشد، سامانه آن را به‌عنوان «احتمالاً همان تشخیص از منبعی دیگر» علامت می‌زند. با **Leave those out** می‌توانید همه‌ی این موارد را کنار بگذارید.
>
> در به‌روزرسانی یک قانون، وضعیت فعلی آن در سامانه، یادداشت‌های تست و تگ‌ها حفظ می‌شوند.

در پایان، دکمه‌ی پایین (مثلاً **Import 2 new · update 3**) را بزنید. بعد از ورود، فهرست قوانین ساخته‌شده، به‌روزشده، نادیده‌گرفته‌شده و خطاها نمایش داده می‌شود.

> **توجه**
>
> قوانین منابع دیگر برای مدل داده‌ی همان محصول نوشته شده‌اند، مثل Splunk CIM، Elastic ECS یا جدول‌های Sentinel. قبل از استفاده، نام فیلدها، index و sourcetype را با محیط خود تطبیق دهید و قانون را در وضعیت testing تست کنید.

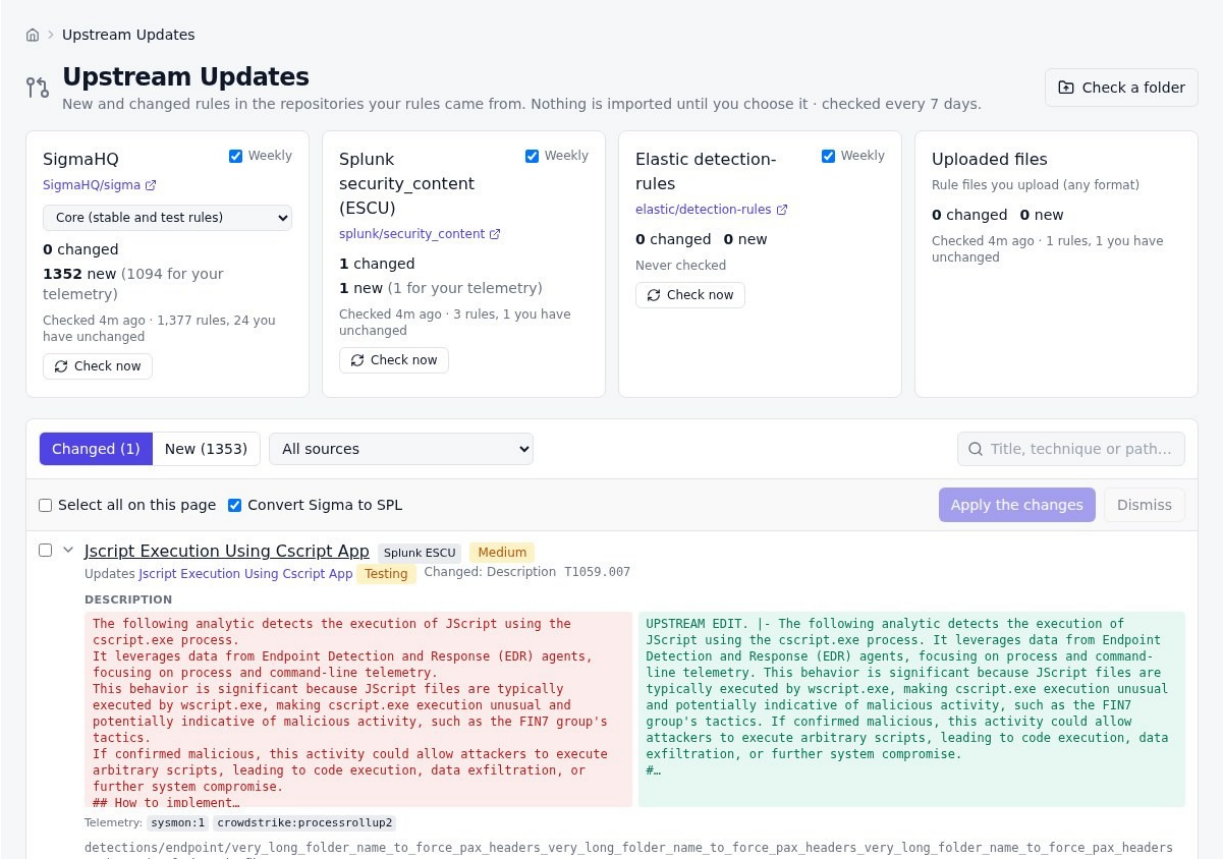
به‌روزرسانی از مخزن‌های اصلی

مخزن‌های عمومی مثل Splunk security_content (ESCU)، SigmaHQ و Elastic detection-rules مـدام قانون جدید اضافه یا قانون‌های قبلی را اصلاح می‌کننـد. صـفحه‌ی **Upstream Updates** (در بخش Tools) نشـان می‌دهد از آخرین بار چه چیزی تغییر کرده است. سامانه **هیچ چیزی را خودکار وارد نمی‌کند**؛ فقط فهرست می‌دهد و شما انتخاب می‌کنید.

- **کارت هر منبع:** تعداد قانون‌های تغییرکرده و جدید، زمان آخرین بررسی و دکمه‌ی **Check now**. سامانه هر ۷ روز یک بار منابع فعال (تیک **Weekly**) را خودکار بررسی می‌کند. منبعی که از آن قانون وارد کرده‌اید خودکار فعال است. برای SigmaHQ می‌توانید بسته را انتخاب کنید: **Core** (قانون‌های stable و test)، **Core+** (به‌علاوه‌ی experimental) یا **All rules**.
- **Check a folder:** برای سرور بدون اینترنت، یا برای Microsoft Sentinel. پوشه‌ی قانون‌ها (مثلاً یک clone از مخزن) را انتخاب کنید تا با قانون‌های فعلی مقایسه شود.

قانون‌های تغییرکرده

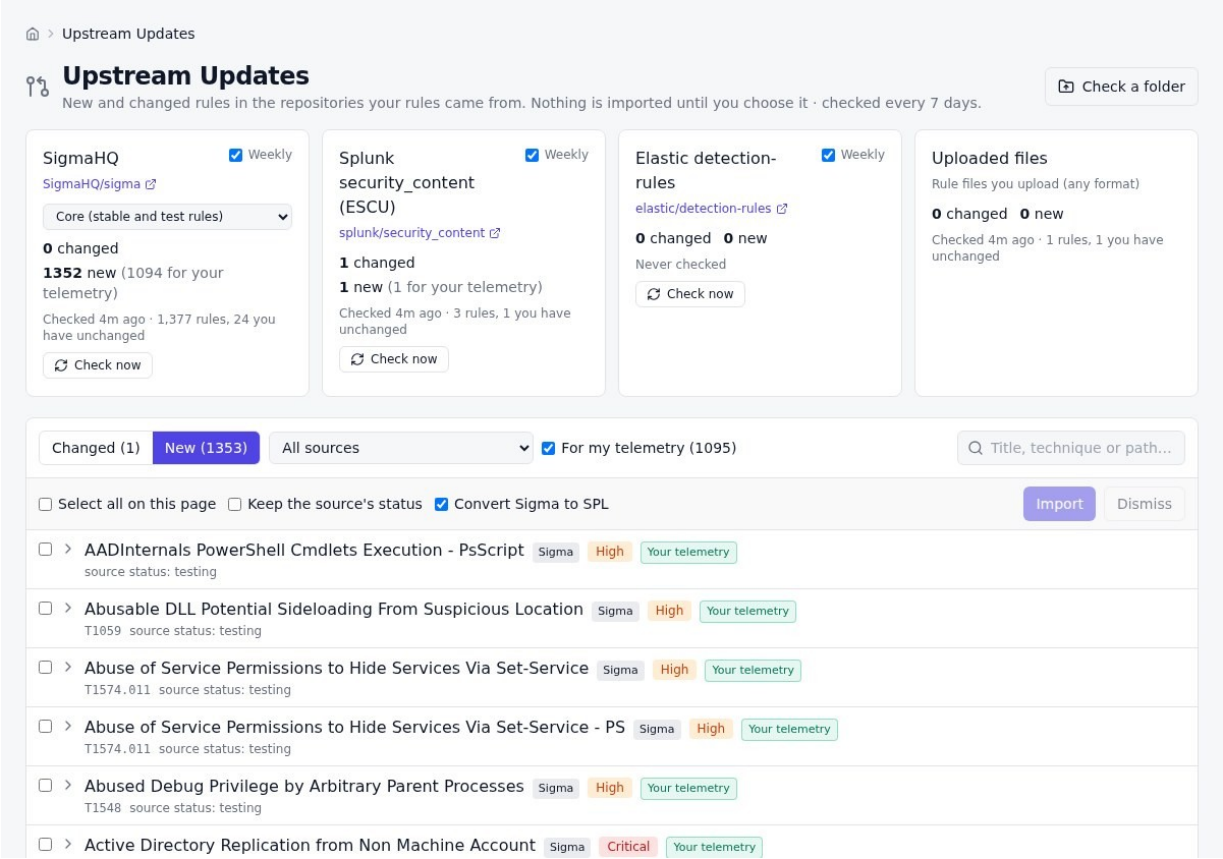
در تب **Changed** قانون‌هایی آمده که قبلاً وارد کرده‌اید و منبع اصلی آن‌ها را عوض کرده است. با کلیک روی هر قانون، تغییرات فیلدبه‌فیلـد نمـایش داده می‌شـود: نسـخه‌ی فعلی شـما بـا رنـگ قرمـز و نسـخه‌ی جدیـد بـا رنـگ سـبز. لینـک **Updates …** قانون فعلی شما را باز می‌کند.



شکل ۱۹ — قانونی که در مخزن اصلی تغییر کرده، با نمایش تفاوت‌ها

قانون‌های جدید

در تب **New** قانون‌هایی آمده که هنوز ندارید. گزینه‌ی **For my telemetry** (پیش‌فرض روشن) فقط قانون‌هایی را نشان می‌دهد که روی لاگ‌هایی کار می‌کنند که قانون‌های Production یا testing شما همین الان از آن‌ها استفاده می‌کنند؛ یعنی به احتمال زیاد آن لاگ را جمع می‌کنید. این قانون‌ها برچسب سبز **Your telemetry** دارند. **Show the file** فایل اصلی قانون را نشان می‌دهد.



شکل ۲۰ — قانون‌های جدید SigmaHQ که روی تله‌متری فعلی شما کار می‌کنند

وارد کردن یا رد کردن

1. قانون‌های موردنظر را تیک بزنید (یا **Select all on this page**).
2. برای قانون‌های جدید، **Keep the source's status** وضعیت منبع را نگه می‌دارد؛ در غیر این صورت قانون به‌صورت draft وارد می‌شود. **Convert Sigma to SPL** برای قانون‌های Sigma کوئری SPL می‌سازد.
3. **Apply the changes** (در تب Changed) یا **Import** (در تب New) را بزنید. وضعیت قانون‌های موجود تغییر نمی‌کند.
4. **Dismiss** قانون را از فهرست حذف می‌کند. اگر منبع بعداً دوباره همان قانون را تغییر دهد، دوباره نمایش داده می‌شود.

نکته

اگر کوئری قانونی را که در لب تست کرده‌اید با نسخه‌ی جدید جایگزین کنید، وضعیت اعتبارسنجی آن به **Retest** تغییر می‌کند (فصل ۱۱).

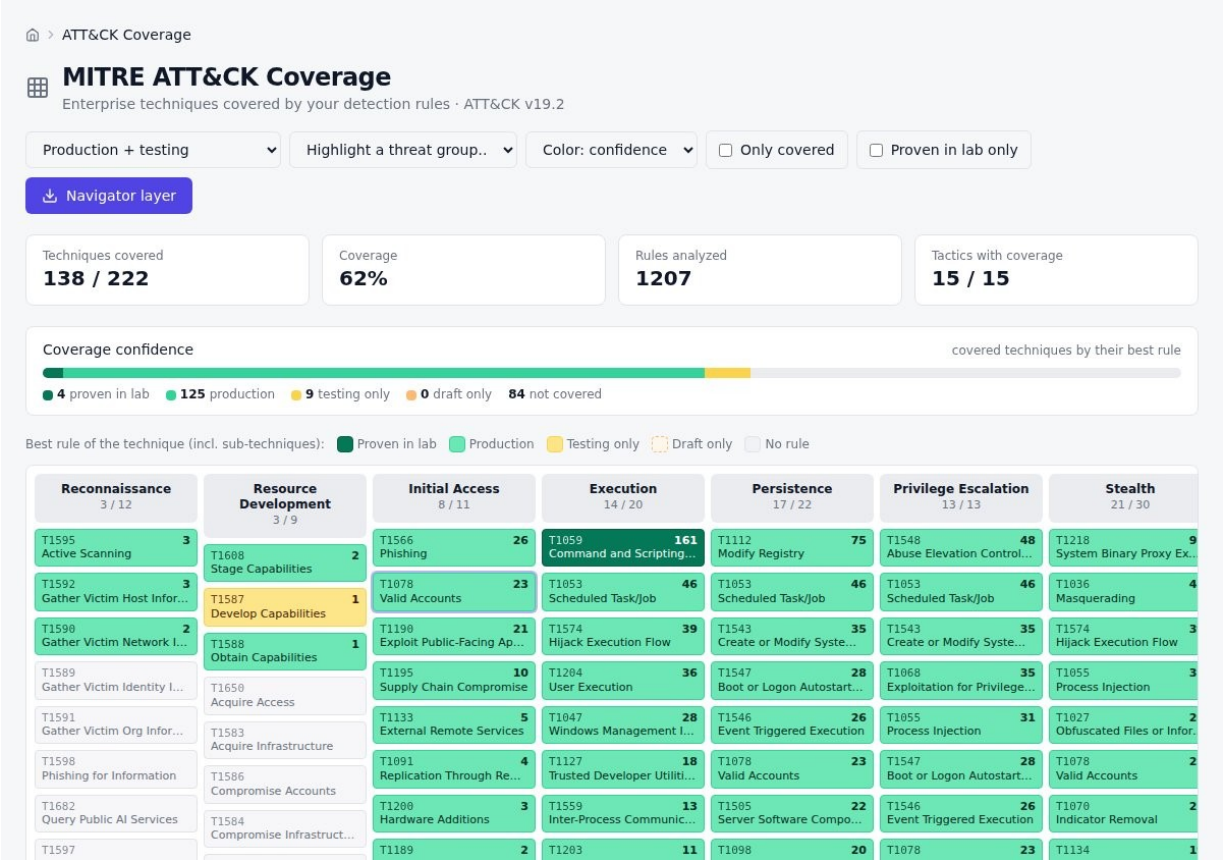
در صفحه‌ی **Data Health**، بررسی **Imported rules changed upstream** همین قانون‌های تغییرکرده را فهرست می‌کند.

خروجی Sigma

- **همه‌ی قوانین:** منوی **Export Sigma** در صفحه‌ی قوانین. گزینه‌ی **Rules with a Sigma source** فقط قوانینی را که منبع Sigma دارند خروجی می‌دهد. گزینه‌ی **All rules** برای بقیه‌ی قوانین هم یک اسکلت Sigma می‌سازد که باید کامل شود.
- **قوانین انتخاب‌شده: Export Sigma** در نوار عملیات گروهی.
- **یک قانون:** دکمه‌ی **Sigma** در صفحه‌ی قانون.

فصل ۵ – پوشش MITRE ATT&CK

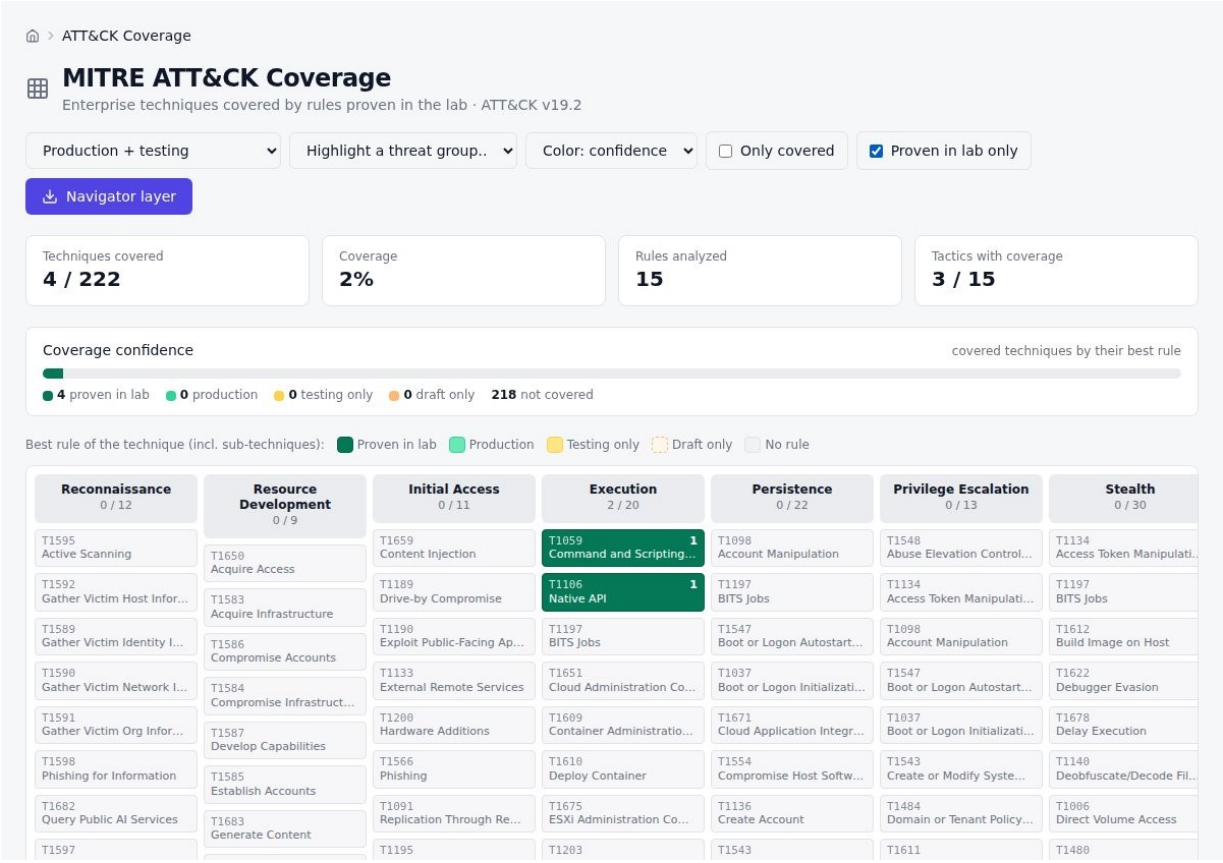
صفحه‌ی **ATT&CK Coverage** ماتریس کامل ATT&CK Enterprise را نشان می‌دهد. هر ستون یک تاکتیک است و هر خانه یک تکنیک.



شکل ۲۱ – ماتریس پوشش ATT&CK

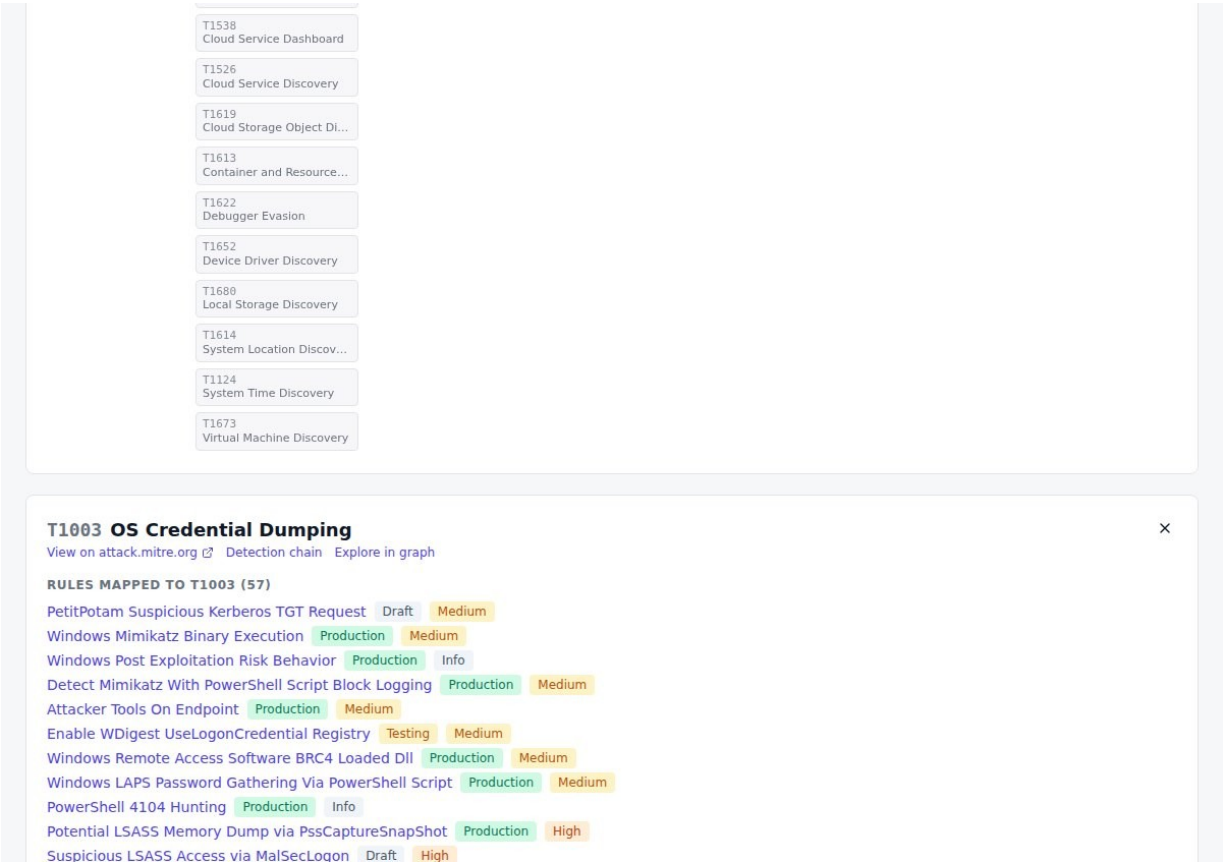
- **کارت‌های بالا:** تعداد تکنیک‌های پوشش‌داده‌شده، درصد پوشش، تعداد قوانین بررسی‌شده و تعداد تاکتیک‌هایی که دست‌کم یک قانون دارند.
- **Coverage confidence:** تکنیک‌های پوشش‌داده‌شده بر اساس بهترین قانونشان دسته‌بندی می‌شوند: **Proven in lab** (قانون production یا testing که آخرین تستش در لب حمله را تشخیص داده)، **Testing only**، **Production** و **Draft only** (هنوز هیچ قانونی برای این تکنیک اجرا نمی‌شود). نوار این کارت نشان می‌دهد چه سهمی از پوشش واقعاً قابل اتکاست.
- **رنگ خانه‌ها:** پیش‌فرض بر اساس همین اطمینان است: سبز تیره اثبات‌شده در لب، سبز روشن production، زرد فقط testing، نارنجی خط‌چین فقط draft و خاکستری بدون قانون. با گزینه‌ی **Color: rule count** رنگ‌ها بر اساس تعداد قوانین می‌شوند (هر چه تیره‌تر، قوانین بیشتر).
- **فیلتر وضعیت:** پیش‌فرض **Production + testing** است، چون draftها هنوز جایی اجرا نمی‌شوند و پوشش را بیش از واقع نشان می‌دهند. **Active rules (not deprecated)** همه‌ی قوانین به‌جز deprecated را حساب می‌کند و **Production only** فقط production را.

- **Only covered:** فقط تکنیک‌های دارای قانون.
- **Proven in lab only:** فقط قوانینی را حساب می‌کند که آخرین تستشان در لب حمله را تشخیص داده است (فصل ۱۱). این «پوشش اثبات‌شده» است، در برابر پوشش ادعاشده‌ی حالت عادی.
- **Navigator layer:** دانلود لایه برای ATT&CK Navigator، ابزار رسمی MITRE. اگر **Proven in lab only** روشن باشد، لایه هم فقط پوشش اثبات‌شده را دارد.



شکل ۲۲ — پوشش اثبات‌شده: فقط قوانینی که در لب تست و تأیید شده‌اند

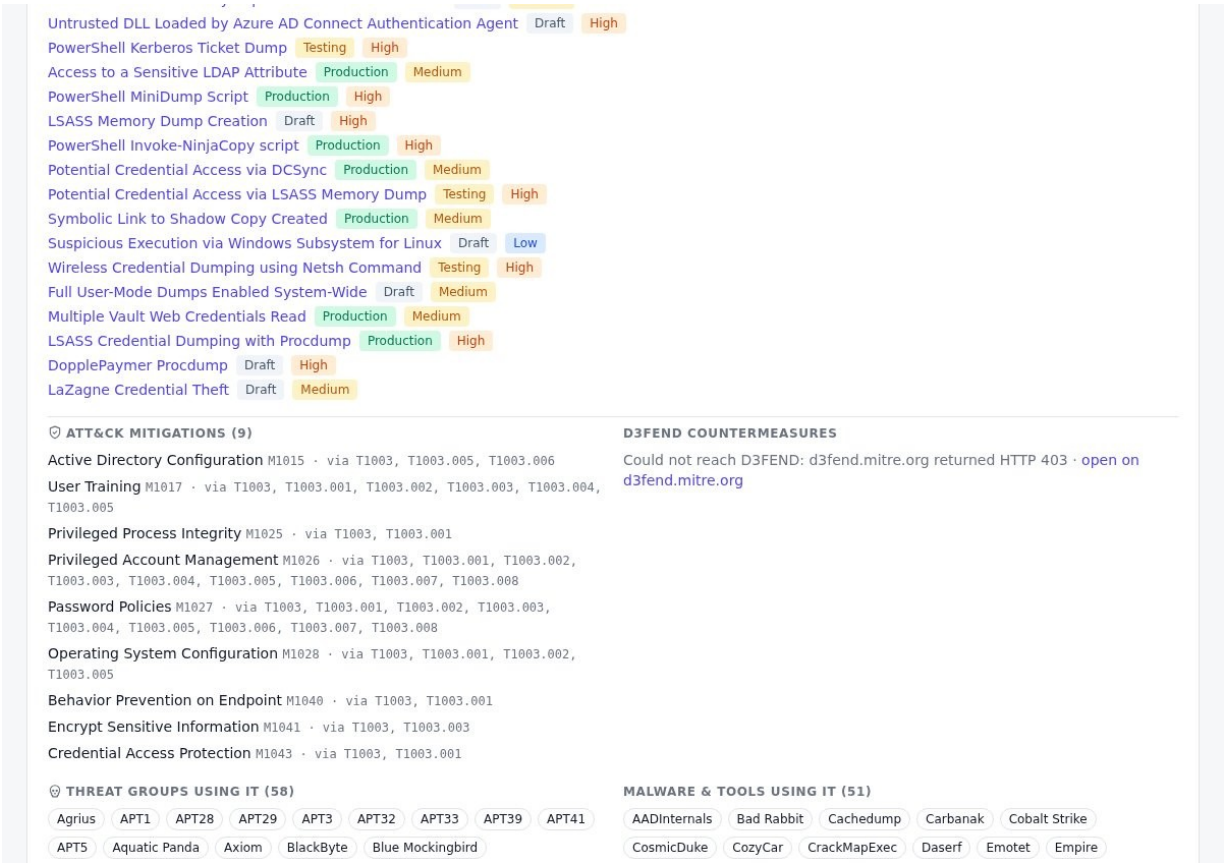
با کلیک روی هر خانه، جزئیات آن تکنیک زیر ماتریس باز می‌شود: قوانینی که مستقیم به تکنیک نگاشت شده‌اند، وضعیت پوشش هر زیرتکنیک، و لینک به سایت MITRE، زنجیره‌ی تشخیص و گراف دانش.



شکل ۲۳ – جزئیات تکنیک T1003 و زیرتکنیک‌های آن

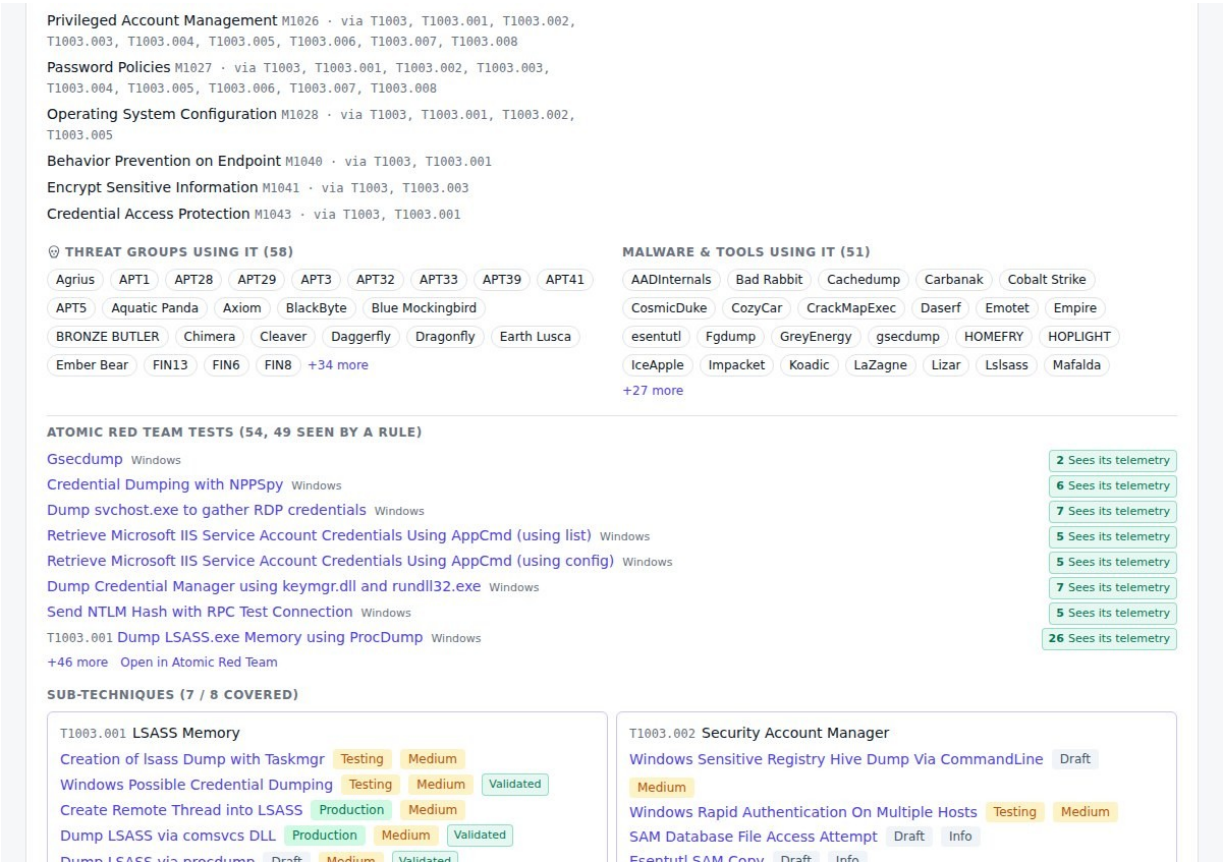
زیر فهرست قوانین، اطلاعات دفاعی و تهدیدی همان تکنیک آمده است:

- **ATT&CK mitigations:** کنترل‌های پیشگیرانه‌ای که MITRE برای این تکنیک پیشنهاد می‌کند، مثل Credential Access Protection. ماوس را روی هر مورد نگه دارید تا توضیحش را ببینید؛ با کلیک، صفحه‌ی آن در سایت MITRE باز می‌شود.
- **D3FEND countermeasures:** اقدامات دفاعی D3FEND، دسته‌بندی‌شده بر اساس تاکتیک دفاعی (Harden، Detect، Isolate و …). این بخش هنگام باز کردن تکنیک از d3fend.mitre.org خوانده و ذخیره می‌شود. اگر سرور به اینترنت دسترسی نداشته باشد، به‌جای فهرست، لینک صفحه‌ی D3FEND آن تکنیک نمایش داده می‌شود.
- **Threat groups using it** و **Malware & tools using it:** گروه‌های مهاجم و بدافزارها و ابزارهایی که طبق ATT&CK از این تکنیک استفاده کرده‌اند. با کلیک روی هر کدام، صفحه‌ی پوشش آن باز می‌شود (فصل ۹).



شکل ۲۴ — کاهش‌دهنده‌ها، اقدامات D3FEND و گروه‌هایی که از T1003 استفاده می‌کنند

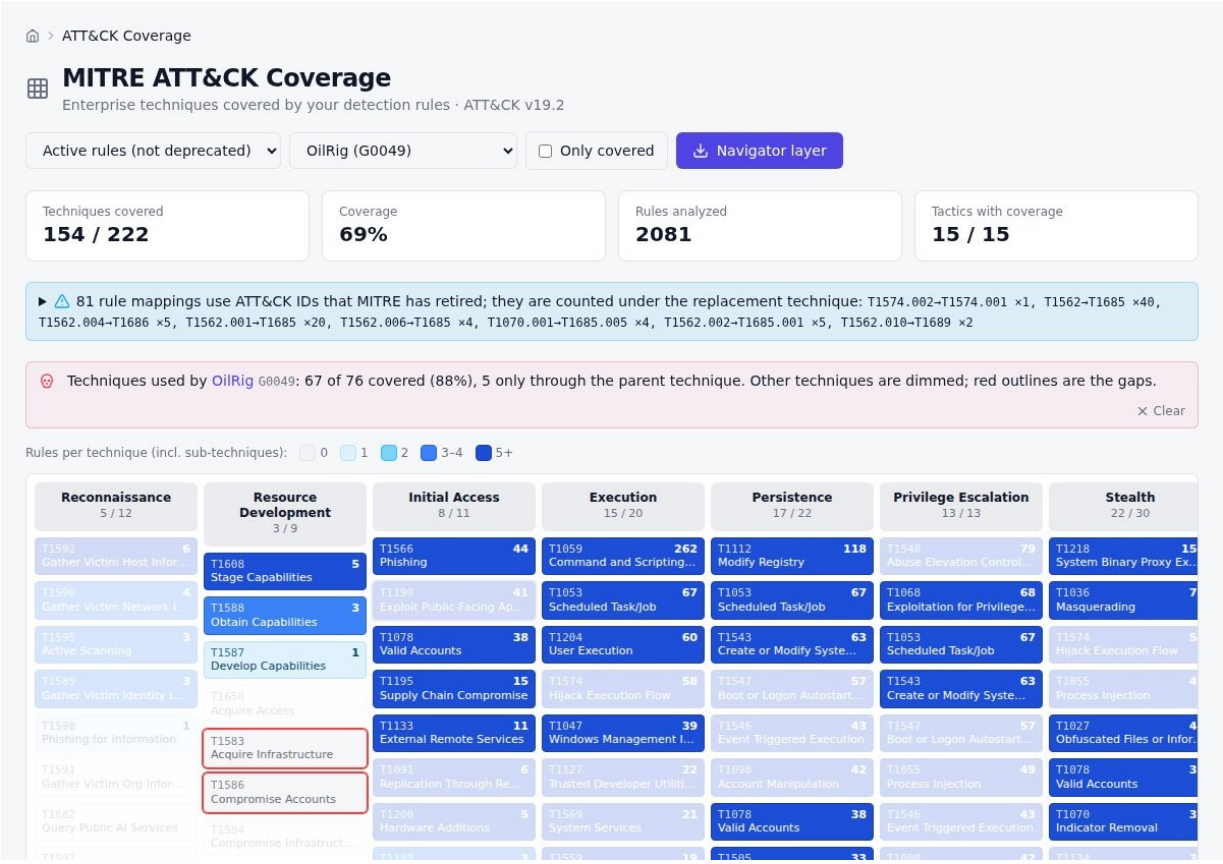
پایین همین بخش، **Atomic Red Team tests** تست‌های آماده‌ی آن تکنیک و زیرتکنیک‌هایش را فهرست می‌کند. کنار هر تست تعداد قوانینی آمده که تله‌متری آن تست را می‌بینند؛ **no rule sees it** یعنی هیچ قانونی رویدادهای آن تست را نمی‌خواند. کنار قوانین هم نشان اعتبارسنجی‌شان نمایش داده می‌شود.



شکل ۲۵ — تست‌های Atomic Red Team تکنیک T1003 و قوانین زیرتکنیک‌ها با نشان Validated

نمایش تکنیک‌های یک گروه مهاجم روی ماتریس

از منوی **Highlight a threat group…** بالای صفحه یک گروه را انتخاب کنید (یا از صفحه‌ی گروه، **In the ATT&CK matrix** را بزنید). تکنیک‌هایی که آن گروه استفاده می‌کند روشن می‌مانند و بقیه کم‌رنگ می‌شوند. تکنیک‌های آن گروه که هیچ قانونی ندارند **کادر قرمز** می‌گیرند؛ این‌ها شکاف‌های شما در برابر همان گروه‌اند. کادر بالای ماتریس درصد پوشش را نشان می‌دهد و **Clear** حالت عادی را برمی‌گرداند.



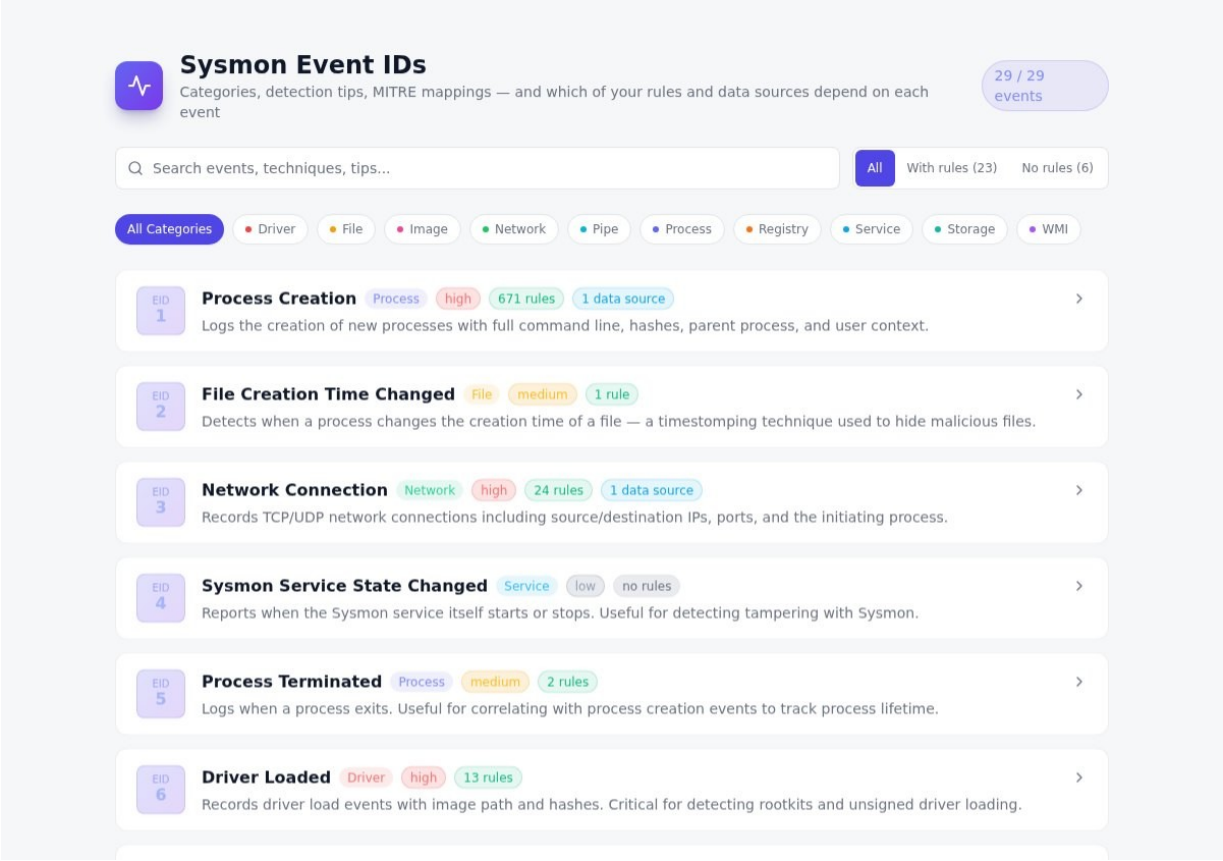
شکل ۲۶ — تکنیک‌های گروه OilRig (APT34) روی ماتریس پوشش

نکته

MITRE گاهی شناسه‌ی تکنیک‌ها را بازنشسته و با شناسه‌ی دیگری جایگزین می‌کند. اگر قوانین شما از شناسه‌ی بازنشسته استفاده کنند، کادر آبی بالای ماتریس آن‌ها را نشان می‌دهد. سامانه این قوانین را زیر شناسه‌ی جایگزین حساب می‌کند، ولی بهتر است نگاشت قانون را اصلاح کنید.

فصل ۶ – رویدادهای Sysmon

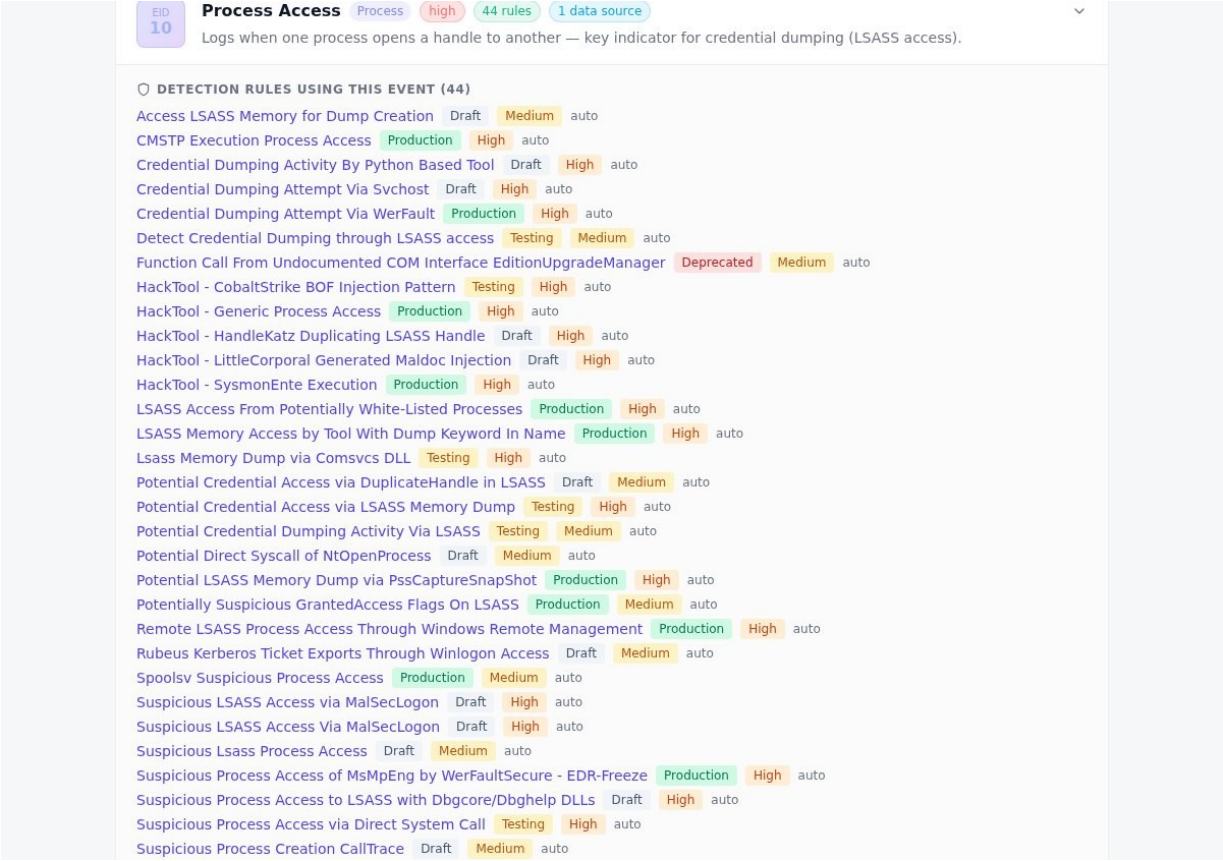
صفحه‌ی **Sysmon Events** مرجع همه‌ی رویدادهای Sysmon است. کنار هر رویداد، قوانین و منابع داده‌ای که به آن وابسته‌اند نمایش داده می‌شود.



شکل ۲۷ – فهرست رویدادهای Sysmon

- هر کارت: شماره‌ی رویداد (EID)، نام، دسته، ارزش تشخیصی (high، medium، low) و تعداد قوانین و منابع داده‌ی وابسته.
- جست‌وجو در نام، توضیح، تکنیک‌ها و نکته‌ها. فیلتر دسته‌ها (Process، Network، Registry و …).
- **With rules** و **No rules**: رویدادهای دارای قانون و بدون قانون.

با کلیک روی هر کارت، جزئیات آن باز می‌شود: فهرست قوانین وابسته (با وضعیت و شدت)، منابع داده، فیلدهای کلیدی، نکته‌های تشخیص و تکنیک‌های مرتبط. اگر قوانین زیاد باشند، اول ۵۰ قانون نمایش داده می‌شود و **Show all** بقیه را نشان می‌دهد.

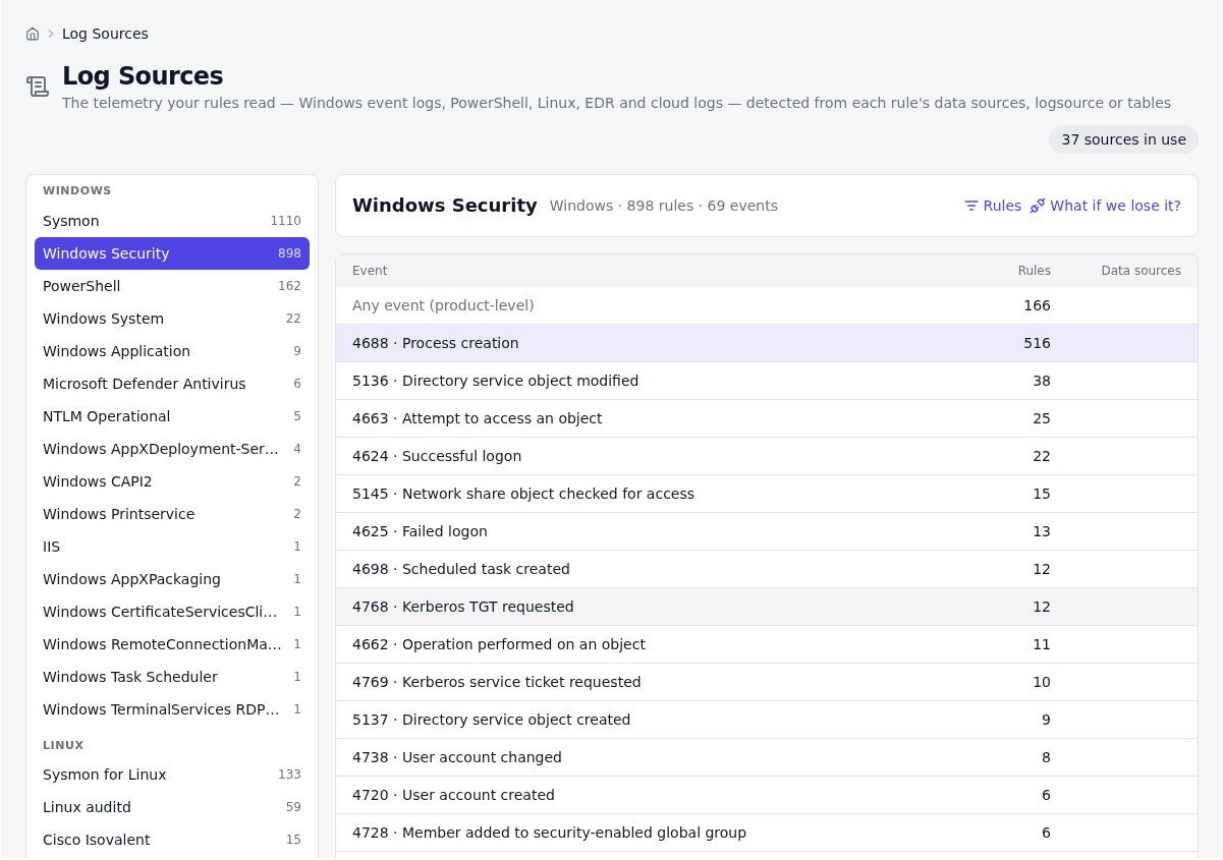


شکل ۲۸ — جزئیات رویداد 10 (Process Access) و قوانین وابسته

برچسب **auto** کنار یک قانون یعنی سامانه وابستگی را خودکار از کوئری تشخیص داده است. وابستگی دستی از فرم ویرایش قانون تعیین می‌شود (فصل ۳).

فصل ۷ – منابع لاگ

بسیاری از قوانین به داده‌ای غیر از Sysmon تکیه دارند: لاگ Security ویندوز، PowerShell، Sysmon for Linux، auditd، رویدادهای EDR (CrowdStrike، Microsoft Defender XDR، Elastic Defend، SentinelOne) و لاگ‌های ابری. صفحه‌ی **Log Sources** همه‌ی این منابع و رویدادهایشان را نشان می‌دهد و مشخص می‌کند هر قانون کدام را می‌خواند.



شکل ۲۹ – منبع Windows Security و قوانینی که رویداد 4688 را می‌خوانند

- **ستون چپ:** منابع لاگ، دسته‌بندی‌شده بر اساس سکو (Windows، Linux، EDR، Identity، Cloud و …). عدد کنار هر منبع تعداد قوانینی است که از آن استفاده می‌کنند.
- **جدول رویدادها:** رویدادهای منبع انتخاب‌شده با تعداد قوانین و صفحه‌های منبع داده. ردیف **Any event (product-level)** قوانینی است که فقط نام محصول را آورده‌اند، نه رویداد مشخص؛ مثلاً قوانین Elastic که می‌گویند «Elastic Defend».
- با کلیک روی یک رویداد، قوانینی که آن را می‌خوانند زیر جدول نمایش داده می‌شوند.
- **Rules** یا **In the rule list:** فهرست قوانین را با همین منبع یا رویداد فیلتر می‌کند.
- **What if we lose it?:** تحلیل اثر قطع همین منبع یا رویداد را در گراف باز می‌کند (فصل ۱۱).
- منبع **Sysmon** صفحه‌ی مرجع جداگانه‌ی خودش را دارد (فصل ۶).

منبع لاگ هر قانون از کجا می‌آید؟

سامانه منبع لاگ را از خود قوانین استخراج می‌کند و بعد از ذخیره یا ورود هر قانون به‌روز می‌کند:

منبع قانون	از کجا خوانده می‌شود
Splunk ESCU	فهرست `data_source` فایل اصلی، مثل «Windows Event Log Security 4688» یا «CrowdStrike ProcessRollup2».
Elastic	تگ‌های «Data Source:» مثل Elastic Defend؛ اگر کوئری روی `event.code` لاگ Security فیلتر کند، همان رویدادها.
Microsoft Sentinel	جدول‌هایی که قانون می‌خواند (مثل DeviceProcessEvents) و شماره‌ی `EventID` در کوئری SecurityEvent.
Sigma	بخش logsource؛ مثلاً process_creation ویندوز علاوه بر Sysmon 1، رویداد Security 4688 را هم دارد.
قوانین دستی	فیلد **Data source** قانون و شماره‌ی رویدادهای Security در کوئری.

> **نکته**
>
> برای اینکه قانونی که خودتان نوشته‌اید به منبع درست وصل شود، نام آن را در فیلد **Data source** قانون به همان شکل ESCU بنویسید؛ مثلاً `Windows Event Log Security 4624, Powershell Script Block Logging 4104`.

روی صفحه‌ی هر قانون، زیر رویدادهای Sysmon، نوار **Log events** منابع لاگ آن قانون را نشان می‌دهد.

منشأ هر ارتباط

کنار هر ارتباط برچسبی نشان می‌دهد این ارتباط از کجا آمده و چقدر قابل اعتماد است:

برچسب	معنی
official	از داده‌ی رسمی MITRE ATT&CK؛ مثل تکنیک‌های یک گروه یا کاهش‌دهنده‌ها.
declared (بدون برچسب)	خود قانون آن را نام برده است: فیلد منبع داده، جدول‌های logsource، Sentinel یا فیلد ATT&CK قانون.
manual	کاربر آن را دستی ثبت کرده است.
inferred	سامانه آن را استنتاج کرده، مثلاً از فیلتر EventID در کوئری یا نگاشت دسته‌ی Sigma؛ خود قانون آن را نام نبرده است. کادر خط‌چین دارد.

برچسب	معنی
text match	نام ابزار مهاجم در متن قانون پیدا شده است؛ ممکن است قانون واقعاً آن را تشخیص ندهد. کادر خط‌چین دارد.

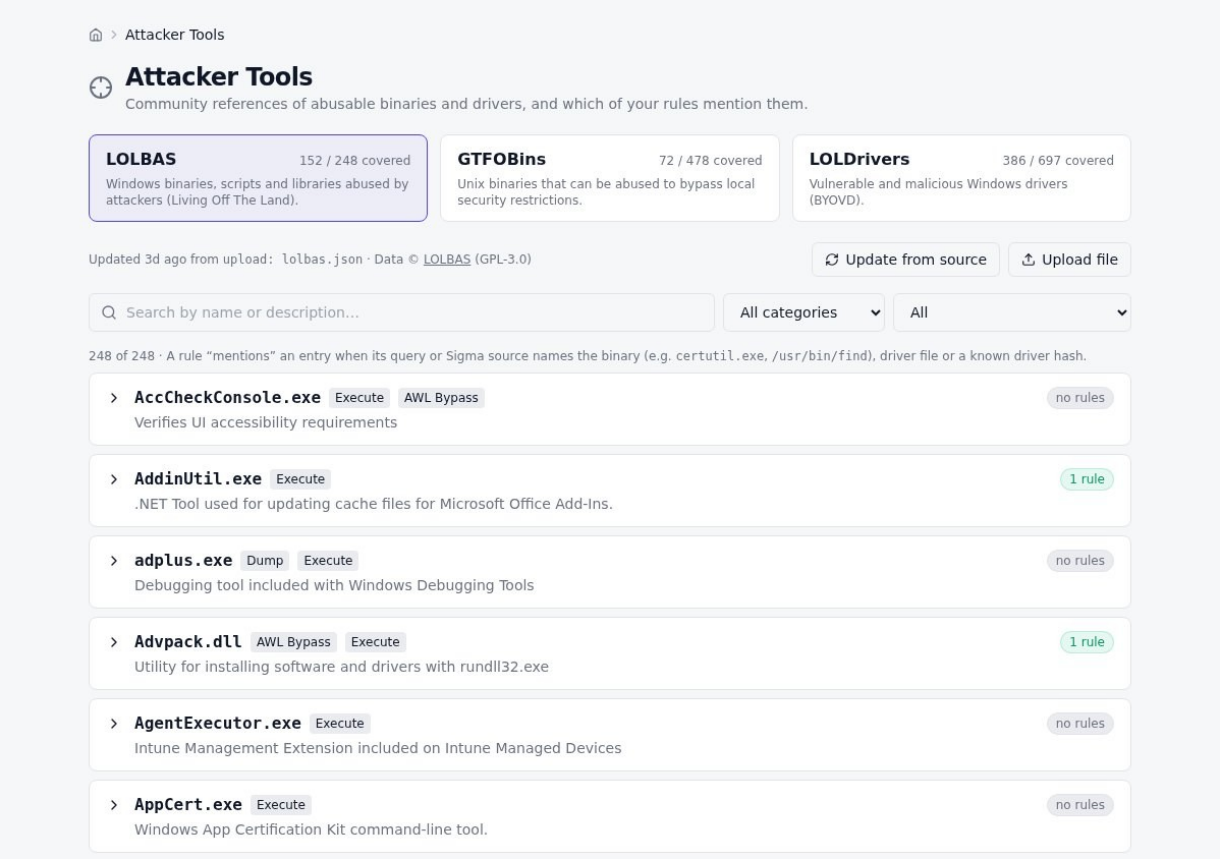
نکته

اگر قانونی به چند رویداد با هم نیـاز دارد (در ESCU بـا «AND»، مثلاً «Sysmon EventID 1 AND Sysmon EventID 11»)، سامانه این شرط را نگه می‌دارد. در تحلیل اثر، قطع هر کدام از آن رویدادها قانون را از کار انداخته حساب می‌کند.

فصل ۸ – ابزارهای مهاجم

صفحه‌ی **Attacker Tools** سه مرجع شناخته‌شده را نشان می‌دهد:

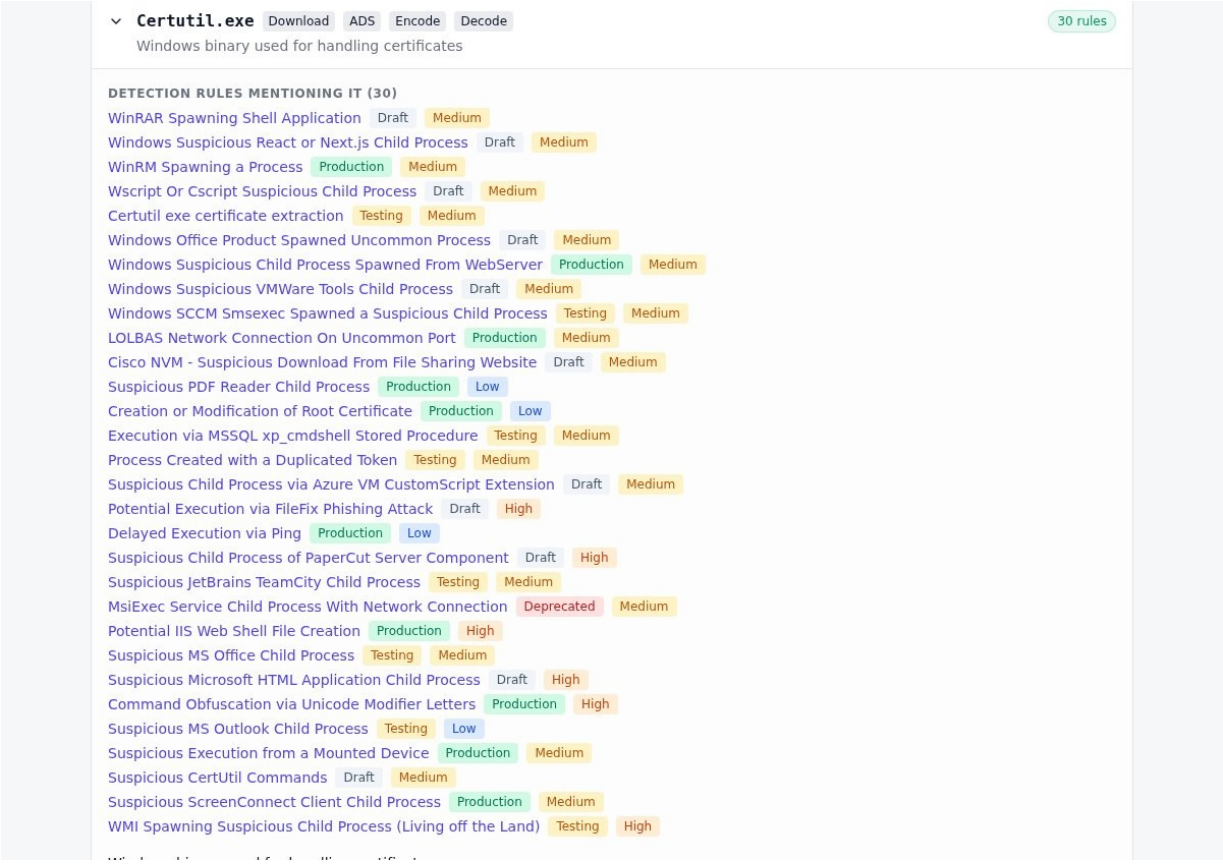
- **LOLBAS:** فایل‌ها، اسکریپت‌ها و کتابخانه‌های ویندوز که مهاجم از آن‌ها سوءاستفاده می‌کند.
- **GTFOBins:** فایل‌های یونیکس که برای دور زدن محدودیت‌ها استفاده می‌شوند.
- **LOLDrivers:** درایورهای آسیب‌پذیر یا مخرب ویندوز.



شکل ۳۰ – فهرست ابزارهای LOLBAS

- **کارت‌های بالا:** با کلیک روی هر کارت، مرجع مربوط انتخاب می‌شود. عدد کارت نشان می‌دهد چند ابزار دست‌کم یک قانون دارند.
- **جست‌وجو و فیلترها:** جست‌وجو در نام و توضیح، فیلتر دسته (مثل Execute یا Download) و فیلتر دارای قانون یا بدون قانون.
- کنار هر ابزار تعداد قوانینی که به آن اشاره کرده‌اند نمایش داده می‌شود. **no rules** یعنی هیچ قانونی آن را پوشش نمی‌دهد.

با کلیک روی هر ابزار، جزئیات آن باز می‌شود: کاربردهای سوءاستفاده، دستور نمونه، تکنیک‌های ATT&CK، منابع و فهرست قوانینی که به آن اشاره دارند.



شکل ۳۱ — جزئیات certutil.exe و قوانینی که به آن اشاره دارند

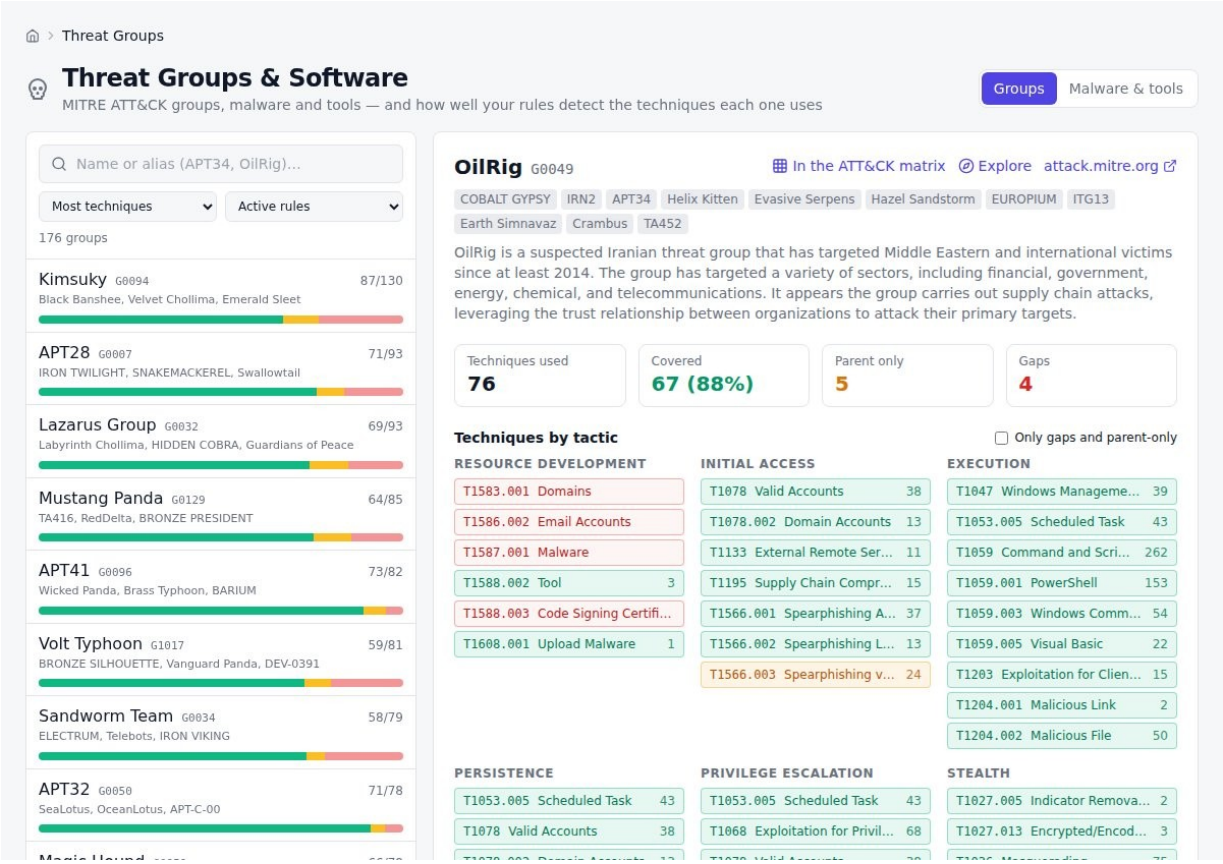
به‌روزرسانی داده‌ها (مدیر)

- **Update from source:** دانلود آخرین نسخه از سایت رسمی هر مرجع. سرور باید به اینترنت دسترسی داشته باشد.
- **Upload file:** برای سرورهای بدون اینترنت. فایل JSON رسمی مرجع را روی سیستم دیگری دانلود و این‌جا بارگذاری کنید.

سامانه با مقایسه‌ی کوئری و منبع Sigma هر قانون با نام ابزارها، خودکار پیدا می‌کند کدام قانون به کدام ابزار اشاره دارد. این اطلاعات بعد از هر تغییر خودکار به‌روز می‌شود.

فصل ۹ – گروه‌های تهدید و بدافزارها

صفحه‌ی **Threat Groups** گروه‌های مهاجم شناخته‌شده (مثل APT34/OilRig یا APT29)، بدافزارها و ابزارهای مهاجم را از پایگاه MITRE ATT&CK نشان می‌دهد و برای هر کدام مشخص می‌کند قوانین شما چه سهمی از تکنیک‌هایش را تشخیص می‌دهند. این همان سؤال همیشگی است: «در برابر فلان گروه چقدر آماده‌ایم؟»



شکل ۳۲ – پوشش تکنیک‌های گروه OilRig

- **تب‌ها: Watchlist** برای گروه‌هایی که سازمان پایش می‌کند (پایین‌تر)، **Groups** برای گروه‌های مهاجم و **Malware & tools** برای بدافزارها و ابزارها.
- **فهرست سمت چپ:** جست‌وجو در نام و نام‌های دیگر (مثلاً APT34 گروه OilRig را پیدا می‌کند). مرتب‌سازی بر اساس بیشترین تکنیک، بیشترین شکاف، بهترین پوشش یا نام. عدد کنار هر مورد یعنی «تکنیک‌های پوشش‌داده‌شده / کل تکنیک‌ها».
- **نوار رنگی:** سبز یعنی پوشش‌داده‌شده، زرد یعنی فقط قانون روی تکنیک والد وجود دارد، قرمز یعنی شکاف.
- **فیلتر وضعیت:** پوشش با قوانین فعال، فقط Production، یا Production + testing حساب شود.
- **Search descriptions (sector, country):** جست‌وجو در توضیح گروه‌ها هم انجام می‌شود؛ مثلاً « financial»، «energy» یا «Middle East» گروه‌هایی را پیدا می‌کند که به این بخش یا منطقه حمله کرده‌اند.

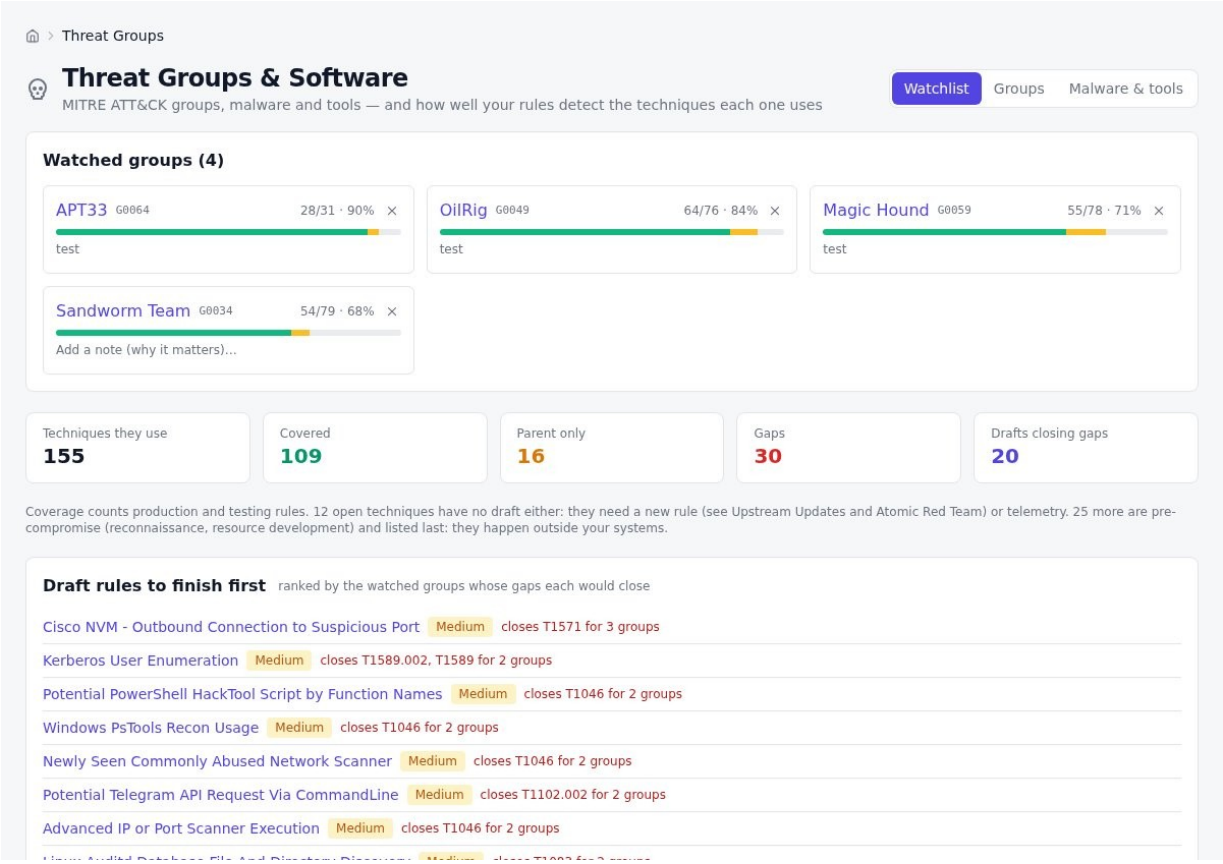
جزئیات یک گروه

- **کارت‌ها:** تعداد تکنیک‌های گروه، تعداد و درصد پوشش‌داده‌شده، تعداد **Parent only** و تعداد شکاف‌ها.
- **Techniques by tactic:** تکنیک‌های گروه، دسته‌بندی‌شده بر اساس تاکتیک، با همان رنگ‌بندی. با کلیک روی هر تکنیک، زنجیره‌ی تشخیص آن باز می‌شود. گزینه‌ی **Only gaps and parent-only** فقط کمبودها را نشان می‌دهد.
- **Malware and tools it uses:** بدافزارها و ابزارهای گروه با پوشش هر کدام.
- **In the ATT&CK matrix:** تکنیک‌های گروه را روی ماتریس پوشش نشان می‌دهد (فصل ۵). **Explore** گروه را در گراف دانش باز می‌کند.

> **نکته**
>
> **Parent only** یعنی گروه از یک زیرتکنیک استفاده می‌کند (مثلاً T1003.001) ولی قوانین شما فقط به تکنیک والد (T1003) نگاشت شده‌اند. چنین قانونی ممکن است آن زیرتکنیک را تشخیص بدهد یا ندهد؛ بررسی کنید.

لیست پایش (Watchlist)

همه‌ی گروه‌های ATT&CK برای یک سازمان به یک اندازه مهم نیستند. با ستاره‌ی کنار نام هر گروه (یا دکمه‌ی **Watch** در جزئیات گروه) آن را به لیست پایش سازمان اضافه کنید؛ این لیست برای همه‌ی کاربران مشترک است و کاربرانی که مجوز ویرایش قوانین دارند آن را تغییر می‌دهند. برای هر گروه می‌توانید یادداشتی بنویسید که چرا مهم است.



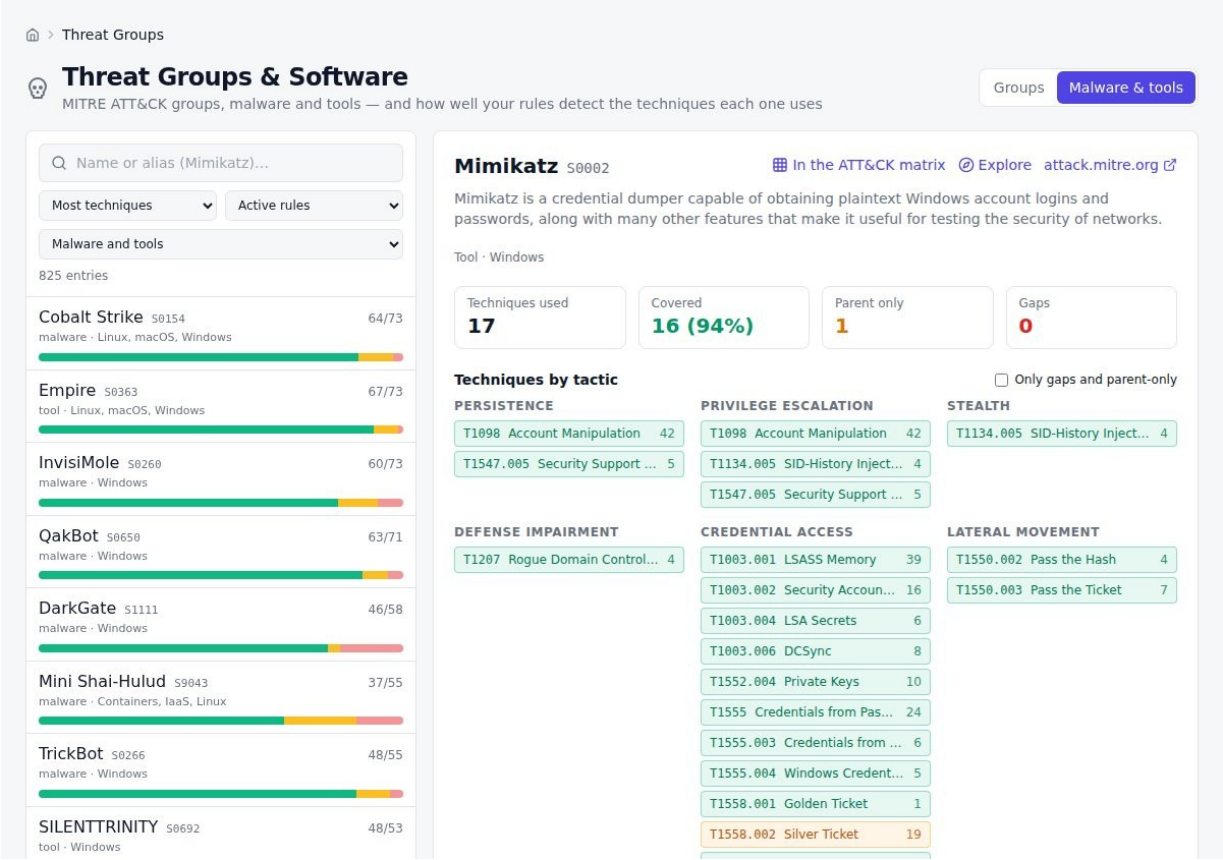
شکل ۳۳ — لیست پایش: گروه‌های مرتبط، شکاف‌هایشان و draftهایی که باید اول کامل شوند

- **کارت‌ها:** تعداد تکنیک‌هایی که گروه‌های پایش‌شده استفاده می‌کنند، و چندتایشان را قوانین production و testing پوشش داده‌اند، فقط از طریق تکنیک والد، یا اصلاً.
- **Draft rules to finish first:** قوانین draft به ترتیب اهمیت: قانونی که شکاف گروه‌های بیشتری را می‌بندد بالاتر است. قوانینی که فقط به تکنیک‌های پوشش‌داده‌شده اضافه می‌شوند با برچسب «adds depth» در انتها می‌آیند.
- **Techniques of the watched groups:** تکنیک‌ها به ترتیب اولویت: اول شکاف‌ها، بعد Parent only، و در هر دسته تکنیکی که گروه‌های بیشتری استفاده می‌کنند. کنار هر تکنیک تعداد قوانین فعال و draft و لینک تست‌های Atomic آمده است.
- تکنیک‌های **pre-compromise** (شناسایی و آماده‌سازی زیرساخت مهاجم) در انتهای فهرست می‌آیند، چون بیرون از سیستم‌های شما اتفاق می‌افتند و معمولاً با تله‌متری داخلی دیده نمی‌شوند.
- در صفحه‌ی **ATT&CK Coverage** گزینه‌ی **Watchlist ★** در «Highlight a threat group» تکنیک‌های همه‌ی گروه‌های پایش‌شده را روی ماتریس نشان می‌دهد.

> **نکته**
>
> پوشش در لیست پایش همیشه با قوانین production و testing حساب می‌شود، چون draftها هنوز جایی اجرا نمی‌شوند. لیست پایش در پشتیبان JSON هم ذخیره می‌شود.

بدافزارها و ابزارها

در تب **Malware & tools** همین اطلاعات برای هر بدافزار یا ابزار نمایش داده می‌شود، به‌علاوه‌ی نوع، سکوها و گروه‌هایی که از آن استفاده کرده‌اند. فیلتر نوع، بدافزارها را از ابزارها جدا می‌کند.

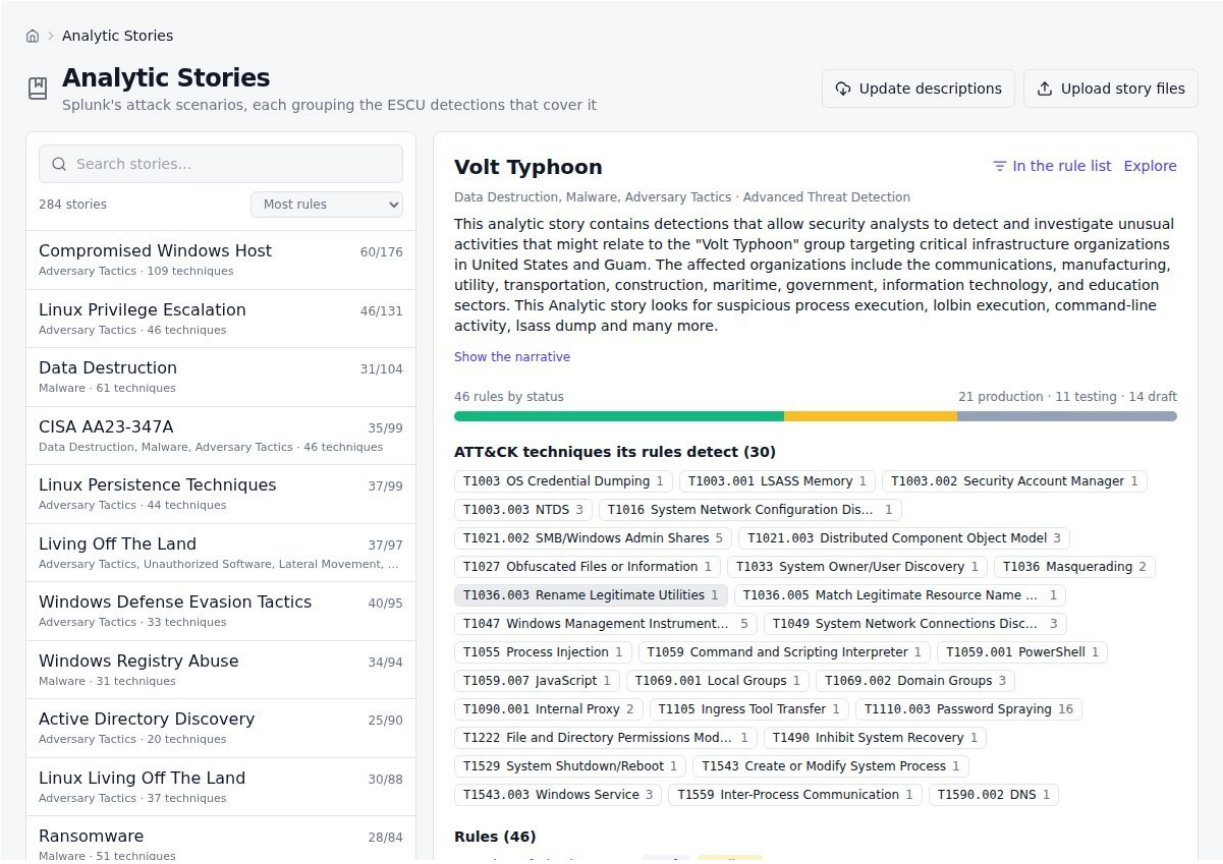


شکل ۳۴ – پوشش تکنیک‌های Mimikatz

این داده‌ها همراه سامانه نصب می‌شوند و به اینترنت نیاز ندارند. با به‌روزرسانی داده‌ی ATT&CK، گروه‌ها و بدافزارها هم به‌روز می‌شوند.

فصل ۱۰ – سناریوهای تحلیلی Splunk

Splunk قوانین ESCU را در قالب **Analytic Story** دسته‌بندی می‌کند؛ هر سناریو یک حمله یا تهدید مشخص است، مثل Volt Typhoon یا Ransomware، و قوانینی که آن را تشخیص می‌دهند. صفحه‌ی **Analytic Stories** این سناریوها را نشان می‌دهد.



شکل ۳۵ – سناریوی Volt Typhoon با قوانین و تکنیک‌هایش

- **فهرست سمت چپ:** جست‌وجو و مرتب‌سازی بر اساس تعداد قوانین، تعداد قوانین Production یا نام. عدد کنار هر سناریو یعنی «قوانین Production / همه‌ی قوانین».
- **جزئیات:** توضیح سناریو و روایت کامل آن (**Show the narrative**)، نوار وضعیت قوانین، تکنیک‌های ATT&CK که قوانینش تشخیص می‌دهند و فهرست قوانین.
- تکنیکی که کادر خط‌چین قرمز دارد، فقط قوانین deprecated دارد.
- **In the rule list:** فهرست قوانین را با همین سناریو فیلتر می‌کند؛ مثلاً برای تغییر وضعیت گروهی قوانین یک سناریو.

سناریوها با ورود قوانین ESCU خودکار ساخته می‌شوند، چون هر قانون نام سناریوهایش را دارد. توضیح و روایت سناریوها از پوشه‌ی stories مخزن رسمی splunk/security_content می‌آید:

- **Download missing descriptions:** دانلود توضیح سناریوهایی که هنوز توضیح ندارند. سرور در اولین اجرا این کار را خودکار انجام می‌دهد.
- **Upload story files:** برای سرورهای بدون اینترنت. فایل‌های YAML پوشه‌ی stories را روی سیستم دیگری دریافت و این‌جا بارگذاری کنید.

روی صفحه‌ی هر قانون ESCU، نوار **Analytic stories** سناریوهای آن قانون را نشان می‌دهد.

فصل ۱۱ — Atomic Red Team و اعتبارسنجی در لب

اینکه قانونی به تکنیک T1003.001 نگاشت شده، یعنی **ادعا** می‌کند آن حمله را تشخیص می‌دهد. برای اینکه مطمئن شویم، باید حمله را در یک محیط آزمایشی (لب) واقعاً انجام دهیم و ببینیم Splunk هشدار می‌دهد یا نه. **Atomic Red Team** مجموعه‌ای از تست‌های کوچک و آماده‌ی حمله برای هر تکنیک ATT&CK است و DetectKB برای هر قانون می‌گوید کدام تست‌ها را اجرا کنید و نتیجه را نگه می‌دارد.

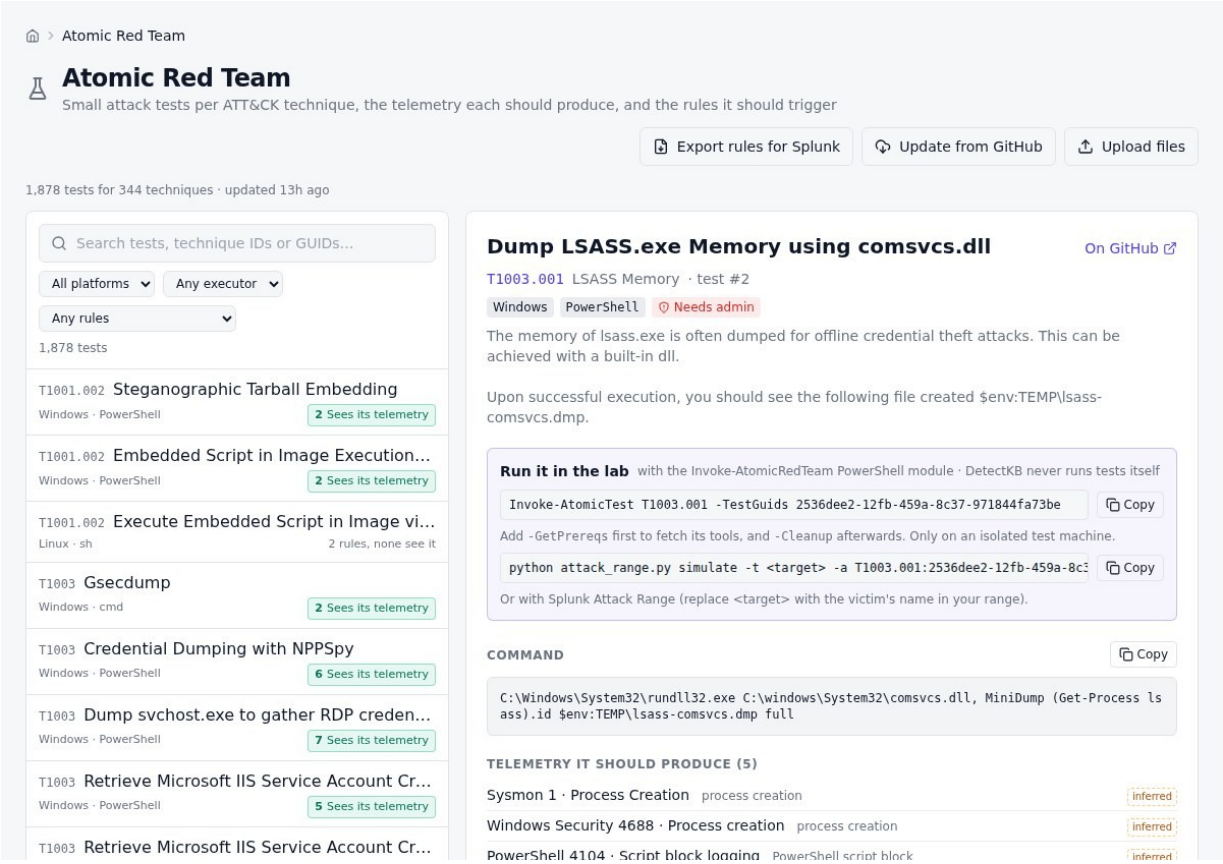
> **توجه**
>
> DetectKB خودش هیچ تستی اجرا نمی‌کند و به ماشین‌های لب وصل نمی‌شود. تست‌ها را خودتان روی ماشین قربانی در لب اجرا می‌کنید.
>
> تست‌ها حمله‌ی واقعی‌اند. فقط روی ماشین‌های ایزوله‌ی لب اجرا شوند، هرگز روی سیستم‌های عملیاتی. راه‌اندازی لب در سند جداگانه‌ی `docs/lab-setup` آمده است.

روند کار

1. در DetectKB قانون (یا تکنیک) را باز کنید و تستی را که باید قانون را فعال کند پیدا کنید.
2. دستور آماده‌ی تست را کپی کنید و روی ماشین قربانی در لب اجرا کنید.
3. چند دقیقه بعد در Splunk لب ببینید قانون هشدار داده یا نه.
4. نتیجه را در DetectKB ثبت کنید. وضعیت قانون خودکار به‌روز می‌شود.

صفحه‌ی Atomic Red Team

صفحه‌ی **Atomic Red Team** در نوار کناری همه‌ی تست‌ها را نشان می‌دهد (حدود ۱۹۰۰ تست برای بیش از ۳۰۰ تکنیک). سمت چپ فهرست تست‌ها با جست‌وجو و فیلتر است و سمت راست جزئیات تست انتخاب‌شده.

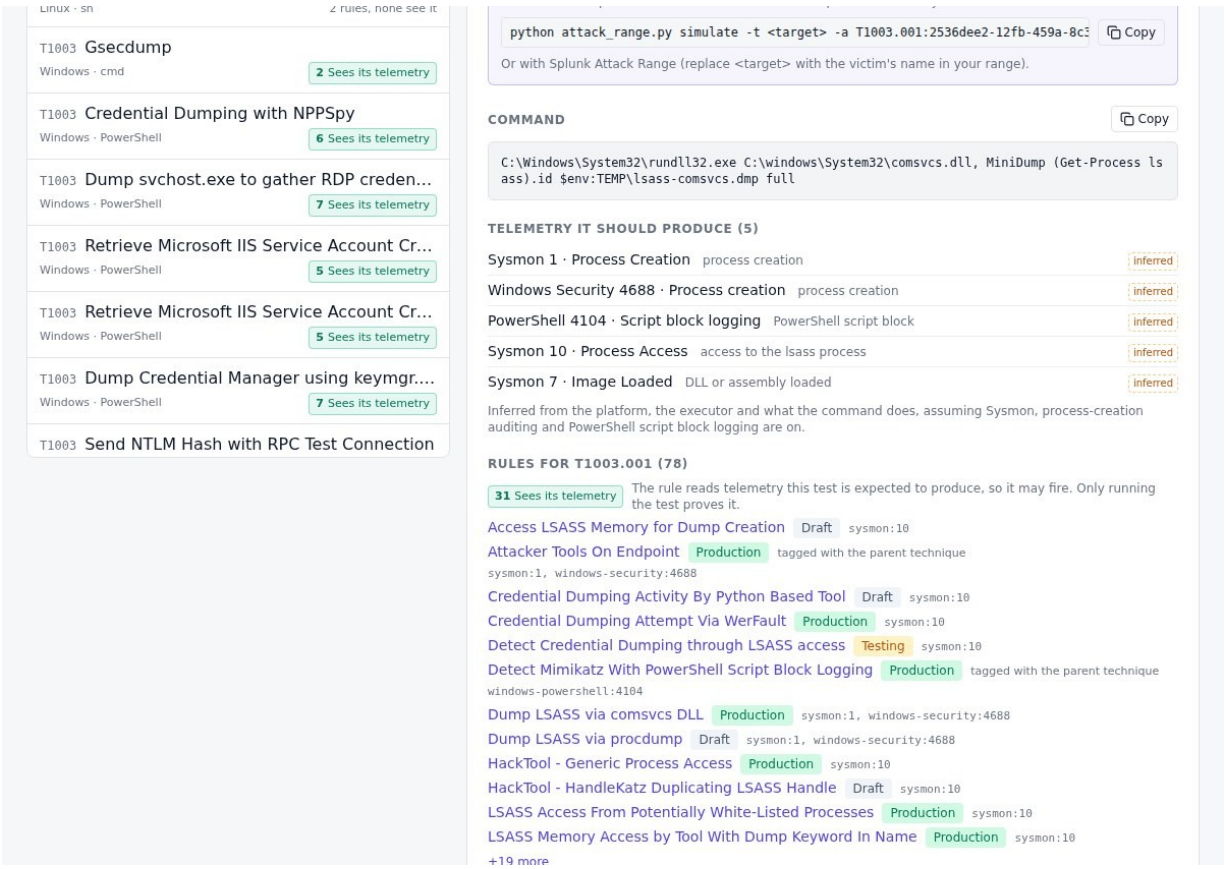


شکل ۳۶ — صفحه‌ی Atomic Red Team و جزئیات یک تست

- **فیلترها:** پلتفرم (Windows، Linux و ...)، نوع اجرا (PowerShell، cmd، sh، bash، Manual)، و وضعیت قوانین: **A rule sees its telemetry** (قانونی رویدادهای تست را می‌بیند)، **No rule sees its telemetry** و **No rule for the technique** (شکاف پوشش).
- **Run it in the lab:** خط آماده‌ی `Invoke-AtomicTest` برای اجرا با ماژول Invoke-AtomicRedTeam، و خط معادل برای Splunk Attack Range. دکمه‌ی **Copy** آن را کپی می‌کند. قبل از اجرا با `-GetPrereqs` ابزارهای تست را دریافت کنید و بعد از آن با `-Cleanup` پاک‌سازی کنید.
- **Command:** دستور حمله با مقادیر پیش‌فرض پرشده؛ **Show the #{placeholders}** نسخه‌ی خام را نشان می‌دهد. **Prerequisites**، **Inputs** و **Cleanup** هم زیر آن آمده‌اند.
- **Telemetry it should produce:** رویدادهایی که اجرای تست باید تولید کند، مثل Sysmon 10 برای دسترسی به lsass یا 4104 برای PowerShell. این‌ها را سامانه از روی دستور حدس زده و برچسب **inferred** دارند.

قوانین هر تست

بخش **Rules for ...** قوانین همان تکنیک را در چهار دسته نشان می‌دهد:



شکل ۳۷ — تله‌متری مورد انتظار و قوانین مرتبط با یک تست

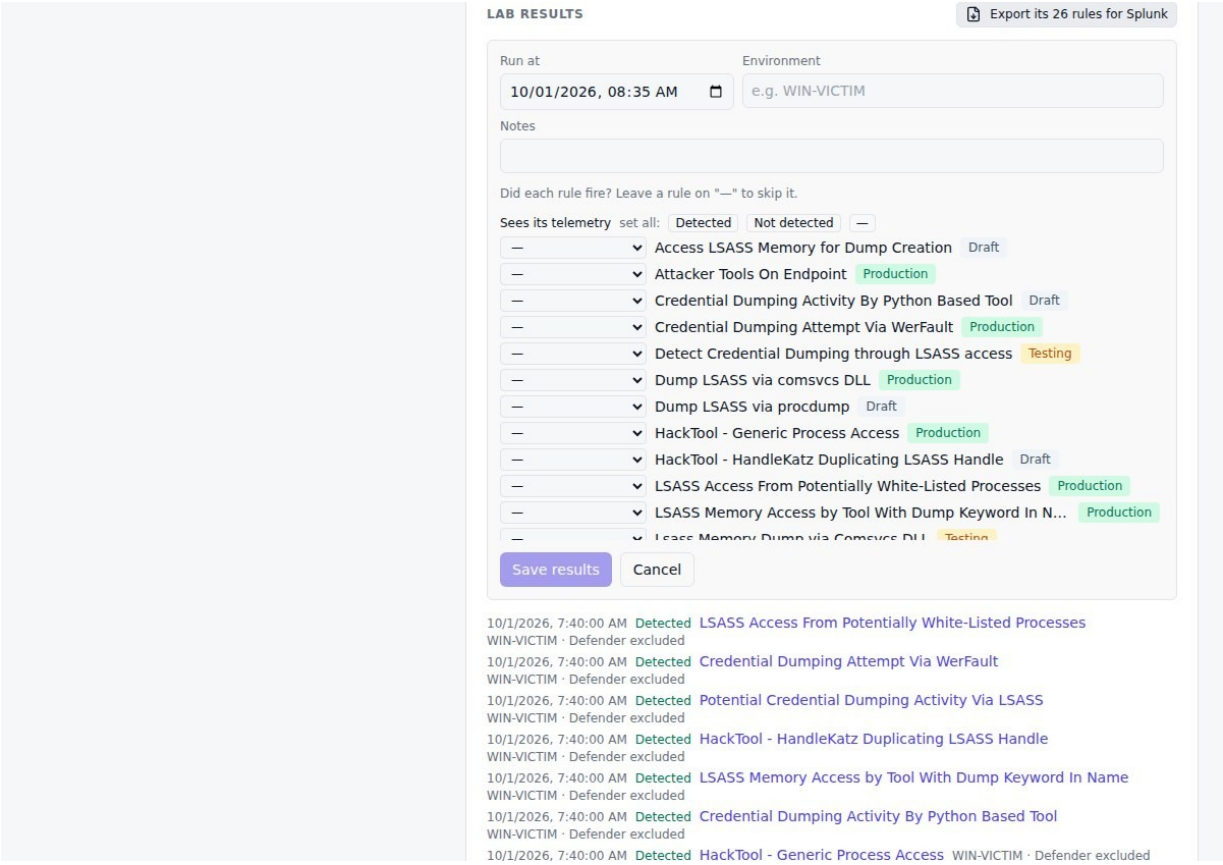
دسته	معنی
Sees its telemetry	قانون رویدادی را می‌خواند که این تست تولید می‌کند؛ احتمالاً با این تست فعال می‌شود. فقط اجرای تست آن را ثابت می‌کند.
Needs the EDR	قانون به داده‌ی یک EDR (مثل CrowdStrike یا Defender XDR) وابسته است و فقط جایی کار می‌کند که آن محصول نصب باشد.
Other telemetry	هم‌تکنیک است، ولی رویدادی را می‌خواند که این تست تولید نمی‌کند.
No telemetry links	قانون هیچ منبع لاگ شناخته‌شده‌ای ندارد و سامانه نمی‌تواند قضاوت کند.

> **نکته**
>
> قانونی که روی تکنیک مادر (مثلاً T1003) تگ خورده، برای تست‌های زیرتکنیک‌ها (T1003.001) هم حساب می‌شود؛ برعکس آن نه.

ثبت نتیجه‌ی یک اجرا برای چند قانون

بعد از اجرای یک تست، معمولاً می‌خواهید نتیجه را برای همه‌ی قوانین مرتبط ثبت کنید. در جزئیات تست، بخش **Lab results** را پیدا کنید و **Record a run** را بزنید:

1. زمان اجرا (**Run at**)، محیط (مثلاً `WIN-VICTIM · Defender excluded`) و در صورت نیاز یادداشت را وارد کنید.
2. برای هر قانون نتیجه را انتخاب کنید. دکمه‌های **set all** کنار هر دسته، نتیجه‌ی همه‌ی قوانین آن دسته را یک‌جا تعیین می‌کنند. قانونی که روی «—» بماند ثبت نمی‌شود.
3. **Save results** را بزنید.



شکل ۳۸ — ثبت نتیجه‌ی یک اجرا برای قوانین مرتبط و تاریخچه‌ی اجراهای تست

زیر فرم، تاریخچه‌ی اجراهای همین تست با نتیجه‌ی هر قانون نمایش داده می‌شود.

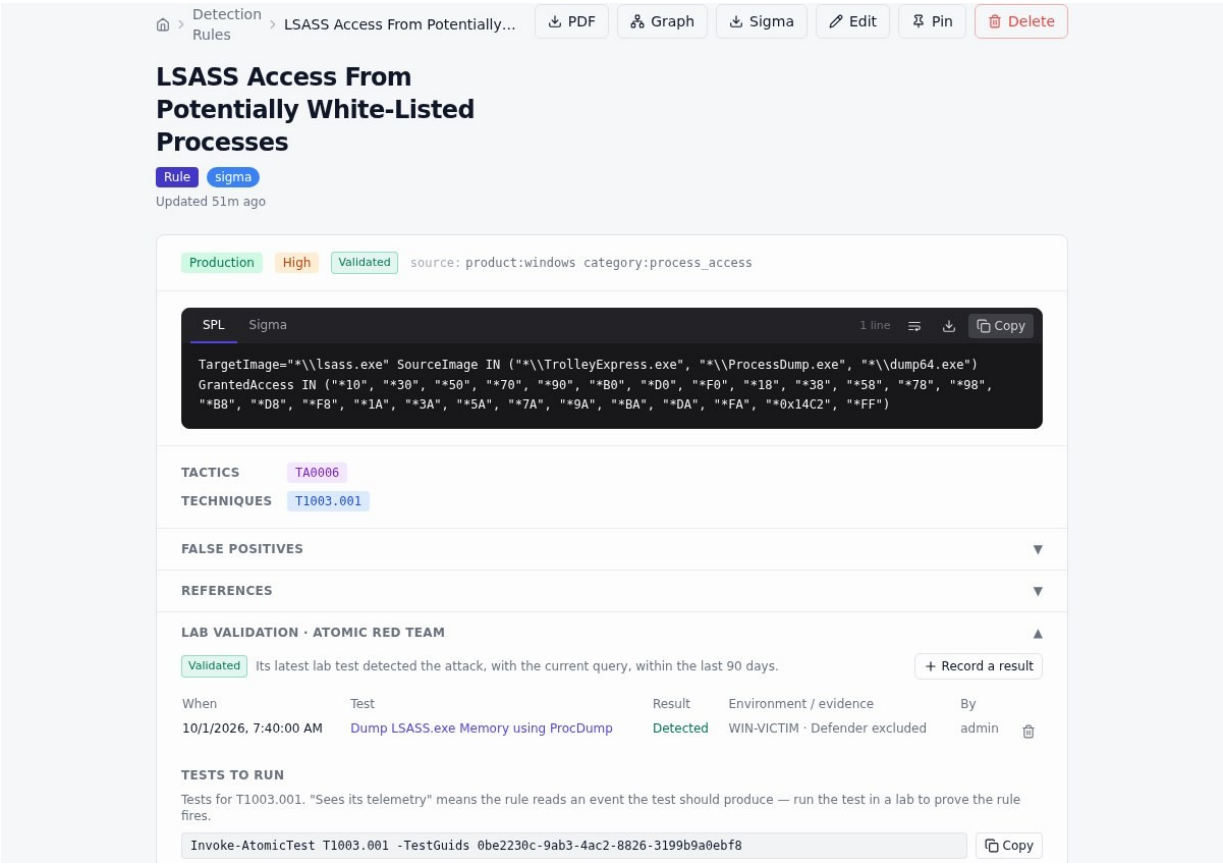
نتیجه‌ها

نتیجه	کی انتخاب کنیم
Detected	قانون برای این اجرا هشدار داد.
Not detected	حمله اجرا شد و لاگش در Splunk هست، ولی قانون هشدار نداد.
Partly detected	قانون فقط بخشی از حمله را گرفت.
Blocked (did not run)	آنتی‌ویروس یا EDR جلوی اجرای تست را گرفت؛ قانون واقعاً آزموده نشد.
Test error	تست به‌درستی اجرا نشد (مثلاً پیش‌نیاز نداشت).

> **نکته**
>
> نتیجه‌های **Blocked** و **Test error** در تاریخچه می‌مانند ولی وضعیت قانون را تغییر نمی‌دهند، چون چیزی درباره‌ی خود قانون نمی‌گویند.

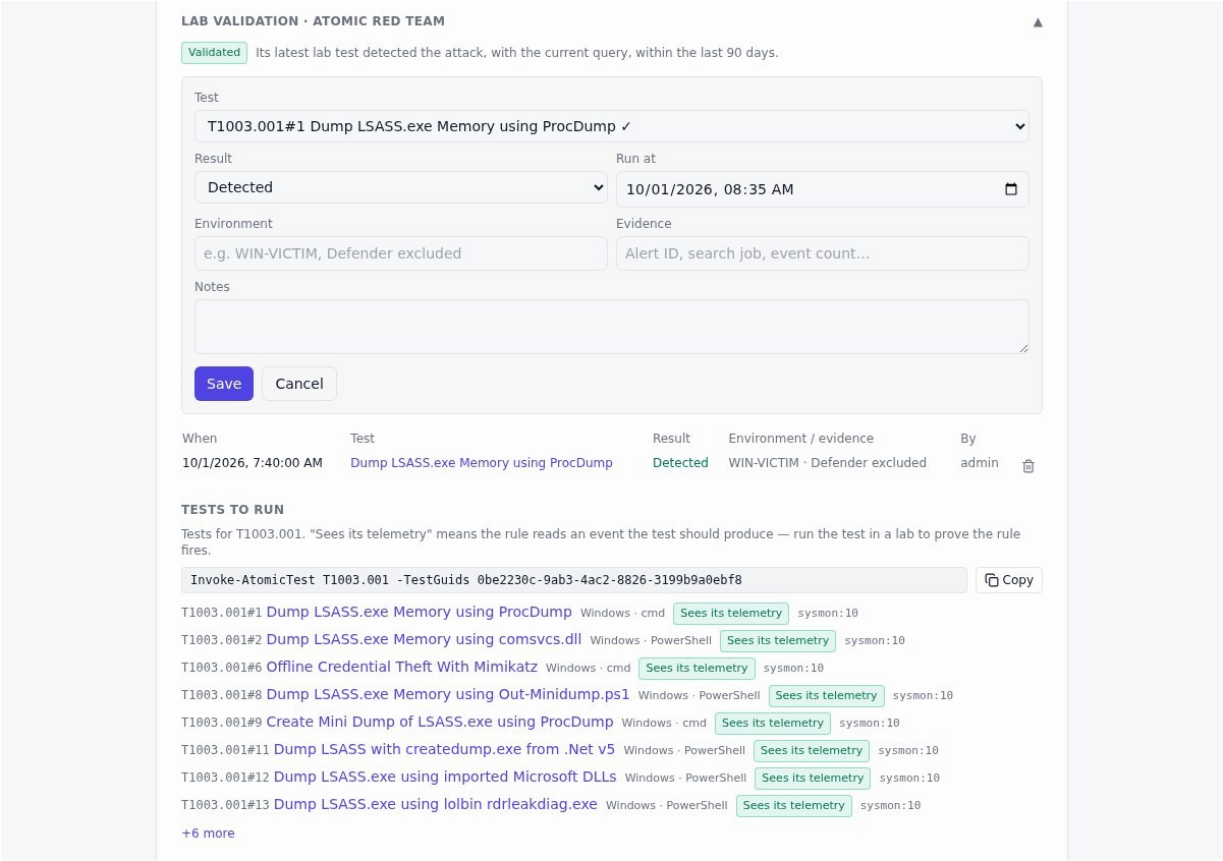
اعتبارسنجی در صفحه‌ی قانون

در صفحه‌ی هر قانون، بخش **Atomic Red Team · Lab validation** را باز کنید. بالای آن وضعیت قانون و توضیحش، سپس تاریخچه‌ی تست‌ها (زمان، تست، نتیجه، محیط و مدرک، ثبت‌کننده) و در پایان **Tests to run**، یعنی تست‌های پیشنهادی همین قانون با خط آماده‌ی اجرا آمده است.



شکل ۳۹ — نشان Validated در بالای قانون و بخش Lab validation

برای ثبت یک نتیجه فقط برای همین قانون، **Record a result** را بزنید. تست را از فهرست انتخاب کنید (تست‌هایی که قانون تله‌متری‌شان را می‌بیند با ✓ مشخص شده‌اند) یا **Another test** را برای تستی غیر از Atomic Red Team بزنید. در **Evidence** شناسه‌ی هشدار یا جستجوی Splunk را بنویسید تا بعداً قابل پیگیری باشد.



شکل ۴۰ — فرم ثبت نتیجه در صفحه‌ی قانون

وضعیت اعتبارسنجی قانون

وضعیت هر قانون از **آخرین** نتیجه‌ی معتبرش می‌آید:

وضعیت	یعنی
Validated	آخرین تست، حمله را تشخیص داد؛ با همین کوئری و در ۹۰ روز اخیر.
Partly validated	آخرین تست بخشی از حمله را تشخیص داد.
Failed in lab	آخرین تست حمله را تشخیص نداد.
Retest	کوئری قانون بعد از آخرین تست تغییر کرده، یا آخرین تست قدیمی‌تر از ۹۰ روز است. در تاریخچه، اجراهای قبل از تغییر کوئری با **query changed since** مشخص می‌شوند.
Not tested	هیچ نتیجه‌ای برای قانون ثبت نشده است.

نتیجه‌ی اشتباه را با آیکون سطل زباله کنار آن در تاریخچه حذف کنید. ثبت و حذف نتیجه به دسترسی ویرایش قانون (`editor` یا `admin`) نیاز دارد.

اگر قانون هشدار نداد

Not detected همیشه به این معنی نیست که قانون خراب است. قبل از اصلاح قانون، این‌ها را بررسی کنید:

علت احتمالی	چطور بفهمیم
حمله اصلاً اجرا نشد	خروجی تست روی ماشین قربانی. در این صورت نتیجه را **Blocked** یا **Test error** ثبت کنید.
لاگ تولید نشد (Sysmon یا Audit)	در Splunk در بازه‌ی زمان تست، `index=sysmon` یا `index=win` را جستجو کنید.
لاگ به Splunk نرسید	اگر همان جستجو خالی است، Forwarder یا index را بررسی کنید.
ماکرو یا فیلتر قانون	کوئری قانون را دستی و بدون فیلتر انتهایی اجرا کنید.
قانون برای نسخه‌ی دیگری از حمله است	دستور تست را با منطق قانون مقایسه کنید.

فقط وقتی لاگ حمله در Splunk هست ولی قانون آن را نمی‌گیرد، قانون واقعاً به بازبینی نیاز دارد.

خروجی قوانین برای Splunk لب

برای اینکه قوانین در Splunk لب اجرا شوند، باید آن‌ها را آن‌جا تعریف کنید. **Export rules for Splunk** در بالای صفحه‌ی Atomic Red Team یک فایل `savedsearches.conf` می‌سازد:

- **Rules:** قوانین Production، Production و testing، یا همه به‌جز deprecated.
- **Only:** فقط قوانین تکنیک‌هایی که تست Atomic دارند، یا همه‌ی قوانین.
- در جزئیات هر تست، **Export its … rules for Splunk** فقط قوانینی را که تله‌متری همان تست را می‌بینند خروجی می‌دهد.

هر قانون در این فایل یک جستجوی ذخیره‌شده است که هر ۵ دقیقه روی ۱۵ دقیقه‌ی اخیر اجرا می‌شود و اگر نتیجه داشته باشد هشدار می‌دهد. فایل را در `$SPLUNK_HOME/etc/apps/<app>/local/` روی Splunk لب بگذارید و Splunk را دوباره راه‌اندازی کنید. فقط قوانینی که کوئری SPL دارند در خروجی می‌آیند. قوانین ESCU به اپ‌های ES Content Update و CIM روی Splunk لب نیاز دارند.

به‌روزرسانی تست‌ها (مدیر)

- **Download from GitHub / Update from GitHub:** دریافت فهرست تست‌ها از مخزن رسمی redcanaryco/atomic-red-team. سرور در اولین اجرا این کار را خودکار انجام می‌دهد.
- **Upload files:** برای سرور بدون اینترنت؛ فایل `atomics/Indexes/index.yaml` یا فایل‌های تکنیک (`atomics/T*/T*.yaml`) را بارگذاری کنید.

> **نکته**
>
> نتیجه‌های ثبت‌شده بخشی از پشتیبان JSON هستند و با بازگردانی برمی‌گردند.

فصل ۱۲ – گراف دانش

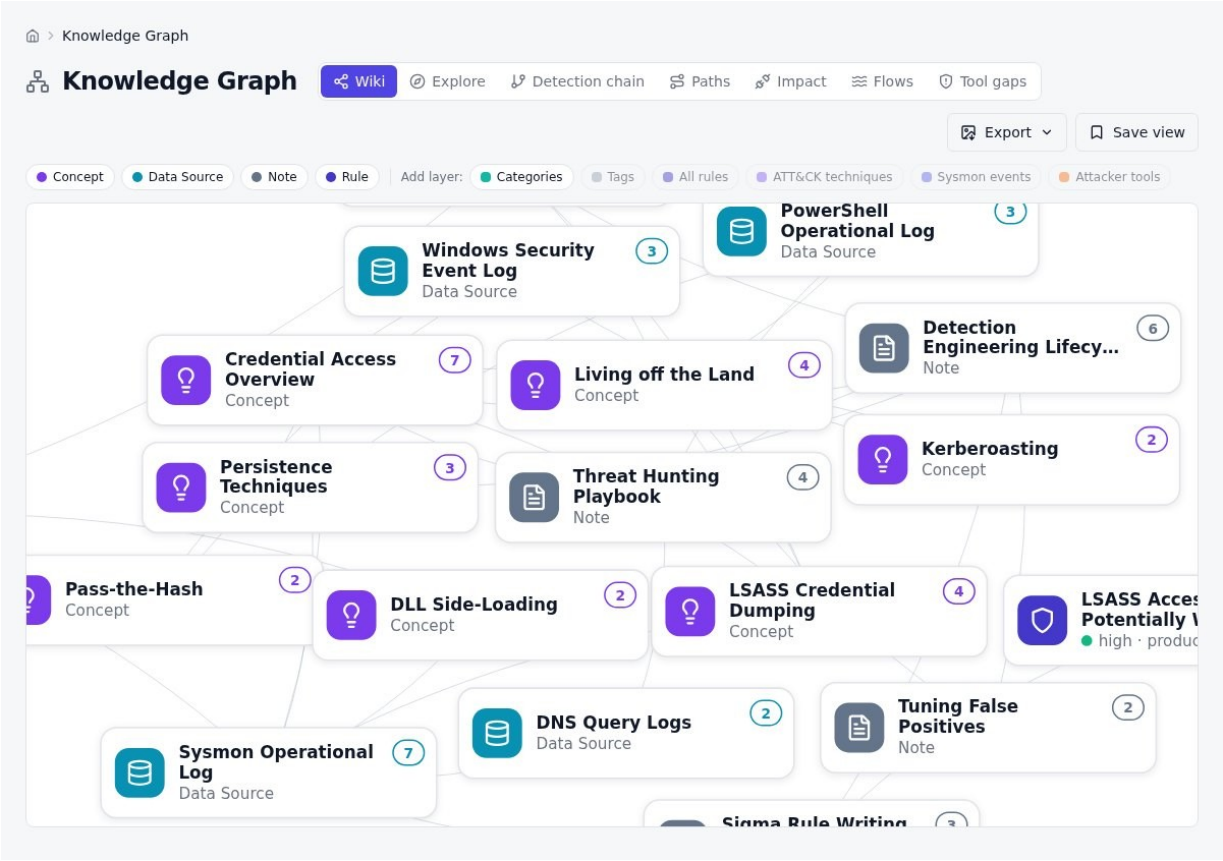
صفحه‌ی **Knowledge Graph** همه‌ی ارتباط‌ها را یک‌جا نشان می‌دهد: صفحه‌ها و لینک‌هایشان، قوانین، تکنیک‌ها، رویدادهای Sysmon و منابع لاگ دیگر، ابزارهای مهاجم، گروه‌های تهدید، بدافزارها، کاهش‌دهنده‌ها، سناریوهای تحلیلی، تگ‌ها و دسته‌ها. گراف هفت نما دارد که با تب‌های بالای صفحه انتخاب می‌شوند:

نما	کاربرد
Wiki	صفحه‌های دانش و لینک‌های بین آن‌ها.
Explore	شروع از یک گره و باز کردن قدم‌به‌قدم همسایه‌ها.
Detection chain	زنجیره‌ی یک تکنیک: تاکتیک ← تکنیک ← قوانین ← رویدادهای لاگ ← منابع داده.
Paths	کوتاه‌ترین مسیرهای ارتباطی بین دو گره.
Impact	اگر یک منبع لاگ، رویداد یا منبع داده قطع شود، چه چیزی از کار می‌افتد.
Flows	جریان تشخیص‌ها از منابع لاگ به تاکتیک‌های ATT&CK.
Tool gaps	ابزارهای مهاجم و تکنیک‌هایی که هیچ قانونی پوششان نمی‌دهد.

وضعیت هر نما در آدرس صفحه ذخیره می‌شود؛ می‌توانید آن را با **Save view** ذخیره کنید یا لینکش را بفرستید.

Wiki

صفحه‌های دانش و لینک‌های ویکی بینشان نمایش داده می‌شوند. هر رنگ یک نوع صفحه است. با چرخ ماوس بزرگ‌نمایی کنید و با کشیدن، گراف را جابه‌جا کنید. با کلیک روی هر گره، پنل جزئیات آن باز می‌شود. با دکمه‌های لایه‌ها می‌توانید قوانین، تکنیک‌ها، رویدادهای Sysmon و لاگ، ابزارها، سناریوهای تحلیلی، گروه‌های تهدید، بدافزارها، کاهش‌دهنده‌ها، تگ‌ها و دسته‌ها را هم به گراف اضافه کنید. لایه‌های بزرگ مثل بدافزارها گراف را شلوغ می‌کنند؛ برای آن‌ها نمای Explore مناسب‌تر است.

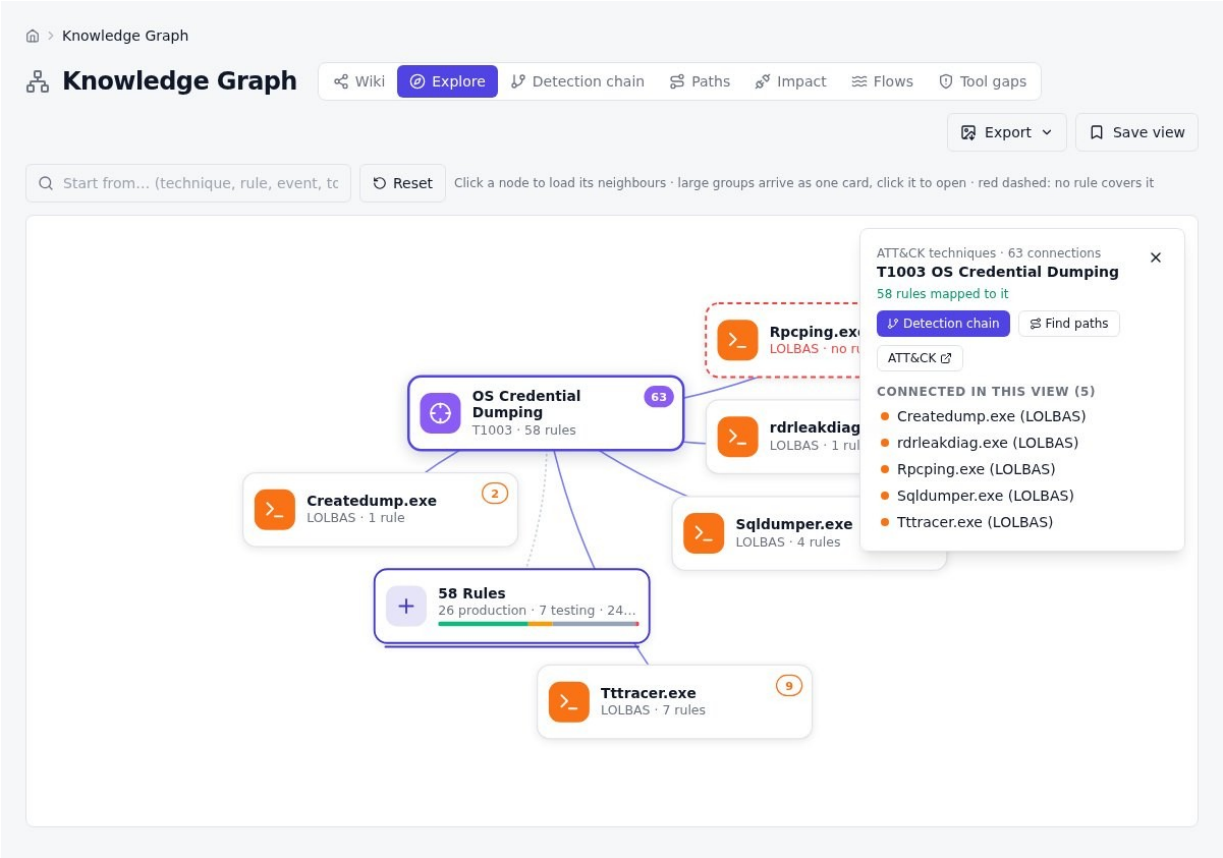


شکل ۴۱ — نمای Wiki

Explore

مناسب‌ترین نما برای کاوش. یک نقطه‌ی شروع انتخاب کنید: در جعبه‌ی **Start from…** جست‌وجو کنید یا یکی از گره‌های پیشنهادی را بزنید. سپس:

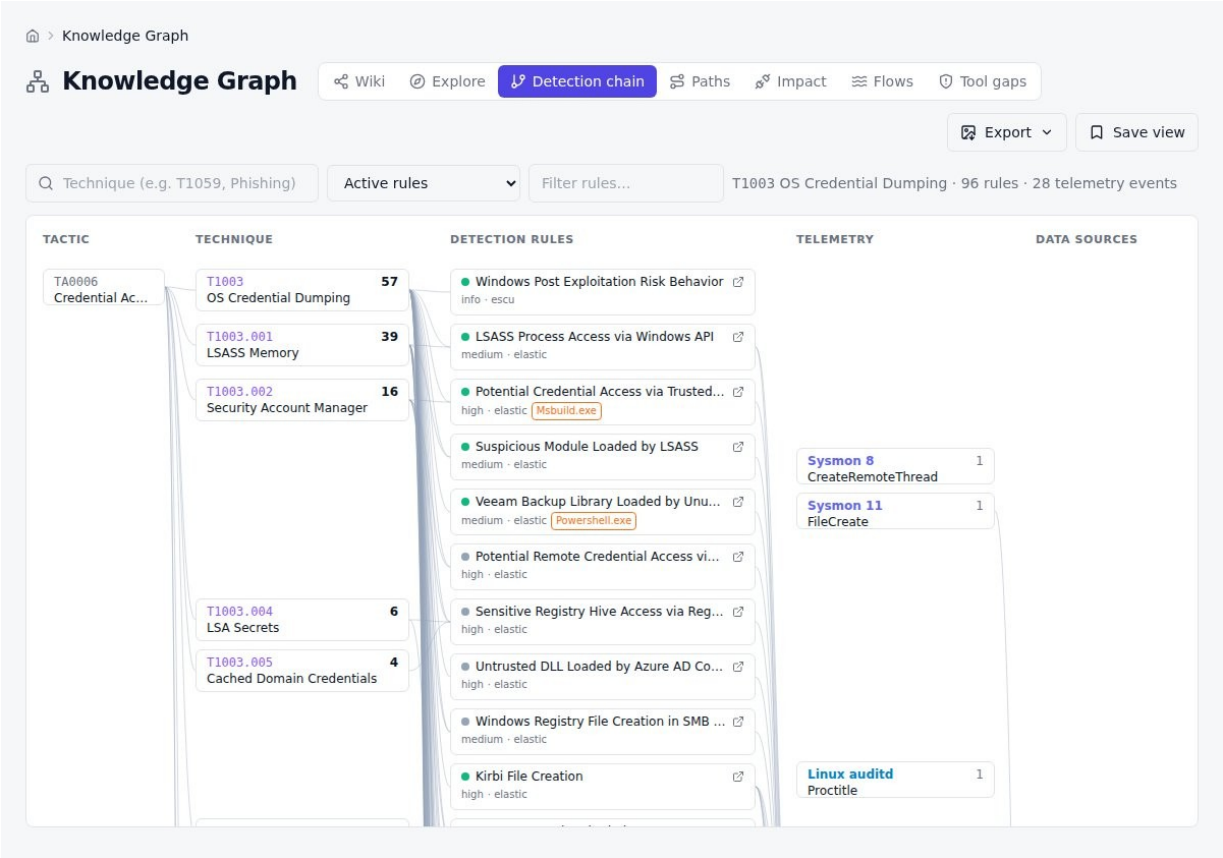
- با کلیک روی هر کارت، همسایه‌هایش بار می‌شوند. عدد گوشه‌ی کارت تعداد کل ارتباط‌های آن است.
- گروه‌های بزرگ، مثلاً ۵۸ قانون یک تکنیک، به شکل یک **کارت گروهی** با نوار وضعیت نمایش داده می‌شوند. با کلیک روی کارت، اعضا ۲۵ تا ۲۵ تا باز می‌شوند.
- کارت با **خط‌چین قرمز** و عبارت **no rules** یعنی ابزار یا تکنیکی که هیچ قانونی پوششش نمی‌دهد: یک شکاف تشخیص.
- در پنل کنار گراف: **Detection chain** زنجیره‌ی تکنیک، **Find paths** یافتن مسیر از این گره، **Start from here** شروع دوباره از این گره، و **Hide** پنهان کردن گره.
- **Reset** گراف را به نقطه‌ی شروع برمی‌گرداند.



شکل ۴۲ — نمای Explore حول تکنیک T1003

Detection chain

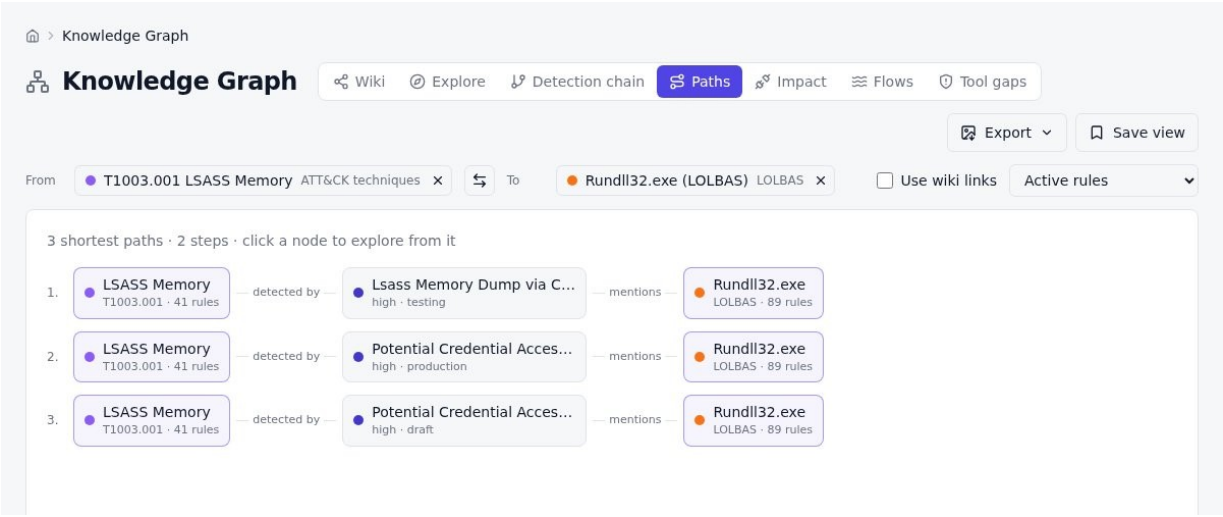
یک تکنیک را انتخاب کنید تا زنجیره‌ی کامل تشخیص آن در ستون‌ها نمایش داده شود: تاکتیک‌ها، تکنیک و زیرتکنیک‌ها، قوانین، رویدادهای لاگ (ستون **Telemetry**: Sysmon، Windows Security، EDR و ...) و منابع داده. ابزارهای مهاجمی که قوانین به آن‌ها اشاره دارند هم نشان داده می‌شوند. ماوس را روی هر مورد ببرید تا مسیر آن پررنگ شود؛ با کلیک، مسیر ثابت می‌ماند. فیلتر وضعیت و جست‌وجو در قوانین هم بالای صفحه است.



شکل ۴۳ — زنجیره‌ی تشخیص T1003

Paths

دو گره را در **From** و **To** انتخاب کنید. سامانه کوتاه‌ترین مسیرهای بینشان را نشان می‌دهد، مثلاً «این ابزار از طریق کدام قوانین به این تکنیک می‌رسد؟». روی هر قدم نوع رابطه نوشته شده است، مثل **detects** (قانون، تکنیک را تشخیص می‌دهد) یا **mentions** (قانون به ابزار اشاره می‌کند). با کلیک روی هر گره مسیر، نمای Explore از آن گره شروع می‌شود. دکمه‌ی ⇄ مبدأ و مقصد را جابه‌جا می‌کند.



شکل ۴۴ — مسیرهای بین T1003.001 و rundll32.exe

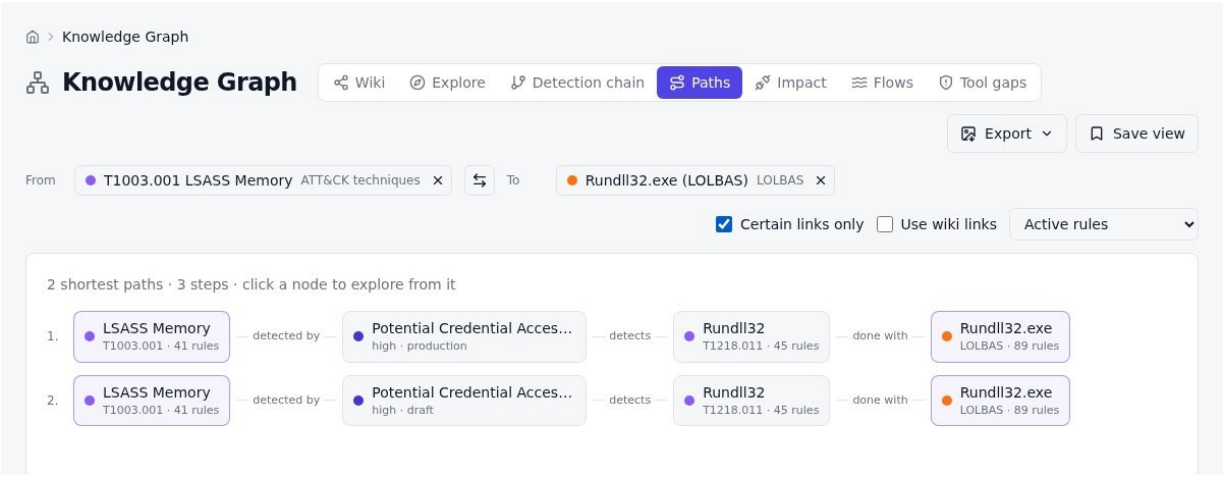
مسیرها فقط از روابط مدل تشخیص می‌گذرند:

- ابزار — تکنیکی که برای آن به کار می‌رود (نگاشت LOLBAS و LOLDrivers)
- قانون — تکنیکی که تشخیص می‌دهد، و ابزاری که در متنش آمده
- قانون — رویداد Sysmon یا رویداد لاگ دیگر — منبع داده‌ای که آن رویداد را فراهم می‌کند
- زیرتکنیک — تکنیک والد
- گروه تهدید، بدافزار یا کاهش‌دهنده — تکنیک‌هایش؛ و سناریوی تحلیلی — قوانینش (این‌ها فقط ابتدا یا انتهای مسیرند)

مثلاً مسیر از گروه APT29 تا رویداد Windows Security 4688 نشان می‌دهد کدام تکنیک‌های این گروه با قوانینی که این رویداد را می‌خوانند تشخیص داده می‌شوند.

چند قاعده برای معتبر ماندن مسیرها:

- تگ‌ها و دسته‌ها هیچ‌وقت گره میانی نیستند.
- رویداد Sysmon یا لاگ فقط یک قانون را به یک منبع داده وصل می‌کند. دو قانونی که هر دو از یک رویداد استفاده می‌کنند، به این دلیل به هم مرتبط حساب نمی‌شوند.
- قوانین deprecated به‌طور پیش‌فرض کنار گذاشته می‌شوند. با منوی وضعیت بالای صفحه می‌توانید فقط Production، Production + testing یا همه را انتخاب کنید.
- لینک‌های ویکی و صفحات Concept و Note فقط با گزینه‌ی **Use wiki links** در مسیر می‌آیند. خود گره‌هایی که انتخاب کرده‌اید همیشه می‌توانند از لینک‌هایشان استفاده کنند. اگر مسیری پیدا نشود ولی با لینک‌های ویکی پیدا شود، سامانه پیشنهادش را می‌دهد.
- از بین کوتاه‌ترین مسیرها، مسیرهایی انتخاب می‌شوند که کمترین هم‌پوشانی را داشته باشند، تا حداکثر ۸ مسیر متفاوت ببینید.
- قدم‌هایی که ارتباطشان استنتاجی یا تطبیق متنی است، با خط‌چین و برچسب **inferred** یا **text match** نمایش داده می‌شوند. گزینه‌ی **Certain links only** این قدم‌ها را کنار می‌گذارد و فقط مسیرهایی را نشان می‌دهد که همه‌ی ارتباط‌هایشان رسمی، اعلام‌شده یا دستی‌اند.

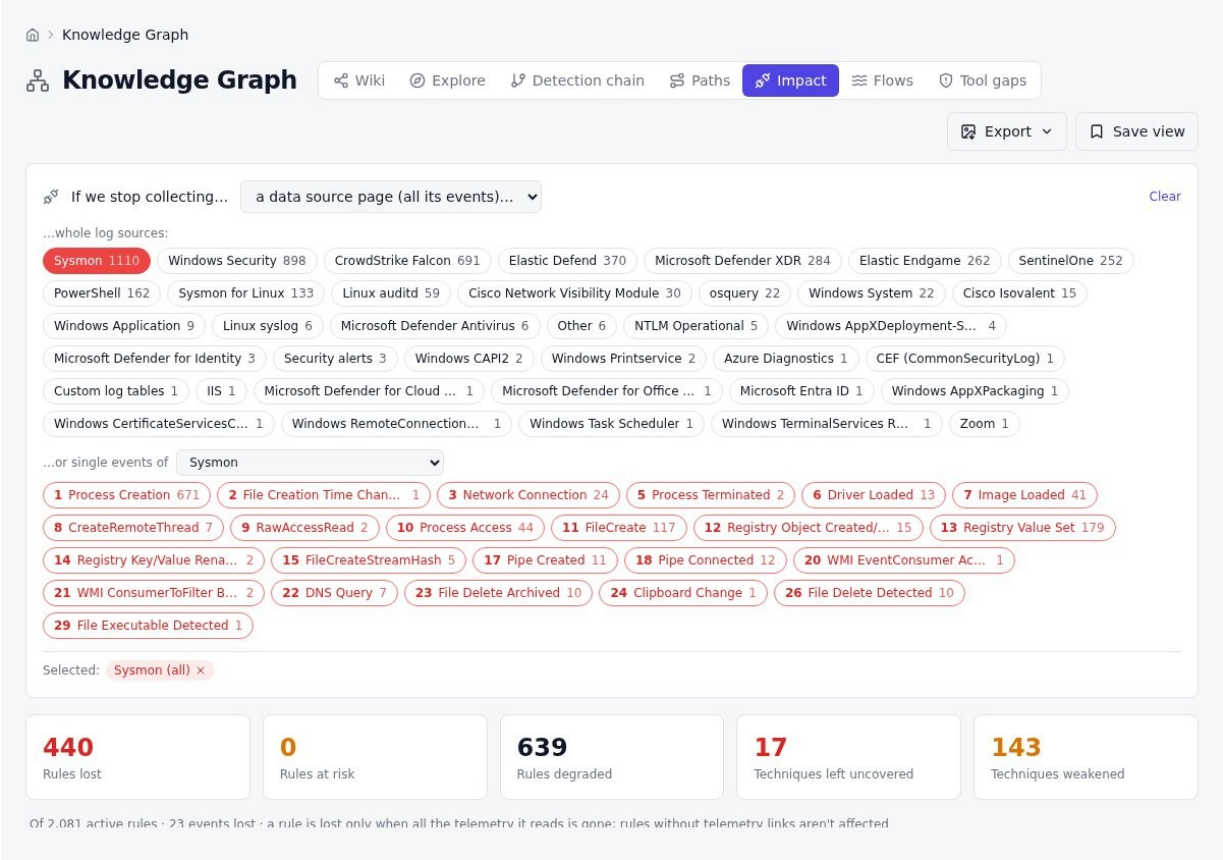


شکل ۴۵ — مسیرهای T1003.001 تا rundll32.exe فقط با ارتباط‌های قطعی

Impact – تحلیل اثر

برای جواب دادن به این سؤال: «اگر جمع‌آوری این داده قطع شود، چه چیزی از دست می‌رود؟»

1. آنچه قطع می‌شود را انتخاب کنید؛ ترکیب هم ممکن است:
2. **…whole log sources:** یک منبع لاگ کامل، مثل Sysmon یا Windows Security. عدد هر دکمه تعداد قوانینی است که از آن منبع استفاده می‌کنند.
3. **…or single events of:** یک منبع را از منو انتخاب کنید و روی رویدادهای مشخص آن کلیک کنید، مثلاً Windows Security 4688.
4. یا از منوی **If we stop collecting…** یک صفحه‌ی منبع داده انتخاب کنید تا همه‌ی رویدادهای آن حساب شوند.
5. انتخاب‌ها در ردیف **Selected** دیده می‌شوند و با ضربدر حذف می‌شوند. نتیجه فوراً نمایش داده می‌شود.



شکل ۴۶ – تحلیل اثر قطع کامل Sysmon

سامانه منابع لاگ هر قانون را جایگزین هم در نظر می‌گیرد: قانونی که هم Sysmon 1 و هم Windows Security 4688 را می‌خواند، با قطع Sysmon از دست نمی‌رود و فقط تضعیف می‌شود. استثنا قوانینی است که به چند رویداد **با هم** نیاز دارند؛ کنار این قوانین عبارت **needs together** آمده و قطع هر کدام از آن رویدادها قانون را از کار می‌اندازد.

نتیجه	معنی
Rules lost	همه‌ی منابع لاگ قانون قطع شده و منبع دیگری هم برایش ثبت نشده است.

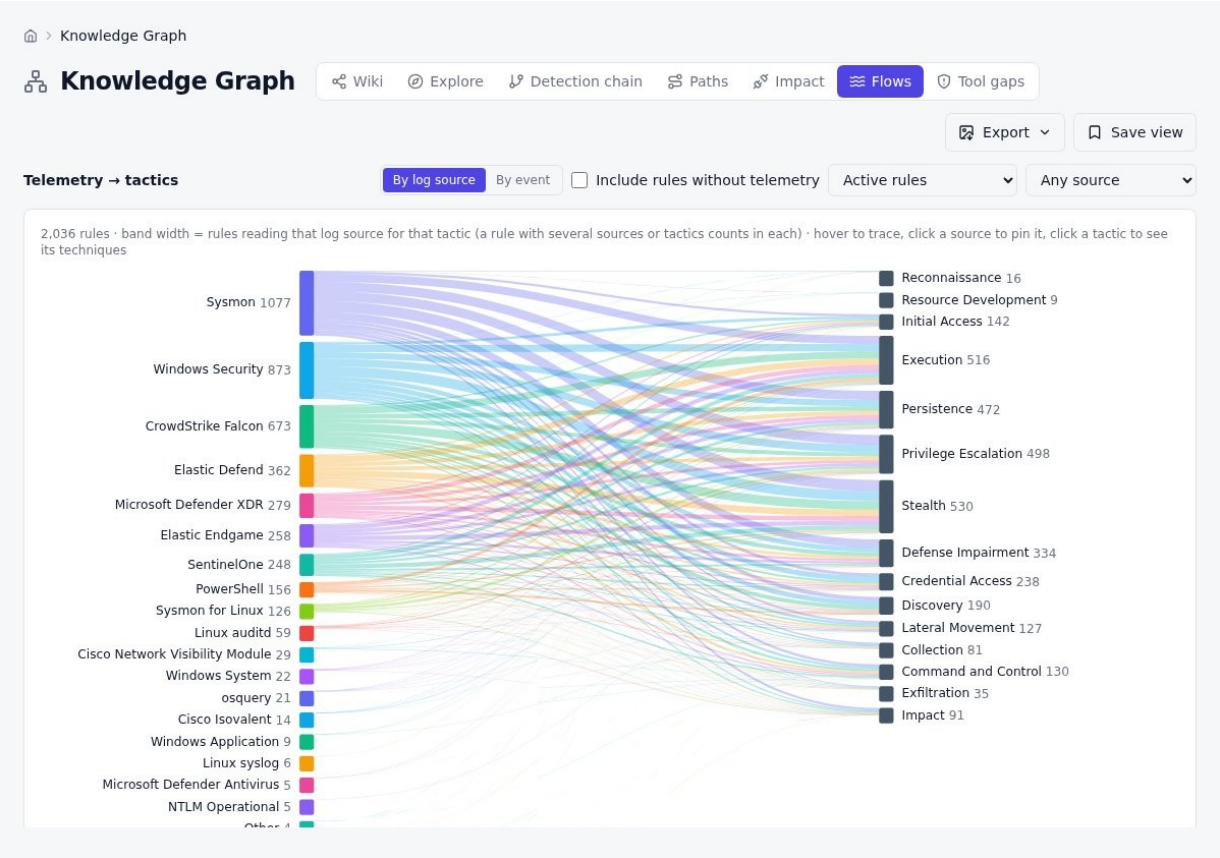
نتیجه	معنی
Rules at risk	همه‌ی منابع لاگ شناخته‌شده‌ی قانون قطع شده، ولی قانون منبع دیگری هم نام برده که سامانه نمی‌شناسد و شاید هنوز کار کند.
Rules degraded	بخشی از منابع لاگ قانون قطع شده و بقیه هنوز کار می‌کنند.
Techniques left uncovered	تکنیک‌هایی که همه‌ی قوانینشان از دست می‌رود. با کلیک، زنجیره‌ی تشخیص آن‌ها باز می‌شود.
Techniques weakened	تکنیک‌هایی که بخشی از قوانینشان را از دست می‌دهند. نوار رنگی سهم باقی‌مانده، در خطر و از دست رفته را نشان می‌دهد.

کاربرانی که مجوز ویرایش قوانین را دارند، کنار فهرست **Affected rules** گزینه‌ی **Set the N lost rules to…** را می‌بینند. با آن فقط قوانینی که برچسب **Lost** دارند به **Deprecated** یا **Draft** می‌روند؛ قوانین در خطر و تضعیف‌شده دست نمی‌خورند. کاربرد اصلی: EDRهایی را که سازمان ندارد با هم انتخاب کنید (مثلاً CrowdStrike، Elastic Defend، SentinelOne) و قوانینی را که فقط به آن‌ها وابسته‌اند کنار بگذارید. همه‌ی EDRهای نداشته را با هم انتخاب کنید؛ قانونی که چند EDR را نام می‌برد با قطع فقط یکی از آن‌ها «Lost» نمی‌شود. این تغییر در Audit log ثبت می‌شود و از صفحه‌ی Detection Rules برگشت‌پذیر است.

> **نکته**
>
> قوانینی که هیچ منبع لاگی برایشان شناخته نشده (معمولاً چون فیلد Data source ندارند) در این محاسبه نیستند. صفحه‌ی **Log Sources** نشان می‌دهد هر قانون به کدام منبع وصل شده است (فصل ۷).

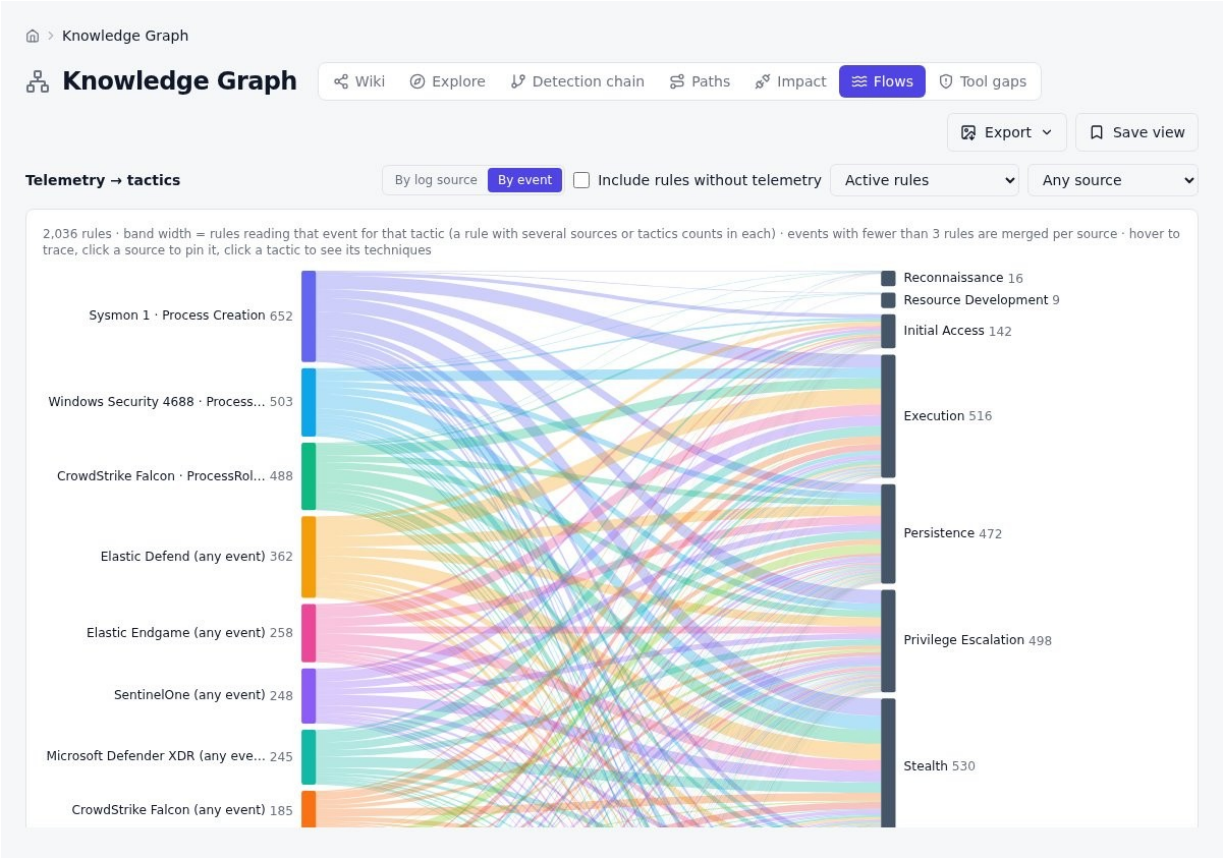
Flows – نمودار جریان

هر نوار نشان می‌دهد چند قانون از یک منبع لاگ (سمت چپ) برای یک تاکتیک ATT&CK (سمت راست) استفاده می‌کنند. پهنای نوار متناسب با تعداد قوانین است. با این نمودار معلوم می‌شود تشخیص هر تاکتیک به کدام داده متکی است.



شکل ۴۷ — نمودار جریان از منابع لاگ به تاکتیک‌ها

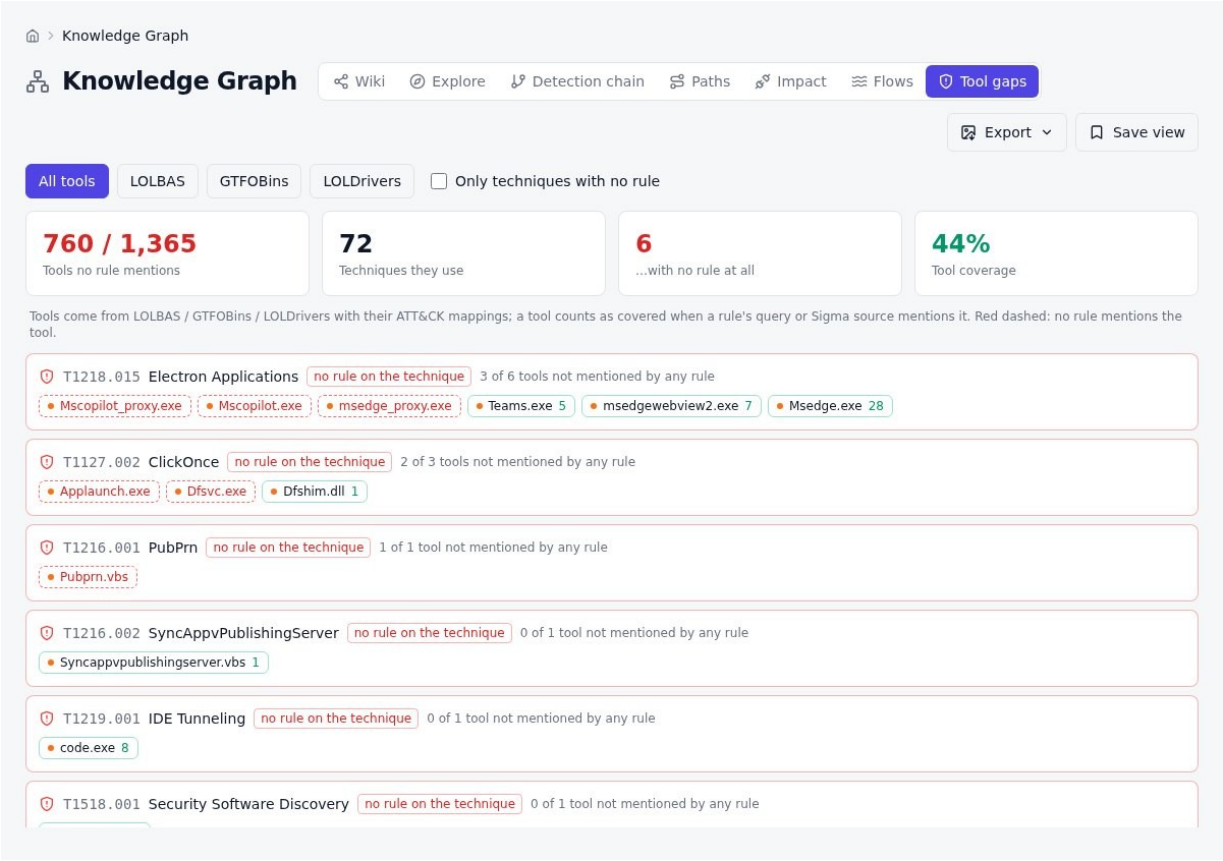
- **By log source / By event:** سمت چپ یا منابع لاگ کامل است (Sysmon، Windows Security، CrowdStrike و …) یا رویدادهای تکی. در حالت رویداد، رویدادهای کوچک (کمتر از ۳ قانون) هر منبع در یک گره «other events» جمع می‌شوند.
- ماوس را روی یک منبع یا تاکتیک ببرید تا جریان‌های آن پررنگ شود.
- با کلیک روی یک تاکتیک، نمودار به تکنیک‌های همان تاکتیک می‌رسد. با کلیک روی یک تکنیک، زنجیره‌ی تشخیص آن باز می‌شود.
- با کلیک روی یک منبع یا رویداد، پنلی باز می‌شود: **What if we lose it?** تحلیل اثر همان منبع، **Rules** فهرست قوانینش و **Reference** صفحه‌ی مرجعش.
- فیلترهای بالا: وضعیت قوانین، منبع قوانین، و **Include rules without telemetry** برای افزودن قوانینی که هیچ منبع لاگی ندارند.



شکل ۴۸ — نمودار جریان در حالت رویداد

Tool gaps — شکاف ابزارها

این نما تکنیک‌هایی را فهرست می‌کند که ابزارهای شناخته‌شده‌ی مهاجم دارند، همراه با ابزارهایی که هیچ قانونی به آن‌ها اشاره نمی‌کند. تکنیک‌هایی که اصلاً قانون ندارند با آیکون هشدار و کادر قرمز، بالای فهرست قرار می‌گیرند.

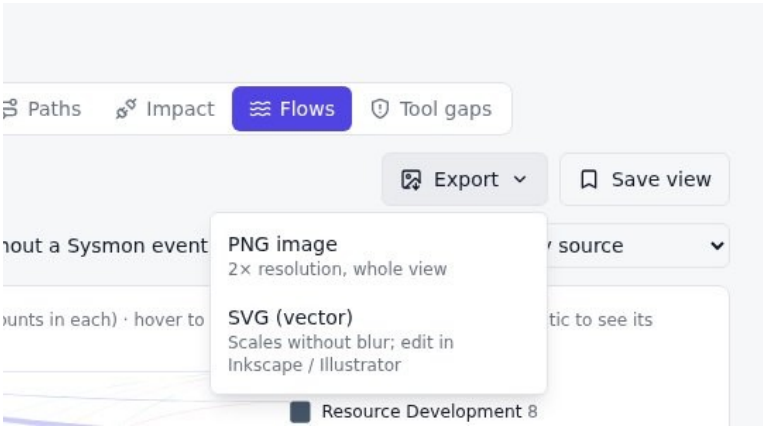


شکل ۴۹ — نمای Tool gaps

- ابزارهای **خطچین قرمز** در هیچ قانونی نیامده‌اند و ابزارهای سبز قانون دارند (با تعداد).
- فیلتر مرجع: **All tools**، **LOLBAS**، **GTFOBins**، **LOLDrivers**. گزینه‌ی **Only techniques with no rule** فقط تکنیک‌های بدون قانون را نشان می‌دهد.
- با کلیک روی تکنیک، نمای Explore از آن شروع می‌شود و با کلیک روی ابزار، صفحه‌ی ابزار باز می‌شود.

خروجی تصویر

دکمه‌ی **Export** بالای گراف، نمای فعلی را ذخیره می‌کند:



شکل ۵۰ — منوی خروجی گراف

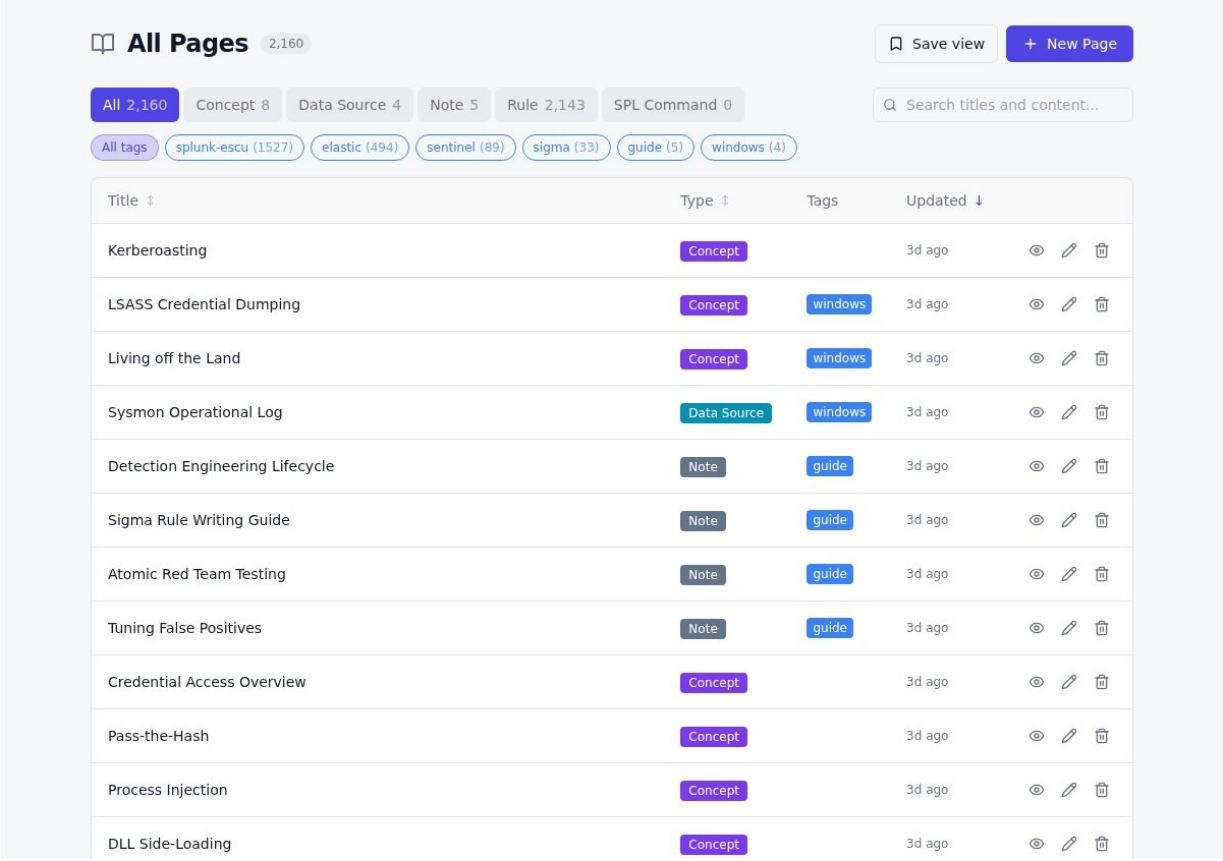
- **PNG image:** تصویر با وضوح دوبرابر از کل نما، حتی بخش‌هایی که دیده نمی‌شوند. برای همه‌ی نماها.
- **SVG (vector):** تصویر برداری که بدون افت کیفیت بزرگ می‌شود. فقط برای نمای Flows.

فصل ۱۳ – صفحات دانش

غیر از قوانین، سامانه صفحه‌های دانش هم دارد: مفاهیم (**Concept**)، منابع داده (**Data Source**)، یادداشت‌ها (**Note**) و دستورهای SPL. همه با Markdown نوشته می‌شوند و با لینک ویکی به هم وصل‌اند.

فهرست همه‌ی صفحه‌ها

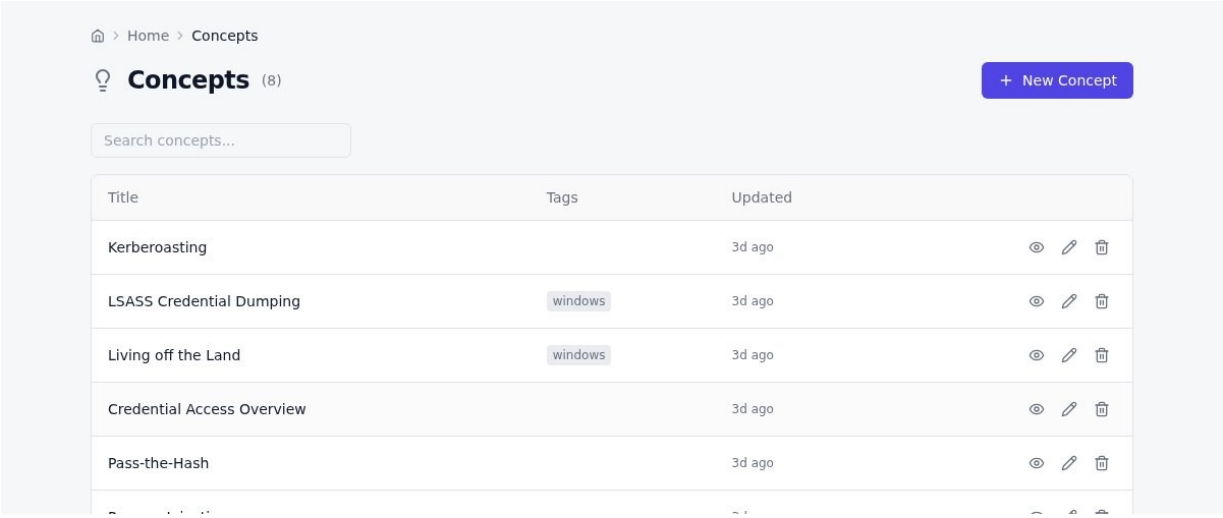
صفحه‌ی **All Pages** همه‌ی صفحه‌ها، از جمله قوانین، را نشان می‌دهد.



شکل ۵۱ – فهرست همه‌ی صفحه‌ها

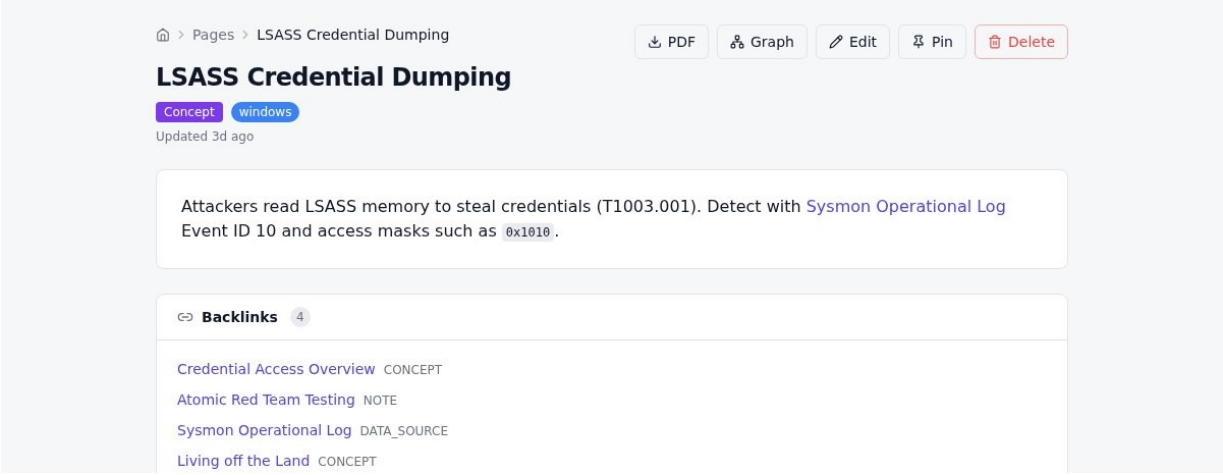
- **دکمه‌های نوع:** فیلتر بر اساس نوع صفحه. عدد کنار هر نوع، تعداد صفحه‌های آن است.
- **تگ‌ها:** فیلتر بر اساس تگ. پرکاربردترین تگ‌ها اول می‌آیند و بقیه پشت **more**.
- **جست‌وجو:** در عنوان و متن صفحه‌ها.
- مرتب‌سازی با کلیک روی سر ستون‌ها (عنوان، نوع، تاریخ)، و صفحه‌بندی پایین جدول.
- دکمه‌های هر ردیف: مشاهده، ویرایش و حذف.

صفحه‌های **Concepts** و **Data Sources** در نوار کناری همین فهرست‌اند، ولی فقط برای یک نوع صفحه.



شکل ۵۲ — فهرست مفاهیم

مشاهده‌ی صفحه



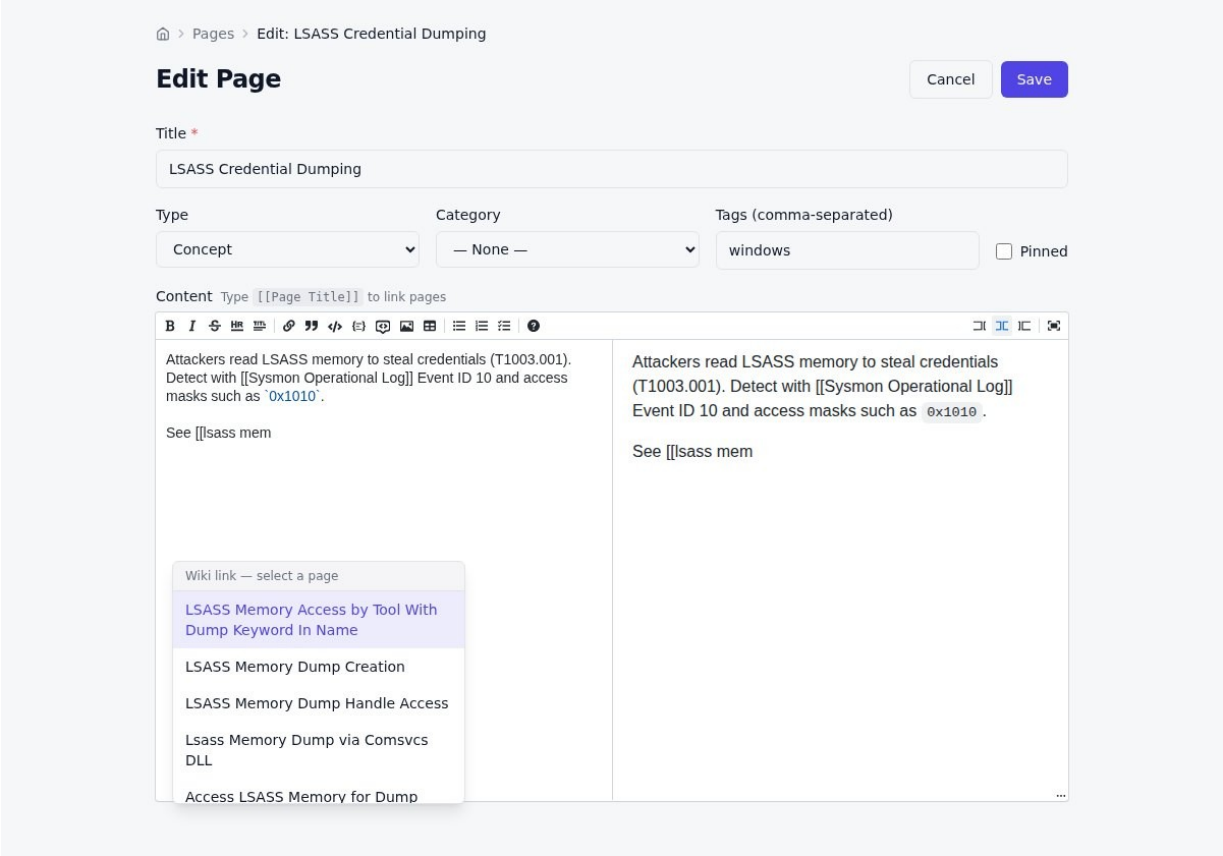
شکل ۵۳ — صفحه‌ی یک مفهوم با لینک ویکی و فهرست Backlinks

- لینک‌های ویکی با رنگ آبی نمایش داده می‌شوند و صفحه‌ی مقصد را باز می‌کنند. لینکی که صفحه‌اش وجود ندارد با رنگ دیگری نمایش داده می‌شود و با کلیک، ساخت آن صفحه شروع می‌شود.
- **Backlinks:** صفحه‌هایی که به این صفحه لینک داده‌اند.
- دکمه‌های بالا مثل صفحه‌ی قانون است: **Pin**، **Edit**، **Graph**، **PDF** و **Delete**.

ساخت و ویرایش صفحه

1. **New Page** را در نوار بالا بزنید، یا در فهرست Concepts و Data Sources دکمه‌ی ساخت همان نوع را.
2. عنوان، نوع، دسته و تگ‌ها را وارد کنید.
3. متن را در کادر **Content** با Markdown بنویسید.
4. **Save** را بزنید.

لینک ویکی: برای لینک به صفحه‌ی دیگر، `[[` تایپ کنید و چند حرف از عنوان صفحه را بنویسید. فهرست پیشنهادها باز می‌شود؛ با کلیدهای جهت‌دار انتخاب و با `Enter` درج کنید. نتیجه به شکل `[[عنوان صفحه]]` در متن قرار می‌گیرد.



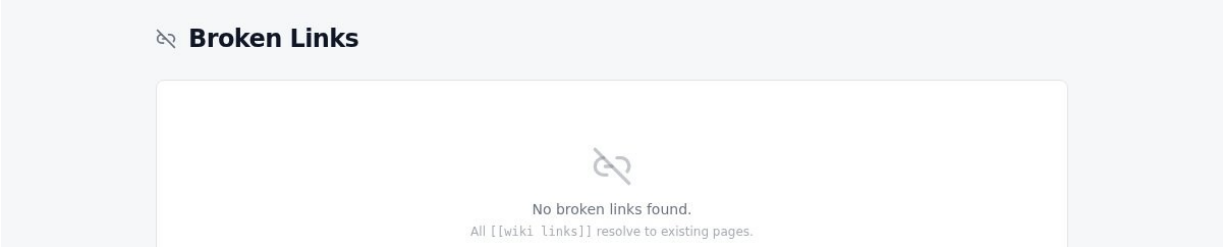
شکل ۵۴ — پیشنهاد صفحه هنگام نوشتن لینک ویکی

دسته‌بندی‌ها

در نوار کناری، کنار **Categories**، دکمه‌ی + را بزنید، نام و رنگ دسته را انتخاب کنید و ذخیره کنید. با کلیک روی نام دسته، صفحه‌های آن نمایش داده می‌شوند. دسته‌ی هر صفحه در فرم ویرایش آن تعیین می‌شود. با حذف یک دسته، صفحه‌هایش حذف نمی‌شوند و فقط بدون دسته می‌مانند.

لینک‌های شکسته

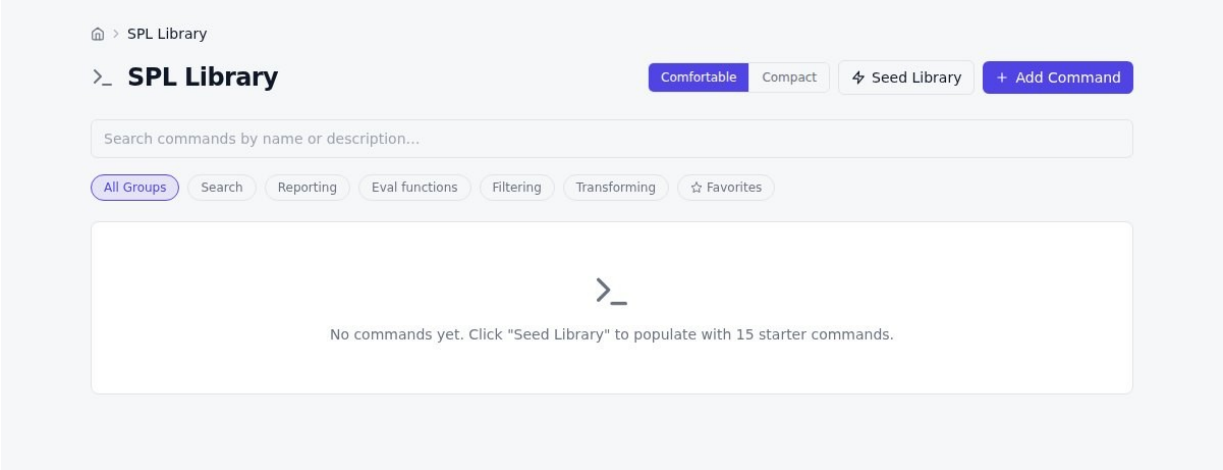
صفحه‌ی **Broken Links** همه‌ی لینک‌های ویکی را که به صفحه‌ی ناموجود اشاره می‌کنند فهرست می‌کند، همراه با صفحه‌ای که لینک در آن است. آن‌ها را اصلاح کنید یا صفحه‌ی مقصد را بسازید.



شکل ۵۵ — صفحه‌ی لینک‌های شکسته (در این نمونه لینک شکسته‌ای وجود ندارد)

کتابخانه‌ی SPL

صفحه‌ی **SPL Library** مجموعه‌ای از دستورهای پرکاربرد Splunk با نحو، توضیح، مثال و نکته‌هاست. با **Add Command** دستور جدید اضافه می‌شود. **Seed Library** مجموعه‌ی آغازینی از ۱۵ دستور رایج را اضافه می‌کند. فیلتر گروه‌ها (Search، Reporting، Eval functions و ...)، علامت‌گذاری علاقه‌مندی‌ها و دو حالت نمایش هم هست.

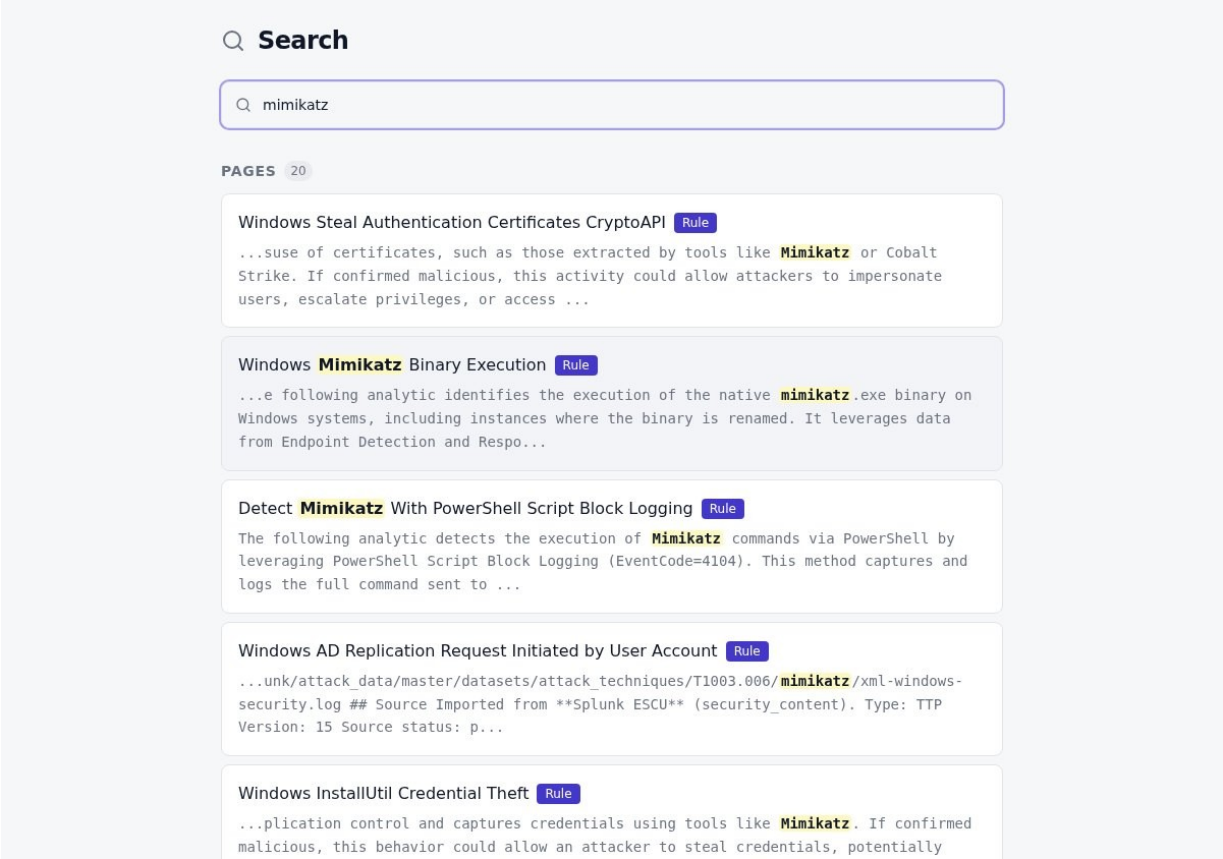


شکل ۵۶ — کتابخانه‌ی SPL

فصل ۱۴ — جست‌وجو و مستندسازی

جست‌وجو

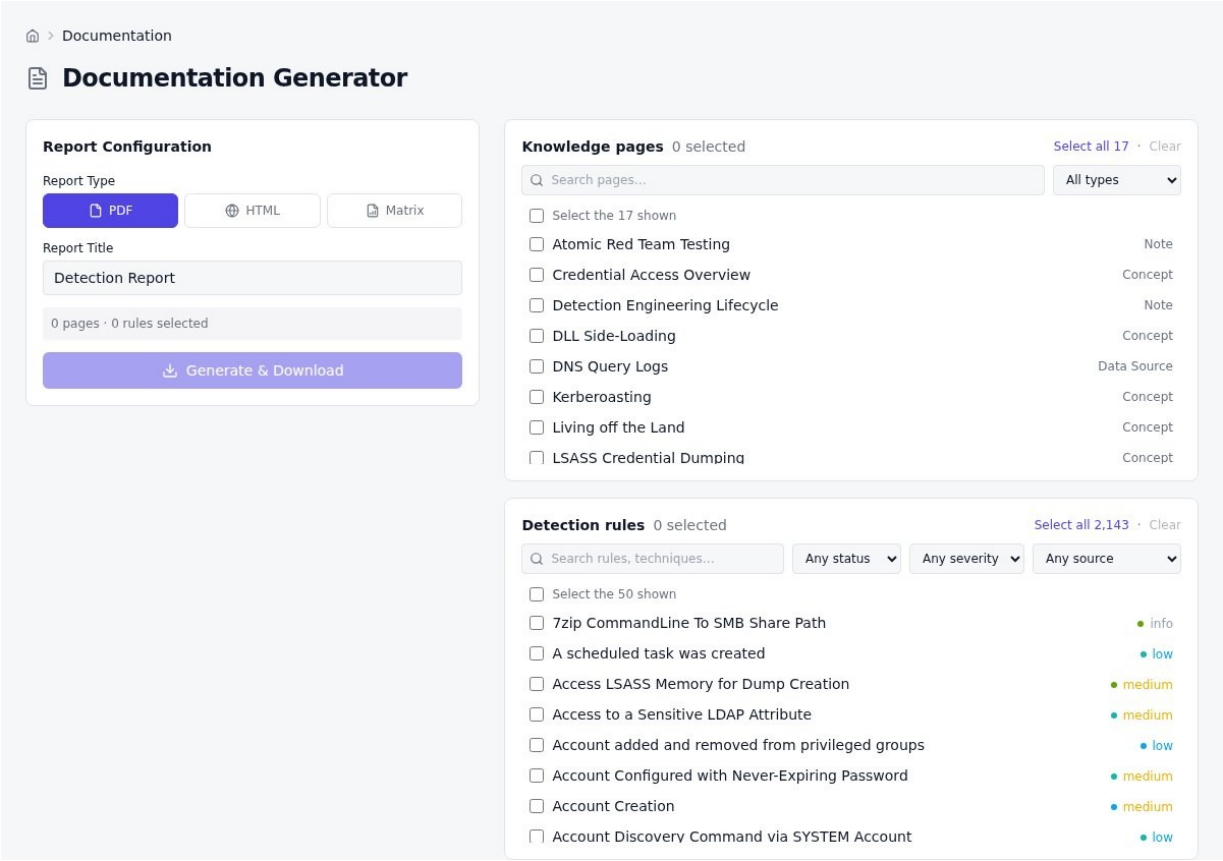
صفحه‌ی **Search** در عنوان و متن همه‌ی صفحه‌ها و قوانین جست‌وجو می‌کند. کلمه‌ی جست‌وجوشده در نتیجه‌ها پررنگ می‌شود و نوع هر نتیجه کنار عنوانش نمایش داده می‌شود. برای جست‌وجوی سریع در هر صفحه، `Ctrl+K` را بزنید (فصل ۲).



شکل ۵۷ — نتیجه‌ی جست‌وجوی mimikatz

ساخت گزارش

صفحه‌ی **Documentation** از صفحه‌ها و قوانین انتخاب‌شده گزارش می‌سازد.



شکل ۵۸ — صفحه‌ی ساخت گزارش

1. نوع گزارش را انتخاب کنید: **HTML**، **PDF** (با فهرست مطالب اختیاری) یا **Matrix** (ماتریس تشخیص بر اساس تکنیک و شدت، با فیلتر تگ اختیاری).
2. عنوان گزارش را بنویسید.
3. در **Knowledge pages** و **Detection rules** موارد مورد نظر را انتخاب کنید. هر دو فهرست جست‌وجو و فیلتر دارند (قوانین با وضعیت، شدت و منبع). **Select all N matching** همه‌ی موارد منطبق با فیلتر را یکجا انتخاب می‌کند و **Show more** موارد بیشتری نشان می‌دهد.
4. **Generate & Download** را بزنید. گزارش ساخته و دانلود می‌شود.

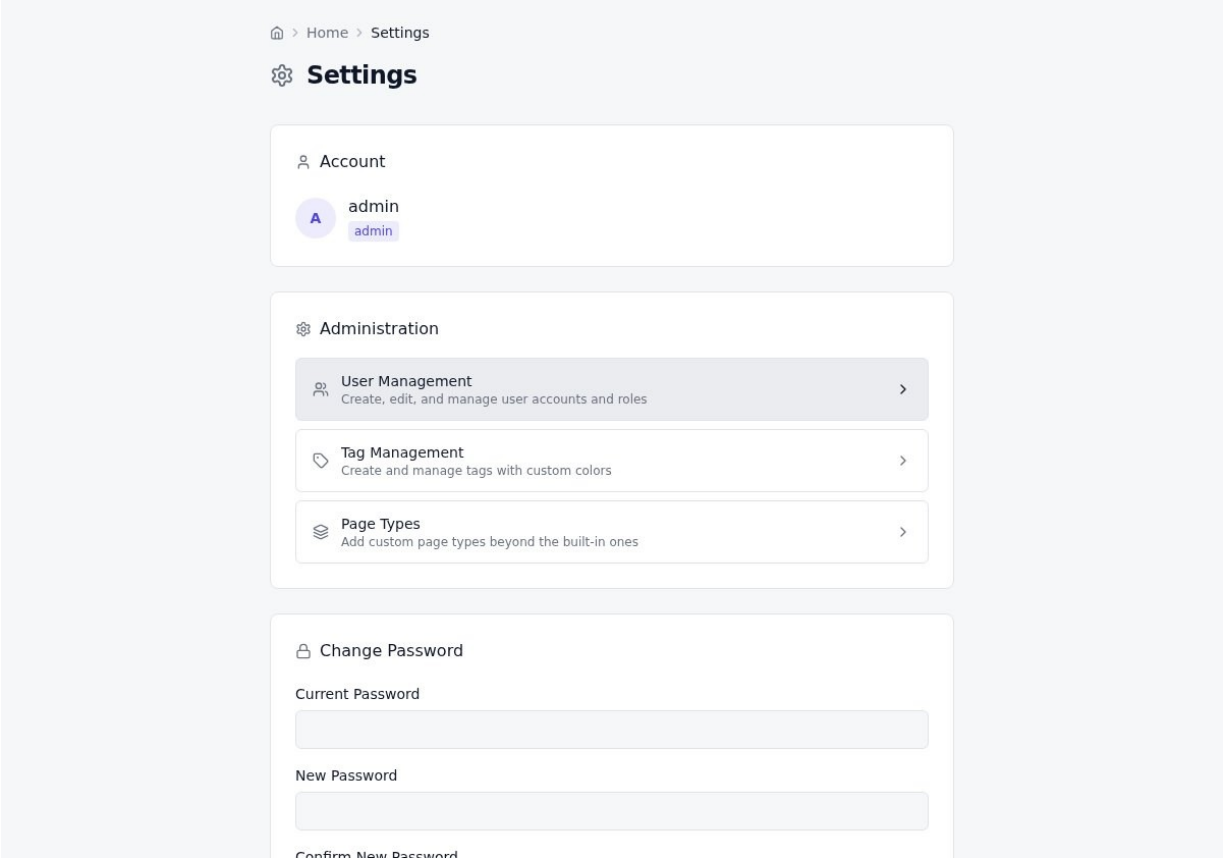
گزارش‌های ساخته‌شده در جدول **Generated Documents** پایین صفحه می‌مانند و از آن‌جا دوباره دانلود یا حذف می‌شوند.

فصل ۱۵ – مدیریت سامانه

تنظیمات و تغییر رمز

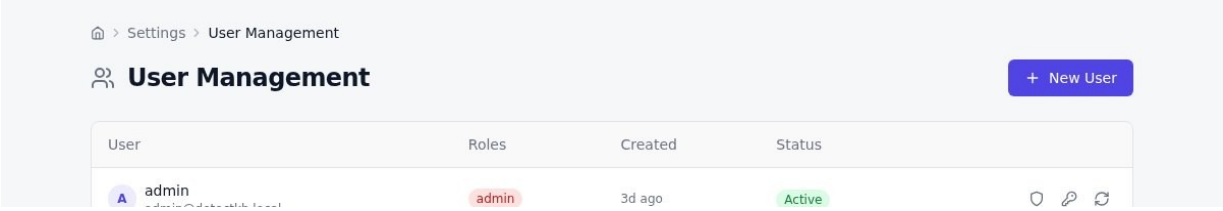
صفحه‌ی **Settings** اطلاعات حساب شما را نشان می‌دهد. در بخش **Change Password** رمز فعلی و رمز جدید را وارد کنید و ذخیره کنید. مدیر در بخش **Administration** به مدیریت کاربران، تگ‌ها و انواع صفحه دسترسی دارد.

قواعد رمز: دست‌کم ۱۰ کاراکتر، حداکثر ۷۲ بایت، بدون نام کاربری، و نه فقط تکرار چند حرف (مثل aaaaaaaaaa). بعد از تغییر رمز، همه‌ی نشست‌های دیگر شما (مثلاً روی رایانه‌ی دیگر) بسته می‌شوند و باید دوباره وارد شوند؛ نشست فعلی باز می‌ماند.



شکل ۵۹ – صفحه‌ی تنظیمات

مدیریت کاربران (مدیر)



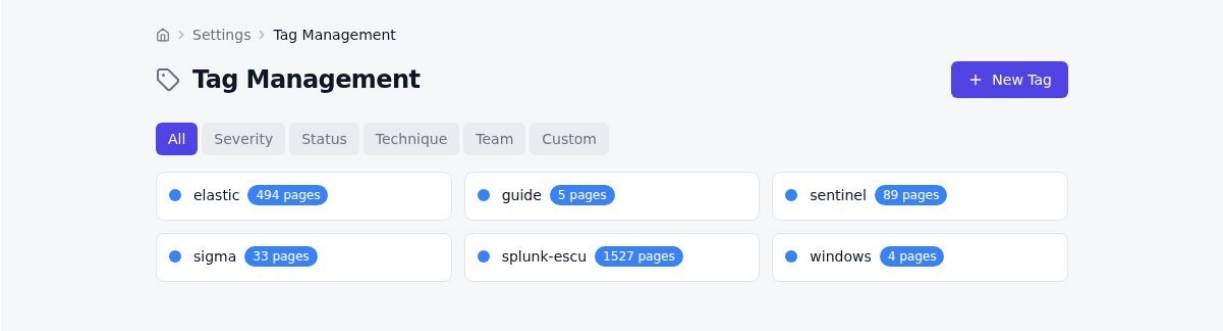
شکل ۶۰ – فهرست کاربران

- **New User:** ساخت کاربر جدید با نام کاربری، ایمیل، رمز اولیه و نقش. کاربر در اولین ورود باید رمزش را عوض کند.
- دکمه‌های کنار هر کاربر: **Edit roles** تغییر نقش‌ها، **Reset password** تعیین رمز جدید (کاربر باید دوباره آن را عوض کند، و همه‌ی نشست‌های قبلی‌اش بسته می‌شود)، و **Disable user** / **Enable user** غیرفعال یا فعال کردن حساب.
- رمز کاربر جدید و رمز بازنشانی‌شده هم باید قواعد رمز را رعایت کنند. نام کاربری فقط حروف انگلیسی، عدد و `_` `.` `-` `@` می‌پذیرد.
- مدیر نمی‌تواند نقش admin را از خودش بگیرد یا حساب خودش را غیرفعال کند.

> **نکته**
>
> به جای حذف کاربری که دیگر نباید وارد شود، حسابش را غیرفعال کنید. سوابق فعالیت او در گزارش فعالیت حفظ می‌شود.

تگ‌ها

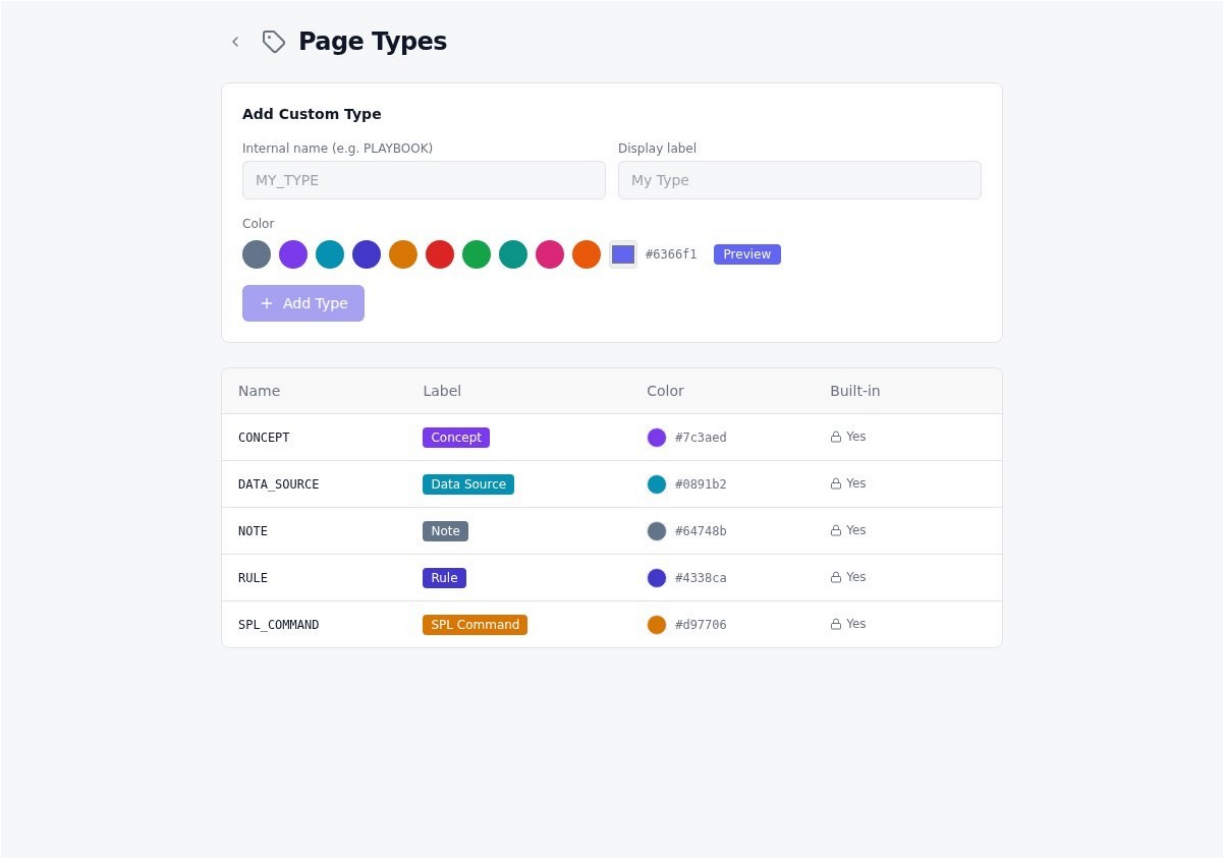
صفحه‌ی **Tag Management** همه‌ی تگ‌ها را با تعداد صفحه‌های هر کدام نشان می‌دهد. با **New Tag** تگ جدید با رنگ و دسته‌ی دلخواه ساخته می‌شود و می‌توانید تگ‌ها را ویرایش یا حذف کنید. تگ‌ها بر اساس دسته (Severity، Status، Technique، Team، Custom) فیلتر می‌شوند.



شکل ۶۱ — مدیریت تگ‌ها

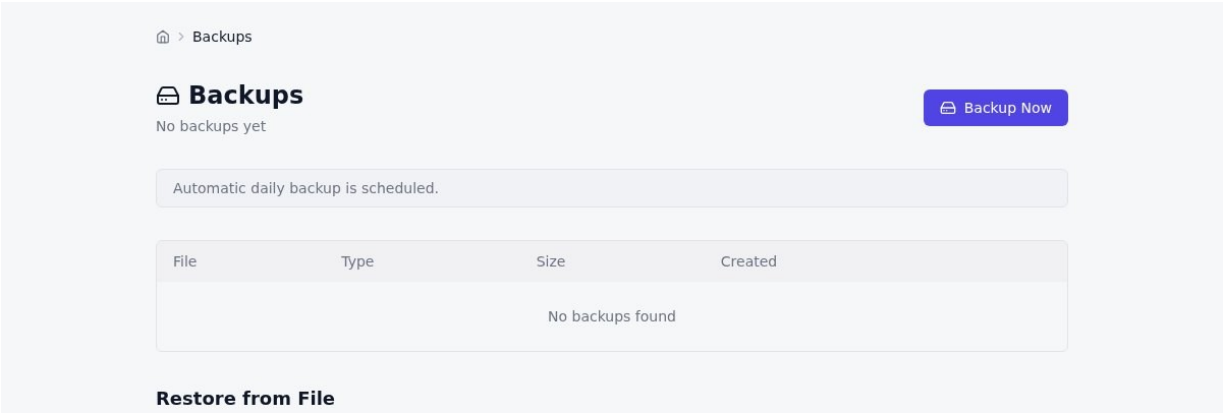
انواع صفحه (مدیر)

غیر از پنج نوع پیش‌فرض (SPL Command، Rule، Note، Data Source، Concept)، می‌توانید نوع دلخواه بسازید، مثلاً Playbook برای روال‌های پاسخ به رخداد. در **Add Custom Type** نام داخلی (حروف بزرگ انگلیسی)، برچسب نمایشی و رنگ را تعیین کنید و **Add Type** را بزنید.



شکل ۶۲ — انواع صفحه

پشتیبان‌گیری و بازگردانی



شکل ۶۳ — صفحه‌ی پشتیبان‌گیری

- **Backup Now:** پشتیبان کامل از پایگاه دانش در قالب JSON، شامل نتیجه‌های تست در لب. فایل در فهرست پایین صفحه قرار می‌گیرد و قابل دانلود است.
- سامانه روزانه یک پشتیبان خودکار هم می‌گیرد.
- **Restore from File:** با **Choose JSON file** فایل پشتیبان را انتخاب و **Restore** را بزنید. این کار فقط برای مدیر است.

توجه

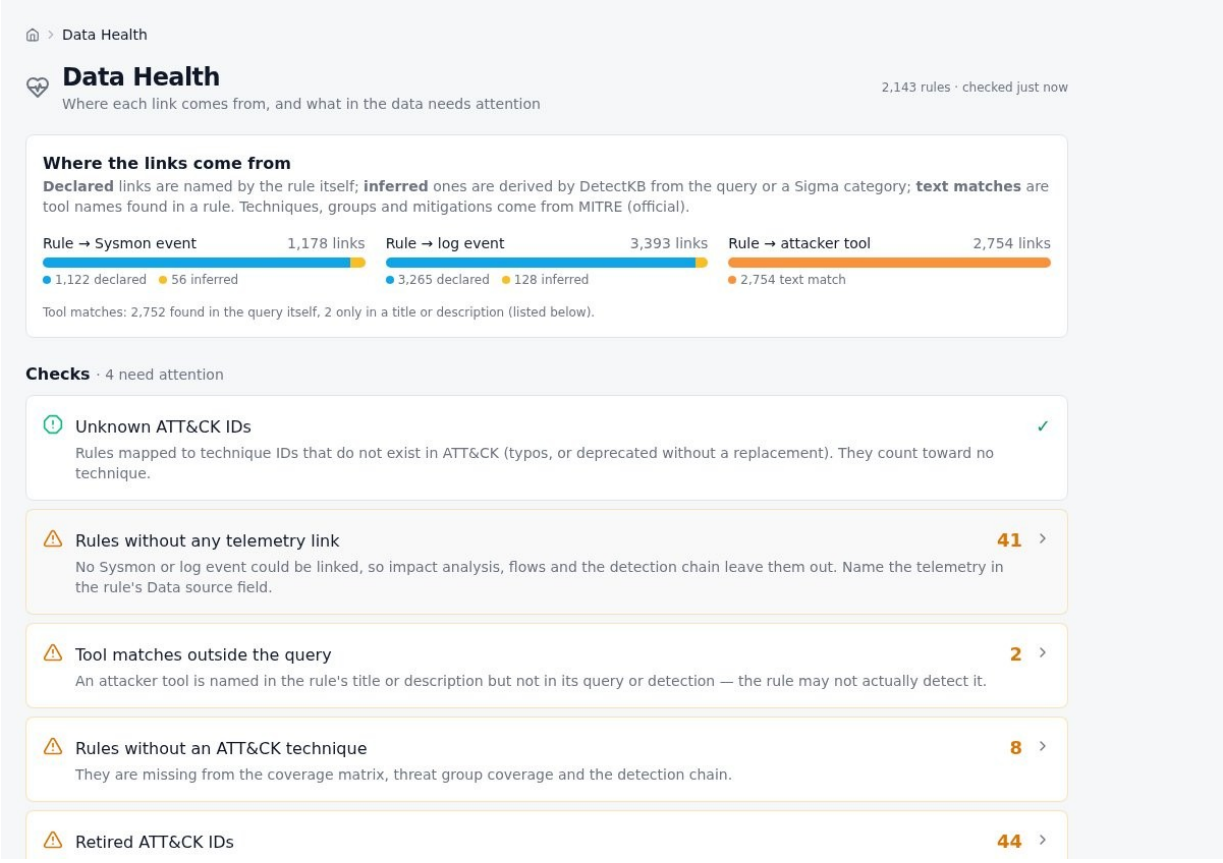
بازگردانی، صفحه‌هایی را که شناسه‌ی آدرس (slug) یکسان دارند بازنویسی می‌کند و قابل بازگشت نیست. قبل از بازگردانی، از وضعیت فعلی پشتیبان بگیرید.

نکته

برای پشتیبان کامل در سطح سرور، دستور `./install.sh update` قبل از هر به‌روزرسانی از دیتابیس MySQL نسخه‌ی پشتیبان می‌گیرد و آن را در پوشه‌ی `backups` ذخیره می‌کند.

سلامت داده

صفحه‌ی **Data Health** در بخش Tools نشان می‌دهد ارتباط‌های سامانه از کجا آمده‌اند و چه چیزی در داده‌ها نیاز به رسیدگی دارد.

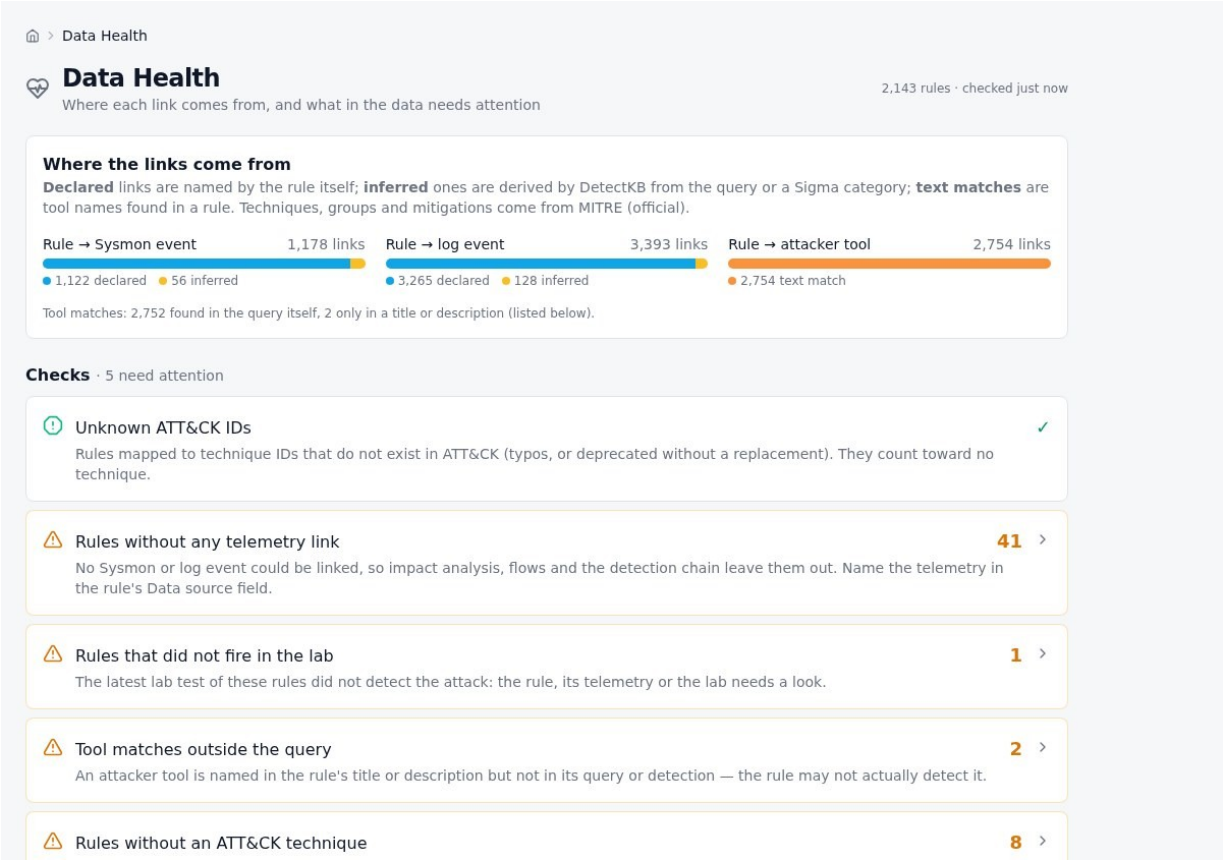


شکل ۶۴ — صفحه‌ی سلامت داده

- **Where the links come from:** سهم ارتباط‌های اعلام‌شده، استنتاجی و تطبیق متنی، برای ارتباط قانون با رویدادهای Sysmon، رویدادهای لاگ و ابزارهای مهاجم.

- **Checks:** هر بررسی تعداد موارد را نشان می‌دهد؛ با کلیک، فهرست قوانین مربوط با لینک به صفحه‌ی هر قانون باز می‌شود. تیک سبز یعنی مشکلی نیست.

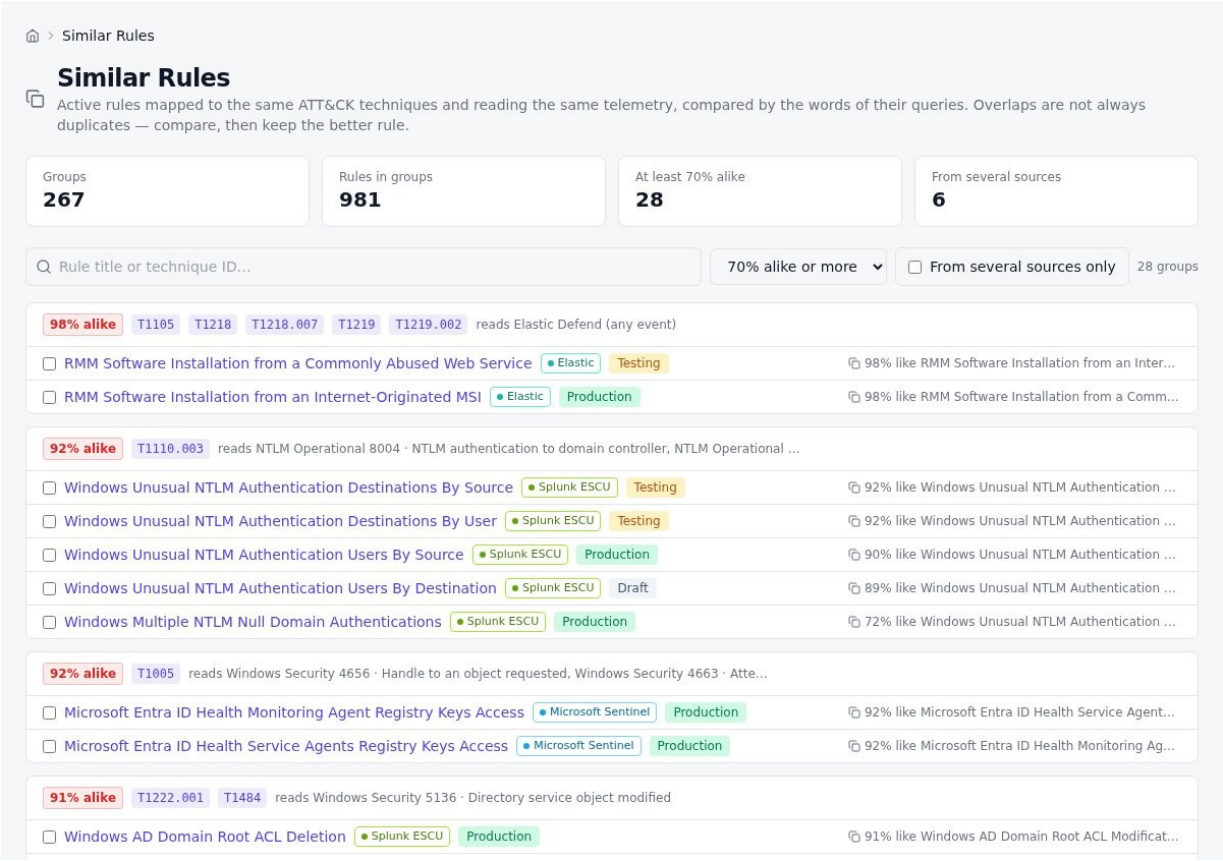
بررسی	معنی
Unknown ATT&CK IDs	شناسه‌ی تکنیکی که در ATT&CK وجود ندارد؛ معمولاً اشتباه تایپی.
Rules that did not fire in the lab	آخرین تست این قوانین در لب حمله را تشخیص نداد (فصل ۱۱).
Rules without any telemetry link	قوانینی که هیچ منبع لاگی برایشان شناخته نشده؛ در تحلیل اثر و نمودار جریان حساب نمی‌شوند.
Tool matches outside the query	نام ابزار فقط در عنوان یا توضیح قانون آمده، نه در کوئری؛ شاید قانون واقعاً آن را تشخیص ندهد.
Rules without an ATT&CK technique	قوانین بدون نگاشت ATT&CK؛ در پوشش حساب نمی‌شوند.
Retired ATT&CK IDs	شناسه‌هایی که MITRE بازنشسته کرده است. دکمه‌ی **Replace with MITRE's IDs** در همین کارت همه را یک‌جا با شناسه‌ی جایگزین MITRE عوض می‌کند (کوئری قوانین دست نمی‌خورد).
Telemetry only inferred	همه‌ی منابع لاگ این قوانین استنتاجی‌اند و خود قانون هیچ‌کدام را نام نبرده است.
Rules needing several events at once	قوانینی که شرط AND دارند.
Data sources DetectKB does not know	نام‌هایی در فیلد منبع داده که سامانه نمی‌شناسد؛ این قوانین در تحلیل اثر «در خطر» حساب می‌شوند.
Imported rules changed upstream	قانون‌هایی که مخزن اصلی‌شان نسخه‌ی جدیدتری دارد (فصل ۴).
Lab results to redo	کوئری قانون بعد از تست تغییر کرده یا تست قدیمی‌تر از ۹۰ روز است.
Production rules never tested in the lab	قوانین Production که هیچ نتیجه‌ی تستی ندارند.
Production rules without false positives	قوانین Production که توضیح مثبت کاذب ندارند.
Rules with the same title	قوانین هم‌نام؛ اغلب یک قانون که از دو منبع وارد شده است.
Overlapping rules	دسته‌هایی از قوانین با تکنیک و تله‌متری یکسان که کوئری‌شان دست‌کم ۷۰٪ شبیه است. لینک کارت به صفحه‌ی **Similar Rules** می‌رود.
Analytic stories without a description	سناریوهایی که هنوز توضیح ندارند.
Data source pages without telemetry	صفحه‌های منبع داده که هیچ رویدادی را نام نمی‌برند.



شکل ۶۵ — بررسی‌های اعتبارسنجی در صفحه‌ی سلامت داده

قوانین مشابه

صفحه‌ی **Similar Rules** در بخش Tools قوانین فعالی را کنار هم می‌گذارد که دقیقاً به همان تکنیک‌های ATT&CK نگاشت شده‌اند و همان تله‌متری را می‌خوانند؛ یعنی چیزی را تشخیص می‌دهند که قانون دیگری هم تشخیص می‌دهد. درون هر دسته، قوانین بر اساس کلمات کوئری و عنوانشان مقایسه می‌شوند. کلمات رایج (مثل `tstats` در همه‌ی قوانین ESCU) وزن کمی دارند و کلمات خاص (نام پروسه، مسیر، سوییچ خط فرمان) وزن زیاد.



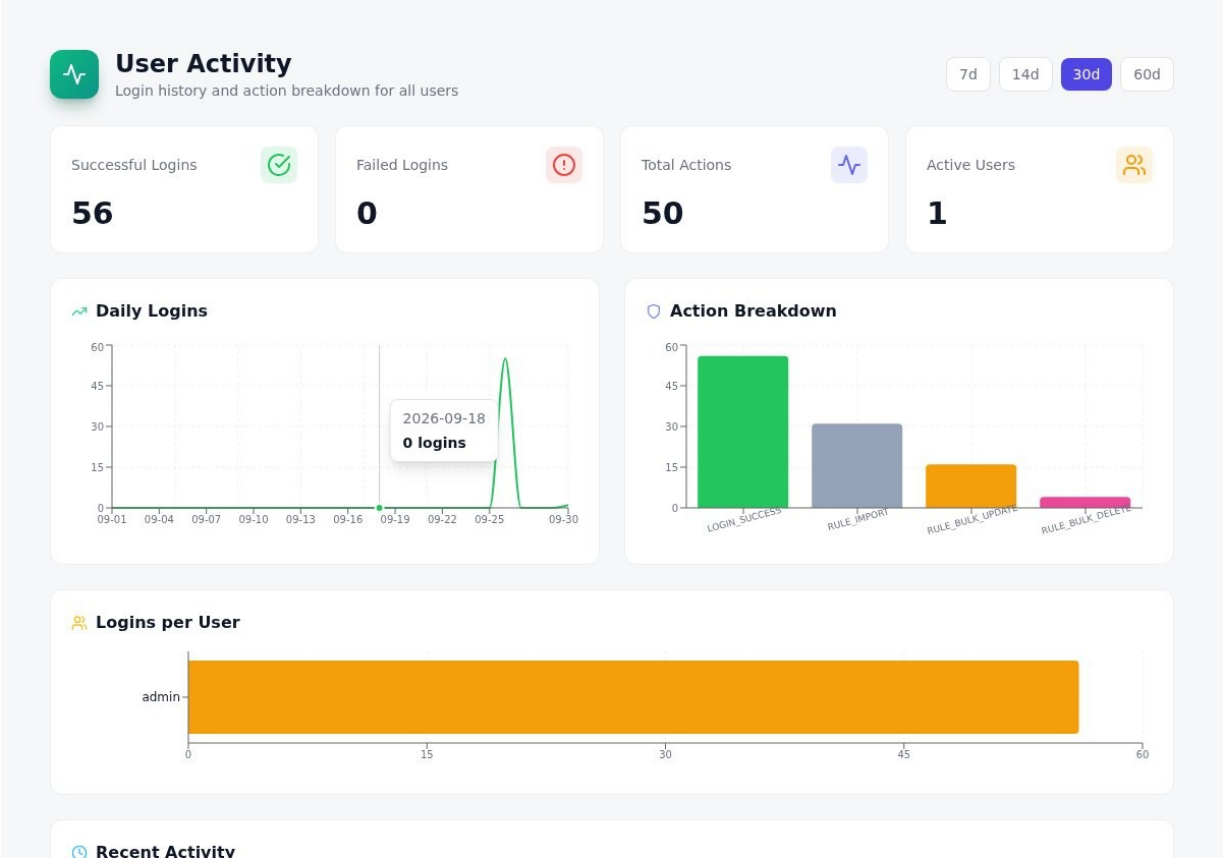
شکل ۶۶ — دسته‌های قوانین مشابه، به ترتیب شباهت

- **کارت‌های بالا:** تعداد دسته‌ها، قوانین درون دسته‌ها، دسته‌هایی که دست‌کم ۷۰٪ شبیه‌اند و دسته‌هایی که قوانینشان از چند منبع آمده‌اند (مثلاً ESCU و Sigma).
- **فیلترها:** حداقل شباهت (پیش‌فرض ۷۰٪)، فقط دسته‌های چندمنبعی، و جست‌وجو بر اساس عنوان قانون یا شناسه‌ی تکنیک.
- **درصد کنار هر قانون:** شباهت آن قانون به نزدیک‌ترین قانون دسته. با کلیک، دو قانون کنار هم باز می‌شوند: تکنیک‌ها، منبع داده، مثبت کاذب، کوئری‌ها و کلماتی که فقط در هر کدام هست.
- **Set N to deprecated:** قوانین انتخاب‌شده‌ی یک دسته را deprecated می‌کند (با تأیید، و فقط برای کاربرانی که مجوز ویرایش قوانین دارند).

> **نکته**
>
> شباهت بالا لزوماً به معنی تکراری بودن نیست: نسخه‌های «By User» و «By Source» یک قانون ESCU عمداً جدا هستند. قبل از کنار گذاشتن، دو قانون را مقایسه کنید.

گزارش فعالیت (مدیر)

صفحه‌ی **Activity** فعالیت کاربران را در بازه‌ی ۷، ۱۴، ۳۰ یا ۶۰ روز گذشته نشان می‌دهد: تعداد ورودهای موفق و ناموفق، تعداد عملیات، کاربران فعال، نمودار ورود روزانه، تفکیک نوع عملیات (مثل ورود قانون و تغییر گروهی)، ورود هر کاربر و فهرست آخرین رویدادها.



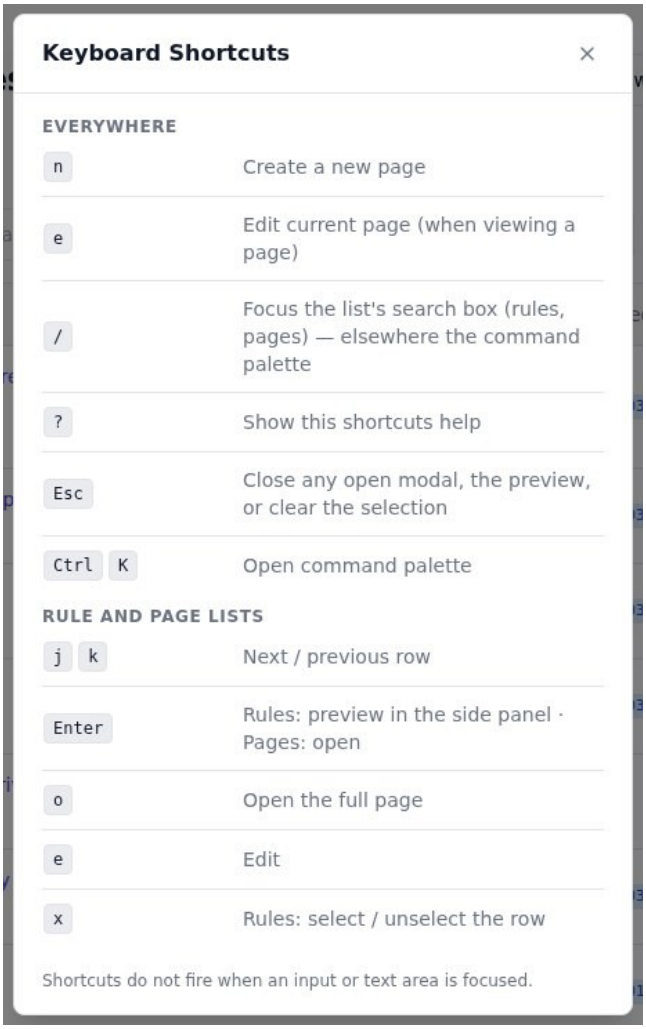
شکل ۶۷ — گزارش فعالیت کاربران

فصل ۱۶ – میانبرهای صفحه‌کلید و ظاهر

با میانبرها، بدون ماوس و سریع‌تر کار می‌کنید. فهرست کامل با کلید `?` در هر صفحه نمایش داده می‌شود.

کلید	کار
`Ctrl+K`	جست‌وجوی سریع
`/`	رفتن به جعبه‌ی جست‌وجوی فهرست (قوانین و صفحه‌ها)؛ در صفحه‌های دیگر، جست‌وجوی سریع
`n`	ساخت صفحه‌ی جدید
`e`	ویرایش صفحه‌ی فعلی یا ردیف انتخاب‌شده در فهرست
`j` / `k`	ردیف بعدی و قبلی در فهرست قوانین و صفحه‌ها. اگر پیش‌نمایش باز باشد، قانون بعدی در آن نمایش داده می‌شود.
`Enter`	قوانین: باز کردن پیش‌نمایش · صفحه‌ها: باز کردن صفحه
`o`	باز کردن صفحه‌ی کامل ردیف انتخاب‌شده
`x`	انتخاب یا لغو انتخاب ردیف (فهرست قوانین)
`Esc`	بستن پنجره یا پیش‌نمایش؛ بار دوم، پاک کردن انتخاب‌ها
`?`	نمایش فهرست میانبرها

میانبرها وقتی داخل یک جعبه‌ی متن هستید کار نمی‌کنند. برای خروج از جعبه‌ی متن، `Esc` را بزنید یا جای دیگری کلیک کنید.



شکل ۶۸ — پنجره‌ی راهنمای میانبرها

حالت تاریک

با دکمه‌ی ماه یا خورشید در نوار بالا، بین حالت روشن و تاریک جابه‌جا شوید. انتخاب شما در همان مرورگر به خاطر سپرده می‌شود.



شکل ۶۹ — داشبورد در حالت تاریک

فصل ۱۷ — پرسش‌های رایج و عیب‌یابی

چرا قوانینی که وارد کردم در پوشش ATT&CK حساب نشده‌اند؟

پوشش به‌طور پیش‌فرض همه‌ی قوانین به‌جز deprecated را حساب می‌کند. اگر فیلتر وضعیت روی **Production only** باشد، قوانین draft حساب نمی‌شوند. همچنین قانون باید در فیلد **MITRE Techniques** شناسه‌ی تکنیک معتبر داشته باشد.

چرا رویداد Sysmon یک قانون تشخیص داده نشده است؟

تشخیص خودکار از کوئری SPL (مثل `EventCode=10` همراه با نام Sysmon) یا logsource قانون Sigma انجام می‌شود. اگر کوئری از ماکرو یا نام دیگری استفاده کند، رویداد را دستی از فرم ویرایش قانون اضافه کنید.

تبدیل Sigma کار نمی‌کند.

اگر پیام **The Sigma conversion service is not running** نمایش داده شود، سرویس تبدیل Sigma اجرا نیست. به مدیر سیستم اطلاع دهید. بقیه‌ی بخش‌های سامانه بدون این سرویس کار می‌کنند.

ابزارهای مهاجم خالی‌اند یا قدیمی شده‌اند.

مدیر باید در صفحه‌ی **Attacker Tools** با **Update from source** داده‌ها را به‌روز کند. روی سرور بدون اینترنت، از **Upload file** استفاده کنید (فصل ۸).

ناگهان از سامانه خارج شدم.

نشست ورود ۲۴ ساعت اعتبار دارد. همچنین اگر رمز شما (توسط خودتان روی دستگاه دیگر یا توسط مدیر) تغییر کند یا حسابتان غیرفعال شود، نشست‌های قبلی بسته می‌شوند. دوباره وارد شوید.

قانونی که تست کرده بودم دوباره Retest شده است.

کوئری قانون بعد از آخرین تست تغییر کرده (حتی با ویرایش یا ورود دوباره‌ی قانون)، یا تست قدیمی‌تر از ۹۰ روز است. تست را دوباره اجرا و نتیجه را ثبت کنید.

تست اجرا شد ولی قانون هشدار نداد.

قبل از اصلاح قانون، بررسی کنید حمله واقعاً اجرا شده، لاگ تولید شده و به Splunk رسیده است. جدول «اگر قانون هشدار نداد» در فصل ۱۱ را ببینید.

رمزم را فراموش کرده‌ام.

از مدیر سامانه بخواهید با **Reset password** برایتان رمز موقت تعیین کند. بعد از ورود، سامانه از شما می‌خواهد رمز جدید انتخاب کنید.

سامانه بالا نمی‌آید و در لاگ خطای P1000 دیده می‌شود (برای مدیر سیستم).

رمز دیتابیس در فایل `.env` با رمزی که دیتابیس با آن ساخته شده یکی نیست. این معمولاً وقتی پیش می‌آید که فایل `.e` `nv` جدیدی کنار دیتابیس قبلی ساخته شود. فایل `.env` نصب قبلی را برگردانید، یا اگر به داده‌ها نیاز ندارید، با `docker compose down -v` دیتابیس را پاک و سامانه را دوباره نصب کنید. جزئیات در بخش Troubleshooting فایل README هست.